Auditoria Técnica e Visual do Portfólio GitHub

Data: 13 de outubro de 2026 (America/Sao_Paulo)
Perfil: arthurjoanes
Entrega principal: AUDITORIA_COMPLETA_PORTFOLIO.md

Edição revisada após as correções locais. As Partes 1-2 e os achados da Parte 8 conservam o diagnóstico e as notas da auditoria inicial; não descrevem automaticamente o código já corrigido. A Parte 3 traz trechos atuais e pontuais, e a Parte 5 reúne os 47 IDs. A revisão por repositório e imagem distingue o que foi confirmado, corrigido novamente e não reexecutado. As versões anteriores estão preservadas em `_revisao_conformidade_2026-10-13/antes-*.md`. Não houve publicação destas alterações no GitHub.

Inventário: 11 repositórios públicos identificados e 11 examinados: 8 projetos próprios, 1 perfil e 2 forks. Nos forks, a revisão profunda se limita ao diff autoral e aos exemplos afetados; não abrange a biblioteca upstream inteira.

Plano atualizado: 47 problemas registrados: 0 P0, 24 P1 e 23 P2. São 38 achados da primeira rodada e 9 complementares na Parte 8. A ausência de P0 significa que não foi demonstrada falha crítica dentro das verificações realizadas, não uma certificação de segurança.

Tecnologias encontradas: Python, FastAPI, Pydantic, PostgreSQL/PostGIS, Redis, SQLAlchemy, React, Next.js, TypeScript, Vite, PySpark, Delta Lake, Kafka, Debezium, Docker, Caddy/Nginx, MapLibre, Leaflet, pytest, Vitest e Playwright. Spark/Scala/Java do fork Delta são tecnologias do upstream; sua autoria não é atribuída ao dono do fork.

Sumário

- Parte 1 - Diagnóstico geral
- Parte 2 - Auditoria individual
- Parte 3 - Revisão de documentação
- Parte 4 - Revisão de UI/UX
- Parte 5 - Plano de correção consolidado
- Parte 6 - Checklist de implementação
- Parte 7 - Parecer final
- Parte 8 - Revisão complementar de segurança, operação e contratos
- Fontes e critérios
- Registro de cobertura e evidências

Repositórios: arthurjoanes · evidencedesk · gestao-recebiveis · loja-assistente · varejo-data-pipeline · api-sentinel · containerops · cycleops · quake-exposure · delta · fastapi-pagination

Parte 1 - Diagnóstico geral

O portfólio tem evidências de engenharia além de CRUD: isolamento por organização, idempotência, controle de concorrência, recuperação de jobs, contratos de dados, publicação consistente, replay e observabilidade. README, runbooks, fixtures e testes permitem discutir essas decisões com base no código. Não é necessário adicionar mais camadas ou novos projetos para demonstrar complexidade.

As principais lacunas encontradas estão nas bordas dos fluxos: estados aceitos pelo frontend e recusados pelo backend, resultado incerto de uma operação, exportações expiradas, identidade persistente de incidentes, restauração de histórico e validação de arquivos que alimentam a visualização. A apresentação visual é coerente nas interfaces renderizadas; os defeitos de fluxo e contrato prejudicam mais a confiança do que a paleta ou a quantidade de componentes.

A documentação dos projetos próprios costuma explicar dados sintéticos, dependências externas e limites de operação. Os ajustes recomendados são localizados: receitas por sistema operacional, limites de navegação, contratos desatualizados e distinção entre comportamento atual e pretendido. As substituições da Parte 3 preservam a voz de um desenvolvedor; trechos condicionados à implementação estão identificados.

CycleOps e QuakeExposure oferecem a menor barreira para uma primeira avaliação: as demos abriram sem autenticação. O perfil ainda não as apresenta. EvidenceDesk e Gestão de Recebíveis exigem atenção aos fluxos centrais antes de uma demonstração guiada. Varejo Data Pipeline tem um defeito reproduzido na ordenação da última tentativa após restauração; API Sentinel precisa preservar a identidade das ocorrências após retenção. ContainerOps teve achados de apresentação e empacotamento do relatório, sem falha de fila ou isolamento demonstrada nesta revisão.

Há consistência de linguagem visual entre os projetos: tons escuros no cabeçalho, superfícies claras, tabelas, sinais de estado e indicação de dados de demonstração. Isso não prova geração automática nem constitui defeito. Cada projeto mantém um objeto de trabalho distinto: incidente, recebível, consulta, publicação, estação ou ativo. As propostas preservam essas diferenças.

Escopo, limites e método

• O perfil foi confirmado pelo usuário. O inventário veio da API pública do GitHub, com página de até 100 itens e 11 resultados, sem paginação restante. Repositórios privados de arthurjoanes não puderam ser inventariados: o conector disponível está ligado a outra conta. Não entram nesta contagem.

• Os oito clones originais do workspace estavam limpos e seus HEADs coincidiam com os remotos. QuakeExposure foi obtido em uma cópia separada para auditoria; a pasta local QuakeExposure continha material de planejamento, não o clone publicado.

• Diretórios `_privado`, prompts de implementação, rascunhos e outras contribuições locais não foram tratados como conteúdo público do perfil. Não houve commit, push, PR nem edição dos repositórios originais.

• A revisão é dirigida a arquivos e fluxos relevantes, com inventário por projeto. Não equivale a leitura linha a linha de todos os arquivos, teste de penetração, auditoria de dependências completa ou garantia de ausência de falhas.

• O Docker CLI está instalado, mas o daemon Linux estava indisponível. PostgreSQL, Redis, Spark, Kafka, Debezium, cargas e recuperação operacional não foram reexecutados quando dependiam desse daemon. Os comandos e resultados realmente executados estão na Parte 2.

• As demos públicas foram observadas no estado servido em 13/10/2026; o SHA do deployment do Pages não foi certificado. As análises de código usam os commits identificados. Capturas históricas foram distinguidas de telas renderizadas nesta auditoria.

• Testes usaram cópias temporárias ou execução sem cache/bytecode nos arquivos originais. Ambientes virtuais existentes foram reutilizados em parte; aprovação de um subconjunto não prova instalação limpa de todos os lockfiles.

Comparação dos repositórios

Escala de 0 a 5: 0 = inviável no escopo observado; 1 = falhas dominantes; 2 = lacunas grandes; 3 = adequado com limitações; 4 = consistente com correções localizadas; 5 = evidência forte e completa para o uso examinado. N/A evita dar nota à arquitetura upstream ou à UI não examinada. As notas são juízo técnico baseado na cobertura registrada, não medidas de senioridade.

Repositório	Engenharia	Documentação	UI/UX	Reprodução
arthurjoanes	N/A	4/5	N/A	N/A
evidencedesk	4/5	4.5/5	3.5/5	3.5/5
gestao-recebiveis	4/5	4.5/5	3.5/5	4/5
loja-assistente	4/5	4.5/5	3.5/5	4/5
varejo-data-pipeline	4/5	4.5/5	4/5	4/5
api-sentinel	4/5	4/5	4/5	4/5
containerops	4.5/5	4/5	4/5	4/5
cycleops	4/5	4/5	4/5	4/5
quake-exposure	4/5	4/5	4/5	4/5
delta	N/A	4/5	N/A	4/5
fastapi-pagination	N/A	4/5	N/A	4/5

Justificativas por dimensão:

arthurjoanes. Engenharia: Perfil, sem implementação executável. Documentação: Texto direto, foco técnico e separação de experiência/projetos. Falta exposição dos dois projetos com demo. UI/UX: README; não foi feita auditoria visual do render do perfil no GitHub. Reprodução: Não se aplica.

evidencedesk. Engenharia: Separação de domínios, revisão imutável, autorização no servidor, jobs/leases e testes relevantes são evidências concretas de engenharia. Os defeitos encontrados concentram-se nos contratos entre fluxo assíncrono e interface; EVD-01/02/03 impedem classificar os fluxos de recuperação como maduros. Documentação: README contextualiza problema, limites e origem das evidências; documentação operacional e verificador de links funcionam. Restam divergências pequenas mas concretas entre API e schemas/interface. UI/UX: Capturas mostram identidade coerente e boa apresentação de fonte/contexto; código oferece estados e controle de foco. Fluxos de devolução, exportação e validação repetida precisam correção. Nota provisória, sem sessão atual de navegador. Reprodução: Há scripts, CI e instruções detalhadas; verificação de documentação e 71 testes atuais passaram. A instalação completa com PostgreSQL, frontend e worker não foi reproduzida nesta auditoria.

gestao-recebiveis. Engenharia: Modelagem transacional, idempotência e recuperação do worker são acima de um CRUD básico. Listas que carregam todas as parcelas merecem contrato mais enxuto; integração completa não foi reexecutada. Documentação: Problema, testes, provas históricas, captura e limitações bem ligados a fontes. README pode encurtar a entrada e incorporar claramente limites atuais de navegação/filtros sem duplicar o inventário. UI/UX: Tela financeira coerente, boa prioridade a saldo e feedback de fluxo. Estado fora da URL, filtros incompatíveis e cascata de tablet prejudicam uso contínuo; avaliação atual é estática com imagens históricas. Reprodução: Compose, locks, wrappers, papéis de banco e provas são concretos. axe-core é usado sem declaração direta. O daemon ausente limita a confiança desta execução, sem imputar falha ao setup.

loja-assistente. Engenharia: Responsabilidades reais de domínio, cálculo monetário controlado, consultas predefinidas, autorização, reservas de orçamento e evidência de avaliação distinguem o projeto de um wrapper de chat.

Recuperação de POST e carregamento parcial ainda têm defeitos relevantes. Documentação: Explica Demo versus LLM, precisão de cálculo, limites, custos e evidência histórica com verificação de integridade. A leitura de resultados de várias rodadas pode ser condensada sem apagar proveniência. UI/UX: Capturas mostram boa hierarquia, recorte próximo aos números e esclarecimento acionável. Histórico, datas e recuperação em falhas precisam melhorias; nota provisória porque o navegador atual não foi executado. Reprodução: Recibos, hashes, fontes históricas e scripts de verificação são fortes. 61 testes atuais selecionados passaram; não se confirmou a instalação completa com o ambiente declarado do projeto.

varejo-data-pipeline. Engenharia: Contratos, snapshot de publicação, precisão e testes de recuperação são fortes. Ordenação por mtime e exportação HTML sem troca atômica deixam falhas específicas verificáveis. Documentação: README conecta problema, fontes, provas, execução e limites com clareza. Há excesso de recibos e datas na página de entrada e falta instalação versionada do harness de navegador. UI/UX: Relatório com hierarquia clara, valores/tabelas e distinção entre ausência e zero. Amostra atual renderizada em três larguras sem overflow global; fluxos completos e acessibilidade assistiva não foram reexecutados. Reprodução: Runtime, wrappers, fixtures e contratos favorecem reprodução. O harness de UI não tem lock próprio, e um teste puro falha no host Windows; Docker indisponível limita a verificação atual, sem ser atribuído ao produto.

api-sentinel. Engenharia: Há isolamento por tenant antes do cache, quota Redis atômica, concorrência limitada, cursor autenticado, deadline do ERP e cancelamento com liberação de recursos. A reutilização de IDs no receiver compromete identidade histórica e precisa ser corrigida. Documentação: Propósito, contas, contratos, evidência histórica e limitações são descritos com precisão. O caminho Linux termina em exemplos PowerShell e o guia pode expor melhor a limitação de descoberta depois das 100 ocorrências. UI/UX: A interface renderizada nas três larguras manteve layout coerente, sem erro JS ou overflow global no estado inicial. Há estados e semântica operacional cuidadosos. Falta descoberta além de 100 ocorrências sem ID conhecido. Reprodução: Runner isolado, workflows, imagens/lock e testes numerosos tornam a reprodução plausível e auditável. Unidade executada com resultado registrado; stack e integração não reexecutadas nesta subauditoria.

containerops. Engenharia: O código examinado implementa transações de admissão, idempotência por owner, fencing de lease, retry limitado e restauração isolada com fases e limpeza verificadas. A inspeção não encontrou falha funcional confirmada nesses caminhos; não equivale a revisão exaustiva de todos os scripts de supply chain. Documentação: O README e guias explicam contrato, operação, confiança na origem, prova local e limites de evidência. Os guias copiados para a sessão mantêm links que não resolvem no pacote, e exemplos do relatório atendem apenas PowerShell. UI/UX: Relatório com identidade própria, navegação por operação, catálogo filtrável, estados separados de integridade/restore e comportamento sem JavaScript. Render inicial coerente nas três larguras; precisão da tabela de CPU e links de guias precisam de ajuste. Reprodução: 143 casos de scripts, 71 de relatório e 126 coletados da aplicação fornecem base concreta; resultados atuais discriminados. Provas completas dependem de Docker/OpenSSL/imagens/scanner; não foram reexecutadas e o host empacotado bloqueia três fixtures de caminho.

cycleops. Engenharia: Domínio separado, eventos transacionais e reconexão SSE; validação de integridade incompleta no replay. Documentação: Instruções específicas, modos e limitações claros; pureza da função está descrita incorretamente no guia. UI/UX: Identidade consistente, mapa/lista e estados úteis; semântica de abas móvel incompleta. Reprodução: Demo abre sem instalação e testes Python locais passam; integrações não reexecutadas.

quake-exposure. Engenharia: Vetor de cálculo, dinheiro inteiro, separação de modos e CAS concretos; parser de grid incompleto. Documentação: Explica origem, limites e diferença entre exposição e dano. Guia extenso, mas ligado a código e comandos. UI/UX: Mapa, comparação e lista formam fluxo claro e responsivo nas capturas; timeout de consulta precisa de estado recuperável. Reprodução: Demo independente de backend e 129 testes web executados; stack de dados não reexecutada.

delta. Engenharia: Alteração pequena; não atribuir a arquitetura do upstream ao autor. Documentação: A contribuição corrige um defeito concreto e verificável do exemplo. UI/UX: Sem interface autoral. Reprodução: Branch e PR reproduzíveis; os exemplos corrigidos passaram na verificação direcionada. A branch padrão manter a versão anterior é normal enquanto o PR está aberto.

fastapi-pagination. Engenharia: Alteração pequena; não atribuir a arquitetura do upstream ao autor. Documentação: A contribuição corrige um defeito concreto e verificável do exemplo. UI/UX: Sem interface autoral. Reprodução: Branch e PR reproduzíveis; os exemplos corrigidos passaram na verificação direcionada. A branch padrão manter a versão anterior é normal enquanto o PR está aberto.

Parte 2 - Auditoria individual dos repositórios

arthurjoanes

Objetivo: Apresentar experiência declarada, competências e projetos para avaliação profissional.

Estágio observado: README de perfil publicado; HEAD 603c69d889f19d0781f486238a55e242ca55b66e igual ao remoto.

Tecnologias: Markdown, PNG.

Arquivos examinados

- `README.md`
- `README.en.md`
- `inventário GitHub de 11 repositórios`

Verificações executadas

Procedimento: Leitura das duas versões e cruzamento de links com inventário público

Resultado: As versões PT/EN apresentam os mesmos seis projetos. CycleOps e QuakeExposure estão ausentes, apesar de demos públicas acessíveis.

Limite: Experiência de emprego e métricas privadas não foram verificadas, nem devem ser tratadas como falsas.

Problemas por categoria

Clareza do propósito e apresentação

PROBLEMA PER-01 - Perfil omite os dois projetos que podem ser avaliados diretamente no navegador

- **Repositório:** arthurjoanes.
- **Categoria:** Clareza do propósito e apresentação.
- **Gravidade:** Média.
- **Localização:** README.md:19-45; README.en.md:19-45.
- **Esforço:** baixo.
- **Prioridade:** P1.

Problema identificado:

Perfil omite os dois projetos que podem ser avaliados diretamente no navegador

Evidência:

Projetos em destaque e Também no portfólio listam seis projetos, sem CycleOps/QuakeExposure. As duas demos públicas abriram durante a auditoria.

Por que isso é um problema:

Um avaliador que entra pelo perfil não descobre essas demonstrações sem explorar a lista de repositórios. A ausência reduz o acesso a evidências concretas de UI e interação.

Impacto:

A primeira impressão fica dependente de projetos que exigem instalação para navegar.

Correção recomendada:

Acrescentar um bloco curto de demos com links de código e execução; ajustar a frase sobre dados sintéticos para reconhecer fontes abertas reais.

Implementação sugerida:

```
Substituir a introdução de Projetos em destaque por:

Os projetos abaixo são demonstrações pessoais. Uso dados sintéticos nos cenários de varejo e operações; Cycl
  eOps e QuakeExposure também usam dados públicos, com a origem e os limites descritos nos repositórios.

### Demonstrações no navegador

- [CycleOps](https://arthurjoanes.github.io/cycleops/): disponibilidade de estações de bicicletas de Oslo, p
  rioridades e replay de uma gravação GBFS. [Código](https://github.com/arthurjoanes/cycleops).
- [QuakeExposure](https://arthurjoanes.github.io/quake-exposure/): exposição de uma carteira fictícia a terr
  emotos, com mapa e comparação de publicações. [Código](https://github.com/arthurjoanes/quake-exposure).

Versão inglesa da introdução:

These are personal demonstrations. The retail and operations scenarios use synthetic data; CycleOps and Quak
  eExposure also use public data, with sources and limits described in their repositories.

### Browser demos

- [CycleOps](https://arthurjoanes.github.io/cycleops/): Oslo bike-share availability, priorities and replay
  of a recorded GBFS feed. [Source](https://github.com/arthurjoanes/cycleops).
- [QuakeExposure](https://arthurjoanes.github.io/quake-exposure/): earthquake exposure for a fictional portf
  olio, with a map and publication comparisons. [Source](https://github.com/arthurjoanes/quake-exposure).
```

Arquivos afetados: `README.md`, `README.en.md`.

Como validar: Abrir os dois links em janela anônima, sem credenciais; conseguir acessar demo e código a partir do perfil. Conferir que a frase sobre origem dos dados é verdadeira em ambos os idiomas.

Parecer para contratação

Texto informa área de atuação e nível declarado. O portfólio justifica perguntas sobre isolamento, filas, dados e operação. Os números de experiência (registros, lojas, anos e ganho de rotina) são declarações do autor: solicitar contexto e responsabilidade individual em entrevista, sem inferir veracidade ou falsidade pelo estilo. PER-01 torna duas evidências públicas mais fáceis de encontrar.

Limitações e qualidade textual

- Não verificados empregador, nível profissional, escala de produção ou resultados comerciais.
- Não há evidência explícita de IA nos dois README lidos. Organização e linguagem técnica não provam geração automatizada.

evidencedesk

Objetivo: Conferir evidências de divergências entre sistemas de pedidos, pagamento e reserva; produzir dossiês com fontes rastreáveis e revisão humana antes de exportar.

Estágio observado: Protótipo local funcional com serviços, worker, persistência e trilha de revisão implementados. Há documentação e evidências de verificações extensas; não foi demonstrada operação produtiva nesta auditoria.

Tecnologias: Python, FastAPI, PostgreSQL, SQLAlchemy, Next.js 16, React 19, TypeScript, Zod, TanStack Query, React Hook Form, Radix Dialog, PDF.js, pytest, Vitest, Playwright, Docker Compose, Azure OpenAI opcional.

Arquivos examinados

- `README.md`
- `backend/pyproject.toml`
- `frontend/package.json`
- `.github/workflows/ci.yaml`
- `backend/src/evidencedesk/config.py`
- `backend/src/evidencedesk/app.py`
- `backend/src/evidencedesk/identity/service.py`
- `backend/src/evidencedesk/database.py`
- `backend/src/evidencedesk/reviews/routes.py`
- `backend/src/evidencedesk/reviews/contracts.py`
- `backend/src/evidencedesk/reviews/service.py`
- `backend/src/evidencedesk/reviews/exporting.py (linhas 1-160)`
- `backend/src/evidencedesk/ingestion/routes.py`
- `backend/src/evidencedesk/ingestion/service.py (linhas 1-190 e buscas direcionadas)`
- `backend/src/evidencedesk/incidents/routes.py`
- `backend/src/evidencedesk/incidents/service.py`
- `backend/src/evidencedesk/jobs/service.py (linhas 1-145)`
- `backend/src/evidencedesk/reconciliation/contracts.py`
- `backend/src/evidencedesk/reconciliation/rules.py (linhas 1-230 e emissões de not_evaluable)`
- `backend/src/evidencedesk/worker.py (linhas 1-150)`
- `frontend/src/lib/session.tsx`
- `frontend/src/lib/http.ts`
- `frontend/src/lib/contracts.ts (schemas de estados, incidente, impacto, revisão e exportação)`
- `frontend/src/lib/form-errors.ts`
- `frontend/src/components/ui/dialog.tsx`
- `frontend/src/features/imports/new-import.tsx`
- `frontend/src/features/incidents/create-incident.tsx`
- `frontend/src/features/incidents/incident-queue.tsx`
- `frontend/src/features/incidents/incident-workspace.tsx (seletor de snapshot e abas)`
- `frontend/src/features/dossiers/dossier-editor.tsx`
- `frontend/src/features/dossiers/dossier-dialogs.tsx`

- `frontend/src/features/dossiers/review-decision.tsx`
- `frontend/src/features/dossiers/dossier-view.tsx`
- `frontend/src/features/dossiers/dossier-draft.ts`
- `frontend/src/features/dossiers/dossier-draft.test.ts`
- `frontend/src/features/evidence/evidence-reader.tsx`
- `frontend/src/features/evidence/pdf-viewer.tsx`
- `frontend/playwright.config.ts`
- `frontend/e2e/review-regressions.spec.ts (linhas 1-100)`
- `frontend/e2e/publication-regressions.spec.ts (linhas 1-100)`
- `frontend/e2e/uiux-regressions.spec.ts (linhas 1-80)`
- `backend/tests/conftest.py`
- `backend/tests/integration/test_manual_workflow.py (linhas 1-200)`
- `backend/tests/unit/test_reconciliation.py (casos de identidade, temporalidade e inconclusão)`
- `scripts/check_repository_docs.py`
- `docs/development.md`
- `docs/runbooks/local.md`
- `docs/data-contract.md (limites e semântica de snapshots)`
- `docs/api-contract.md (importação, revisões, jobs e exportação)`
- `docs/frontend.md (limites e fluxos)`
- `docs/ai-review.md`
- `evals/README.md`
- `docs/readme/home.png (inspeção visual histórica)`
- `docs/readme/citation-mobile.png (inspeção visual histórica)`
- `docs/evidence/evolution-20261012/workbench-desktop.png (inspeção visual histórica do laboratório)`

Verificações executadas

Procedimento: git status --short; git ls-remote origin HEAD

Resultado: Árvore limpa antes e depois; HEAD local e remoto e4dd8efe73e50999b9a75896ce74b75d460223da.

Limite: Compara o HEAD remoto consultado, não todos os branches ou tags.

Procedimento: .venv/Scripts/python.exe -B scripts/check_repository_docs.py

Resultado: Exit 0: 45 documentos, 821 links analisados, lista de problemas vazia.

Limite: 83 links externos não são validados pelo script; não comprova que todos os comandos executam numa instalação nova.

Procedimento: node --input-type=module: importação de frontend/src/lib/contracts.ts e exportSchema.safeParse({id:'e',state:'expired',revision_id:'r',download_url:null,expires_at:'2026-10-12T00:00:00Z',error:null})

Resultado: exportExpiredAccepted=false; 'available_snapshots_truncated' in incidentSchema.shape=false.

Limite: Probe do contrato TypeScript real com dependências existentes; não houve navegação nem servidor.

Procedimento: Em cópia git archive HEAD externa: python -B -m pytest backend/tests/unit/test_reconciliation.py backend/tests/unit/test_pagination.py backend/tests/unit/test_body_limit.py backend/tests/unit/test_runtime_security.py backend/tests/unit/test_export_syntax.py -p no:cacheprovider -q

Resultado: 71 testes passaram em 2,17 s. ED_AI_PROVIDER=disabled; chave Azure vazia; bytecode/cache desabilitados.

Limite: Cinco arquivos unitários, usando o .venv existente. Não executa PostgreSQL, integração, Playwright, build limpo ou provedor real; não revalida todos os números históricos do README.

Procedimento: Inspeção visual de três PNGs versionados

Resultado: Fila desktop histórica, citação mobile e workbench desktop lidos visualmente.

Limite: Capturas preservadas; a home é explicitamente uma captura anterior. Workbench é laboratório separado. Sem comprovação de UI atual renderizada.

Problemas por categoria

UI/UX e fluxo de negócio

PROBLEMA EVD-01 - Revisão devolvida oferece um envio que o servidor sempre recusa

- **Repositório:** evidencedesk.
- **Categoria:** UI/UX e fluxo de negócio.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/dossiers/dossier-view.tsx:370; backend/src/evidencedesk/reviews/service.py:300.
- **Esforço:** baixo (pequeno - 1 a 3 horas).
- **Prioridade:** P1.

Problema identificado:

Revisão devolvida oferece um envio que o servidor sempre recusa

Evidência:

O botão “Enviar para revisão” aparece para ['draft','changes_requested']. submit_revision aceita somente draft e devolve 409 revision_not_draft nos demais estados, orientando criar nova versão.

Por que isso é um problema:

O estado devolvido é imutável e deve originar uma nova revisão. A interface oferece uma transição que a própria máquina de estados proíbe.

Impacto:

Depois de receber pedido de alteração, o autor clica numa ação primária destinada a falhar. Isso compromete o percurso central de revisão humana, sem indicar um defeito na proteção do backend.

Correção recomendada:

Exibir envio somente no rascunho e destacar a criação de nova revisão quando houver changes_requested.

Implementação sugerida:

Trocar a condição por current.review_status === 'draft'. Para changes_requested, apresentar “Preparar nova revisão” junto ao motivo recebido, reutilizando o editor e o controle de revisão-base existentes. Manter a restrição do servidor.

Arquivos afetados: `frontend/src/features/dossiers/dossier-view.tsx`, `frontend/e2e/review-regressions.spec.ts`.

Como validar: Criar revisão, submeter e devolver com alterações. Confirmar ausência de envio direto no estado devolvido, motivo visível e nova revisão editável; salvar e enviar a nova versão com sucesso. Requisição direta de submissão da antiga deve continuar retornando 409.

Contratos de API, confiabilidade e UI/UX

PROBLEMA EVD-02 - Exportação expirada quebra o schema e a mesma tela não cria uma nova tentativa após falha

- **Repositório:** evidencedesk.
- **Categoria:** Contratos de API, confiabilidade e UI/UX.
- **Gravidade:** Média.
- **Localização:** backend/src/evidencedesk/reviews/routes.py:218; frontend/src/lib/contracts.ts:364; frontend/src/features/dossiers/dossier-view.tsx:194 e :238.
- **Esforço:** médio (médio - 0,5 a 1 dia).
- **Prioridade:** P1.

Problema identificado:

Exportação expirada quebra o schema e a mesma tela não cria uma nova tentativa após falha

Evidência:

A API emite state='expired' quando o prazo termina. exportSchema usa jobStateSchema sem expired; probe atual confirmou rejeição desse payload. exportIntent guarda uma única chave por revisão enquanto o componente vive. Clicar novamente após falha/expiração reutiliza essa chave e recupera o recurso anterior. A renderização/polling tampouco trata expired explicitamente.

Por que isso é um problema:

Estado do arquivo exportado e estado do job não são o mesmo contrato. Idempotência deve distinguir repetição da mesma intenção, necessária em falha de rede, de uma nova intenção após término confirmado.

Impacto:

Arquivo expirado vira erro genérico de resposta inválida; falha terminal impede nova exportação pela mesma instância da tela sem remontá-la. O usuário pode ficar sem uma ação clara de recuperação.

Correção recomendada:

Definir estado de exportação que inclua expired e criar uma ação explícita para nova exportação em estados terminais.

Implementação sugerida:

Usar z.union([jobStateSchema,z.literal('expired')]) no schema de exportação. Encerrar polling em expired e exibir “O arquivo expirou. Prepare outra exportação.” Separar recuperar a intenção existente de iniciar uma nova: conservar a chave durante resposta incerta e gerar novo UUID apenas após terminal confirmado e comando explícito do usuário. Tratar failed/cancelled mesmo quando error é null. Documentar esses estados.

Arquivos afetados: `frontend/src/lib/contracts.ts`, `frontend/src/features/dossiers/dossier-view.tsx`, `docs/api-contract.md`, `frontend/e2e/publication-regressions.spec.ts`.

Como validar: Aceitar payload expired no teste de schema; testar falha, cancelamento e expiração sem spinner infinito. Repetir a mesma intenção deve retornar o mesmo recurso; iniciar nova exportação após término deve retornar ID novo. Simular perda da resposta inicial e comprovar que a recuperação não duplica job.

Confiabilidade e recursos

PROBLEMA EVD-03 - Criação inicial de importação não pode ser repetida com segurança após resposta perdida

- **Repositório:** evidencedesk.
- **Categoria:** Confiabilidade e recursos.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/imports/new-import.tsx:56; backend/src/evidencedesk/ingestion/routes.py:27; backend/src/evidencedesk/ingestion/service.py:69.
- **Esforço:** médio (médio - 1 a 2 dias).
- **Prioridade:** P1.

Problema identificado:

Criação inicial de importação não pode ser repetida com segurança após resposta perdida

Evidência:

A tela guarda created apenas depois que POST de criação responde. Esse endpoint não recebe Idempotency-Key; create_import incrementa storage_reserved e cria uuid4 para cada chamada. Se houver commit no servidor seguido de perda da resposta, tentar novamente cria outro lote e outra reserva.

Por que isso é um problema:

O caminho de retomada após conhecer o lote está implementado, mas não cobre a incerteza na primeira criação. A exclusão mútua da política de quota não torna duas requisições sequenciais idempotentes.

Impacto:

Lotes órfãos/duplicados e reserva duplicada de armazenamento até limpeza ou expiração; a pessoa pode atingir limite com um único conjunto de arquivos reenviado após falha de rede.

Correção recomendada:

Adicionar idempotência à admissão do lote e preservar a chave antes de começar a chamada.

Implementação sugerida:

Reutilizar o padrão idempotent_resource de jobs/service.py, com escopo tenant/ator/operação e fingerprint canônico do manifesto. Reservar armazenamento somente quando a intenção for nova, na mesma transação. No cliente manter um UUID por manifesto/intenção e reaproveitá-lo ao recuperar resposta incerta; novo manifesto exige nova intenção. Conflito de chave com corpo diferente deve retornar 409.

Arquivos afetados: `backend/src/evidencedesk/ingestion/routes.py`, `backend/src/evidencedesk/ingestion/service.py`, `backend/src/evidencedesk/jobs/service.py`, `frontend/src/features/imports/new-import.tsx`, `docs/api-contract.md`.

Como validar: Teste de integração simula commit seguido de resposta perdida, repete POST com mesma chave e confere mesmo batch_id, uma reserva e um conjunto de arquivos. Corpo diferente com mesma chave deve falhar.

Teste da UI deve retomar o lote sem duplicá-lo.

UI/UX e contrato de dados

PROBLEMA EVD-04 - Recortes antigos ficam inacessíveis no seletor quando há mais de 50 snapshots

- **Repositório:** evidencedesk.
- **Categoria:** UI/UX e contrato de dados.
- **Gravidade:** Média.
- **Localização:** backend/src/evidencedesk/incidents/service.py:237; frontend/src/lib/contracts.ts:96; frontend/src/features/incidents/incident-workspace.tsx:408.
- **Esforço:** médio (médio - 1 dia).
- **Prioridade:** P1.

Problema identificado:

Recortes antigos ficam inacessíveis no seletor quando há mais de 50 snapshots

Evidência:

O backend retorna os primeiros 50 snapshots e available_snapshots_truncated. O schema TypeScript não declara a flag e a lista da tela não tem paginação nem indicação de truncamento; o probe confirmou ausência da propriedade no schema.

Por que isso é um problema:

O servidor já distingue coleção completa de amostra, mas essa informação é descartada antes da apresentação. O recorte ativo preservado na consulta não oferece navegação pelos demais recortes antigos.

Impacto:

Acima do limite, o usuário interpreta a lista como completa e não consegue selecionar determinados snapshots históricos pelo controle normal.

Correção recomendada:

Propagar a flag e oferecer navegação paginada pelos snapshots autorizados.

Implementação sugerida:

Incluir available_snapshots_truncated no schema e documentar o campo. Como correção imediata, mostrar “Há recortes anteriores que não estão nesta lista”. Para resolver o acesso, fornecer cursor estável por data/ID e botão “Carregar recortes anteriores”, preservando o selecionado mesmo fora da página. Aplicar autorização no endpoint de cada página.

Arquivos afetados: `frontend/src/lib/contracts.ts`, `frontend/src/features/incidents/incident-workspace.tsx`, `backend/src/evidencedesk/incidents/routes.py`, `backend/src/evidencedesk/incidents/service.py`, `docs/api-contract.md`.

Como validar: Com mais de 50 snapshots autorizados, a indicação aparece e um recorte antigo pode ser carregado e selecionado. Alterar autorização não deve permitir recuperar snapshots proibidos por cursor ou URL.

Acessibilidade e usabilidade de formulários

PROBLEMA EVD-05 - Erros nas listas de lacunas não identificam qual campo ou alegação precisa de ajuste

- **Repositório:** evidencedesk.
- **Categoria:** Acessibilidade e usabilidade de formulários.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/dossiers/dossier-editor.tsx:252, :498 e :595; frontend/src/lib/form-errors.ts:1.
- **Esforço:** médio (médio - 0,5 a 1 dia).
- **Prioridade:** P1.

Problema identificado:

Erros nas listas de lacunas não identificam qual campo ou alegação precisa de ajuste

Evidência:

Os textareas de lacunas/verificações usam setValue, sem FieldError, aria-invalid ou aria-describedby. noteList limita 20 linhas/1.000 caracteres por linha. validationMessages deduplica apenas o texto e perde o caminho; campos repetidos produzem a mesma mensagem “Use no máximo 20 linhas...” no rodapé.

Por que isso é um problema:

Ao editar várias alegações, a mensagem não permite localizar a entrada inválida. Campos principais do próprio editor já têm associação de erro, mas essas listas ficam de fora.

Impacto:

Tentativa e erro para encontrar a lista, especialmente em diálogo extenso e com leitor de tela; validação impede salvar sem apontar o controle responsável.

Correção recomendada:

Associar erro a cada textarea e manter campo/índice na lista de erros.

Implementação sugerida:

Usar Controller/useController ou registro equivalente que preserve a ref do controle. Gerar IDs estáveis por field.id, incluir aria-invalid e aria-describedby, e renderizar FieldError com mensagens como “Alegação 2 - Informação que falta: use até 20 linhas”. O resumo deve ter links para os campos; ao enviar, focar o primeiro inválido. Referência de critério: WCAG, identificação de erros.

Arquivos afetados: `frontend/src/features/dossiers/dossier-editor.tsx`, `frontend/src/features/dossiers/dossier-draft.ts`, `frontend/src/lib/form-errors.ts`, `frontend/e2e/review-regressions.spec.ts`.

Como validar: Inserir 21 linhas ou 1.001 caracteres em cada lista, incluindo segunda alegação. Verificar mensagem específica, associação acessível, foco e persistência do rascunho. Não basta testar a função que deduplica strings.

Clareza analítica e UI/UX

PROBLEMA EVD-06 - Resumo atribui toda avaliação inconclusiva à falta de cobertura

- **Repositório:** evidencedesk.
- **Categoria:** Clareza analítica e UI/UX.

- **Gravidade:** Baixa.
- **Localização:** frontend/src/features/dossiers/dossier-view.tsx:316; backend/src/evidencedesk/reconciliation/rules.py:113 e :214.
- **Esforço:** baixo (pequeno - até 1 hora).
- **Prioridade:** P2.

Problema identificado:

Resumo atribui toda avaliação inconclusiva à falta de cobertura

Evidência:

O contador not_evaluable aparece como “avaliações sem cobertura suficiente”. Regras também emitem not_evaluable para event_identity_conflict e comparação temporal indeterminada, que não equivalem a falta de cobertura.

Por que isso é um problema:

A mesma categoria agrupa motivos distintos. O texto resume um deles como se fosse a causa de todos.

Impacto:

O leitor pode procurar mais cobertura de dados quando o problema real é conflito de identidade ou precisão temporal, comprometendo a interpretação de um produto de evidências.

Correção recomendada:

Nomear o agregado “avaliações inconclusivas” e encaminhar aos motivos individuais.

Implementação sugerida:

Substituir o texto por “N avaliações inconclusivas” e uma ajuda curta: “Consulte o motivo de cada registro em Conciliação”. Manter a explicação específica das regras na lista detalhada, sem inventar causa no agregado.

Arquivos afetados: `frontend/src/features/dossiers/dossier-view.tsx`, `frontend/e2e/review-regressions.spec.ts`.

Como validar: Usar fixture com cobertura suficiente e eventos de mesma identidade conflitantes; o resumo não deve dizer que falta cobertura, e a regra detalhada deve mostrar conflito de identidade.

Parecer para contratação

O projeto oferece boa matéria para uma entrevista técnica: imutabilidade de revisão e revisão-base (`reviews/service.py`), autorização corrente, jobs com lease e idempotência (`jobs/service.py`), regras de conciliação que preservam inconclusão (`reconciliation/rules.py`) e separação entre evidência de avaliação e promoção de modelo (`docs/ai-review.md`, `evals/README.md`). Os 71 testes atuais reforçam os domínios executados, sem provar o sistema inteiro.

Perguntas úteis: (1) Em que ponto uma tentativa de importação pode consumir quota duas vezes e como a transação idempotente a impediria? (2) Por que uma revisão devolvida não pode ser reenviada sem nova versão? (3) Como distinguir lease de worker, idempotência da intenção e validade do arquivo? (4) Como um evento de identidade conflitante deve afetar uma conclusão mesmo com cobertura completa? (5) Que evidência faltaria para liberar uso real de sugestão de IA? Pedir que a pessoa percorra os arquivos e desenhe a sequência de falha, em vez de responder só com nomes de padrões.

O material sustenta capacidade de construir um protótipo de engenharia substancial. Experiência operacional de produção, eficácia com usuários reais e qualidade semântica de conclusões geradas não foram comprovadas. Declarações de uso de IA são evidência explícita; estilo, volume de testes e organização de pastas não identificam autoria.

Limitações e qualidade textual

- Sem PostgreSQL/worker/frontend rodando nesta auditoria; nenhum teste de integração ou Playwright atual.
- Não houve chamadas a modelos, uso de credenciais, implantação ou alterações nos repositórios.
- Capturas inspecionadas são históricas; UX atual estática foi cruzada com elas sem equiparar seus estados.
- Testes selecionados usaram ambiente virtual existente, sem instalação limpa das dependências.
- Os cenários de rede perdida foram demonstrados pela sequência de código; a validação de falha ponta a ponta é proposta.
- Não houve varredura completa de todas as dependências, arquivos gerados, histórico Git ou prova de ausência de vulnerabilidades.

gestao-recebiveis

Objetivo: Demonstrar importação e gestão de contas a receber, pagamentos parciais idempotentes, aging, extrato por cliente e lembretes simulados recuperáveis.

Estágio observado: Aplicação local avançada de portfólio, com backend transacional e UI operacional; demonstração de uma empresa fictícia, sem integração de cobrança real ou validação de produção.

Tecnologias: Python 3.13, FastAPI, SQLAlchemy, psycopg, PostgreSQL, Alembic, Next.js 16, React 19, TypeScript, Docker Compose, pytest, Playwright, axe-core, Argon2.

Arquivos examinados

- `README.md`
- `backend/pyproject.toml`
- `frontend/package.json`
- `frontend/package-lock.json`
- `compose.yaml`
- `.env.example`
- `.github/workflows/ci.yml`
- `.github/workflows/secrets.yml`
- `backend/src/gestao_recebiveis/app.py`
- `backend/src/gestao_recebiveis/config.py`
- `backend/src/gestao_recebiveis/auth.py`
- `backend/src/gestao_recebiveis/routes.py`
- `backend/src/gestao_recebiveis/receivables.py`
- `backend/src/gestao_recebiveis/reporting.py`
- `backend/src/gestao_recebiveis/import_csv.py`
- `backend/src/gestao_recebiveis/imports.py`
- `backend/src/gestao_recebiveis/database.py`
- `backend/src/gestao_recebiveis/request_limits.py`
- `backend/src/gestao_recebiveis/models.py`

- backend/src/gestao_recebiveis/views.py
- backend/src/gestao_recebiveis/responses.py
- backend/src/gestao_recebiveis/worker.py
- backend/src/gestao_recebiveis/reminders/service.py
- backend/src/gestao_recebiveis/reminders/provider.py
- frontend/src/features/workspace.tsx
- frontend/src/features/receivables.tsx
- frontend/src/features/imports.tsx
- frontend/src/features/login.tsx
- frontend/src/features/receivable-detail.tsx
- frontend/src/features/reports.tsx
- frontend/src/features/import-preview.tsx
- frontend/src/lib/api.ts
- frontend/src/lib/use-resource.ts
- frontend/src/lib/payment-intent.ts
- frontend/src/lib/format.ts
- frontend/src/components/ui.tsx
- frontend/src/components/workspace-navigation.tsx
- frontend/src/components/responsive-filters.tsx
- frontend/src/components/brand.tsx
- frontend/src/app/page.tsx
- frontend/src/app/layout.tsx
- frontend/src/app/globals.css
- frontend/src/app/financial-workspace.css
- frontend/Dockerfile
- frontend/Dockerfile.e2e
- frontend/next.config.ts
- frontend/tsconfig.json
- frontend/playwright.config.ts
- frontend/tests/uiux-accessibility.spec.ts
- backend/tests/conftest.py
- backend/tests/test_financial.py
- backend/tests/test_reports.py
- scripts/tests/test_verify_restore_backup.py
- docs/demo.md
- docs/frontend-quality.md

- `docs/image-captures.md`
- `docs/verification.md`
- `docs/readme/overview.png`
- `docs/screenshots/restore-proof/6e75361b018645ffa98bce7ad338d4d4/07-aging-residual.png`
- `docs/screenshots/restore-proof/6e75361b018645ffa98bce7ad338d4d4/05-parcela-saldo-preservados.png`

Verificações executadas

Procedimento: git status --short; git rev-parse HEAD; git ls-remote origin HEAD

Resultado: Checkout limpo antes e depois; HEAD local e remoto iguais: 7477a6afe0bbc0a5308cec120f04a5f7384b81ad.

Limite: Consulta pontual em 13/10/2026; nenhuma operação de escrita no remoto.

Procedimento: git archive para cópia externa; Python 3.11 -m unittest discover -s scripts/tests -v

Resultado: 22 testes de scripts host passaram em 0,684 s: guardas de namespace/URL, cópia, manifesto, destino ocupado, comparação de restauração e redação de dados sensíveis.

Limite: Testes de scripts host somente; não é a suíte da aplicação que declara Python 3.13, nem prova de PostgreSQL/worker/UI.

Procedimento: Inspeção dos testes backend, testes UI, fluxos financeiros e workflows

Resultado: Cobertura de regras financeiras e recuperação demonstrada no código e recibos datados; verificados locks, idempotência, CSRF, estados de envio e separação de papéis.

Limite: Docker daemon indisponível; não reexecutei 218 testes backend/37 Playwright históricos nem build frontend ou migrações.

Procedimento: Revisão das imagens overview.png, 07-aging-residual.png e 05-parcela-saldo-preservados.png

Resultado: Capturas existentes mostram visão geral, saldo residual/aging e detalhe com recebimento parcial e histórico. Hierarquia e valores consistentes visualmente; singular incorreto confirmado.

Limite: Imagens históricas com procedência documentada, não sessão atual autenticada. O conflito de tablet é evidência de CSS, sem nova renderização.

Problemas por categoria

UI/UX e navegação

PROBLEMA REC-01 - A navegação financeira não pode ser retomada pelo endereço do navegador

- **Repositório:** gestao-recebiveis.
- **Categoria:** UI/UX e navegação.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/workspace.tsx:38; frontend/src/components/workspace-navigation.tsx:42.
- **Esforço:** médio (Médio: 1-2 dias).
- **Prioridade:** P1.

Problema identificado:

A navegação financeira não pode ser retomada pelo endereço do navegador

Evidência:

Área, título, cliente e filtros ficam em useState. A navegação principal usa button e callbacks; app/page.tsx monta o workspace em /. O código mantém retornos internos ao título e filtros durante a sessão, mas não os sincroniza com URL/histórico.

Por que isso é um problema:

Abrir um título ou extrato é navegação entre contextos de consulta. Sem endereço próprio, recarregar perde o ponto de trabalho e o Voltar nativo não acompanha as telas internas.

Impacto:

O operador não consegue guardar ou compartilhar um link de título/filtro, abrir o mesmo contexto em outra aba ou retomar a consulta após reload. O botão de retorno interno existente não corrige esses usos.

Correção recomendada:

Dar endereço às áreas e detalhes e serializar filtros de consulta na URL.

Implementação sugerida:

Usar rotas ou search params do Next com Links para navegação; validar IDs e filtros no carregamento. Manter o estado de formulários transitórios e a chave de intenção de pagamento separados. Preservar foco e origem de retorno já tratados no workspace.

Arquivos afetados: `frontend/src/app/page.tsx`, `frontend/src/features/workspace.tsx`, `frontend/src/components/workspace-navigation.tsx`, `frontend/src/features/receivables.tsx`, `frontend/src/features/reports.tsx`, `frontend/tests (novo cenário de navegação)`.

Como validar: Abrir título a partir de filtro, copiar URL, recarregar, usar Voltar/Avançar e abrir em nova aba; exigir contexto equivalente após autenticação e ausência de submissão financeira involuntária.

UI/UX e validação

PROBLEMA REC-02 - Os filtros oferecem combinações que a própria API rejeita

- **Repositório:** gestao-recebiveis.
- **Categoria:** UI/UX e validação.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/receivables.tsx:153; backend/src/gestao_recebiveis/reporting.py:69.
- **Esforço:** médio (Pequeno/médio: 0,5 dia).
- **Prioridade:** P1.

Problema identificado:

Os filtros oferecem combinações que a própria API rejeita

Evidência:

O formulário envia aging_bucket e status escolhidos independentemente. A API aceita bucket apenas quando status é None ou open. Assim, "1-30 dias" + "Vencidos", ou qualquer faixa + "Pagos", chega a invalid_status/422. O submit só valida a ordem das datas.

Por que isso é um problema:

A interface oferece a combinação como consulta normal, embora o contrato impeça seu uso; "Vencidos" com faixa de atraso parece especialmente compatível para o operador.

Impacto:

O usuário recebe uma falha depois de preencher controles aparentemente válidos e precisa inferir qual combinação remover. A API protege os dados; o defeito é de interação/contrato.

Correção recomendada:

Explicitar que aging consulta saldo aberto e impedir a combinação inválida antes da requisição.

Implementação sugerida:

Ao selecionar faixa, fixar situação Em aberto com explicação curta, ou permitir no backend interseções semanticamente válidas entre atraso e situação. Se escolher a primeira solução, desabilitar opções incompatíveis e manter validação acessível junto ao campo para estados recebidos pela URL.

Arquivos afetados: `frontend/src/features/receivables.tsx`, `backend/src/gestao_recebiveis/reporting.py (se contrato for ampliado)`, `frontend/tests`, `backend/tests/test_reports.py`.

Como validar: Cobrir cada situação com e sem faixa, especialmente Vencidos+1-30 e Pagos+faixa; nenhuma combinação oferecida como válida deve terminar em 422 inesperado.

UI/UX e CSS responsivo

PROBLEMA REC-03 - Regras posteriores anulam o layout de filtros previsto para tablet

- **Repositório:** gestao-recebiveis.
- **Categoria:** UI/UX e CSS responsivo.
- **Gravidade:** Média.
- **Localização:** frontend/src/app/financial-workspace.css:115,571,963.
- **Esforço:** baixo (Pequeno: 0,5 dia).
- **Prioridade:** P2.

Problema identificado:

Regras posteriores anulam o layout de filtros previsto para tablet

Evidência:

O @media de 901-1100 px define portfolio-workbench com uma coluna e filtros em grid de duas colunas. Mais abaixo, seletores de mesma especificidade restauram 224px + 1fr e display:flex; o @media max-width:1050 ainda impõe 190px + 1fr. A regra de cartões da mesma faixa continua ativa.

Por que isso é um problema:

A ordem de cascata impede a composição explicitamente definida pelo breakpoint: parte do modo tablet é aplicada e outra parte é anulada.

Impacto:

Entre 901 e 1100 px, a carteira mantém a faixa lateral ocupando espaço enquanto os resultados já usam cartões. O conflito é confirmado no código; não foi medido overflow dessa tela em navegador nesta auditoria.

Correção recomendada:

Consolidar as regras responsivas após a base, em ordem consistente, e remover declarações contraditórias.

Implementação sugerida:

Mover/reescrever o breakpoint de tablet depois dos estilos base e do bloco max-width:1050, ou adotar base móvel com ampliações min-width. Manter uma única definição de colunas e display por intervalo.

Arquivos afetados: `frontend/src/app/financial-workspace.css`, `frontend/tests/uiux-accessibility.spec.ts`.

Como validar: Verificar computedStyle em 900, 901, 1024, 1100 e 1101 px; em 1024 exigir uma coluna externa e filtros em duas. Conferir foco, números, ações e abertura/fechamento dos filtros em cada modo.

Eficiência e contrato de API

PROBLEMA REC-04 - A página de títulos carrega todo o histórico de parcelas de cada item

- **Repositório:** gestao-recebiveis.
- **Categoria:** Eficiência e contrato de API.
- **Gravidade:** Média.
- **Localização:** backend/src/gestao_recebiveis/reporting.py:119; backend/src/gestao_recebiveis/responses.py:52; backend/src/gestao_recebiveis/views.py:57.
- **Esforço:** médio (Médio: 1-2 dias).
- **Prioridade:** P2.

Problema identificado:

A página de títulos carrega todo o histórico de parcelas de cada item

Evidência:

list_titles limita a quantidade de títulos, mas busca todos os Payment dos IDs da página, monta payments_by_title e inclui payments em cada resposta. As listagens frontend utilizam saldo/total/estado, sem consultar esse array de cada título. title_detail também carrega parcelas e eventos completos. O extrato tem paginação própria dos recebimentos, que funciona separadamente.

Por que isso é um problema:

Limitar títulos não limita as linhas relacionadas retornadas. A API já calcula o saldo por agregação, portanto não precisa materializar as parcelas para exibir a carteira.

Impacto:

À medida que se acumulam recebimentos pequenos, crescem consulta, serialização e payload de cada abertura da carteira/aging. Não foi feito benchmark nem constatada lentidão na massa demo.

Correção recomendada:

Separar o resumo de título do detalhe e limitar historicos de longa duração.

Implementação sugerida:

Definir resposta de resumo sem payments para carteira/aging/títulos do extrato, conservar paid_cents e remaining_cents agregados. Oferecer paginação de parcelas/eventos no detalhe, com ordem estável e totais calculados independentemente da página. Preservar compatibilidade de clientes ou versionar a mudança.

Arquivos afetados: `backend/src/gestao_recebiveis/reporting.py`, `backend/src/gestao_recebiveis/responses.py`, `backend/src/gestao_recebiveis/views.py`, `frontend/src/lib/api.ts`, `frontend/src/features/receivable-detail.tsx`, `backend/tests/test_reports.py`.

Como validar: Criar títulos com centenas de parcelas e verificar que o payload da lista não cresce com o histórico, mantendo os mesmos saldos. Na paginação do detalhe, conferir ausência de perdas/duplicações e total igual ao agregado.

Reprodutibilidade de testes

PROBLEMA REC-05 - O teste de acessibilidade usa axe-core sem declarar a dependência direta

- **Repositório:** gestao-recebiveis.
- **Categoria:** Reprodutibilidade de testes.
- **Gravidade:** Baixa.
- **Localização:** frontend/tests/uiux-accessibility.spec.ts:4; frontend/package.json:21.
- **Esforço:** baixo (Pequeno: menos de 1 hora).
- **Prioridade:** P2.

Problema identificado:

O teste de acessibilidade usa axe-core sem declarar a dependência direta

Evidência:

O teste importa tipos de axe-core e abre node_modules/axe-core/axe.min.js. package.json não o declara; o lock atual contém axe-core 4.13.0 via eslint-plugin-jsx-a11y. O teste depende dessa instalação transitiva e de sua posição no node_modules.

Por que isso é um problema:

Uma ferramenta usada diretamente pelo projeto deve fazer parte de seu contrato de desenvolvimento, não depender acidentalmente do grafo do linter.

Impacto:

O lock atual registra axe-core como dependência transitiva; não foi demonstrada falha de instalação limpa. Uma atualização legítima da cadeia ESLint pode remover ou deslocar o módulo e quebrar o teste sem alteração da aplicação.

Correção recomendada:

Declarar axe-core como devDependency e resolver o arquivo pela resolução de módulos.

Implementação sugerida:

Adicionar explicitamente a versão escolhida de axe-core ao package.json e regenerar o lock; usar require.resolve("axe-core/axe.min.js") ou equivalente no runner em vez de montar caminho a partir de cwd.

Arquivos afetados: `frontend/package.json`, `frontend/package-lock.json`, `frontend/tests/uiux-accessibility.spec.ts`.

Como validar: Executar npm ci e o teste em instalação limpa e comprovar que remover a dependência transitiva de ESLint não afeta a resolução do scanner.

Texto de interface

PROBLEMA REC-06 - Alguns resumos mostram códigos de faixa e contagem sem concordância

- **Repositório:** gestao-recebiveis.
- **Categoria:** Texto de interface.
- **Gravidade:** Baixa.
- **Localização:** frontend/src/features/receivables.tsx:112; frontend/src/features/reports.tsx:372.
- **Esforço:** baixo (Pequeno: menos de 1 hora).
- **Prioridade:** P2.

Problema identificado:

Alguns resumos mostram códigos de faixa e contagem sem concordância

Evidência:

O resumo concatena "Aging: " com aging_bucket, expondo valores como 1_30. Os cards e totais de relatórios concatenam title_count com "títulos" inclusive quando a quantidade é 1. A captura histórica 07-aging-residual.png mostra "1 títulos".

Por que isso é um problema:

Os selects já têm rótulos compreensíveis; usar o enum bruto no resumo perde essa legibilidade. O singular incorreto aparece em um caso financeiro comum.

Impacto:

Pequeno ruído de compreensão e acabamento em estados que o próprio roteiro demonstra.

Correção recomendada:

Reutilizar rótulos de faixa e formatar contagens no singular/plural.

Implementação sugerida:

Centralizar o mapa current/1_30/31_60/61_90/over_90 para o resumo e os controles, e usar um helper simples de contagem de títulos. Remover partes vazias antes de unir os trechos do resumo.

Arquivos afetados: `frontend/src/features/receivables.tsx`, `frontend/src/features/reports.tsx`, `frontend/src/lib/format.ts`.

Como validar: Conferir as cinco faixas no resumo e contagens 0, 1 e 2 nos cards e extrato; nenhum enum com underscore deve aparecer como rótulo.

Parecer para contratação

Sinal forte para backend/full stack: centavos precisos, resposta textual/BigInt, transações, concorrência de pagamento, idempotência e máquina de estados de lembretes oferecem discussão técnica concreta. O visual tem linguagem de sistema operacional financeiro, e a documentação permite conferir casos com valores pequenos.

Perguntas: o que ocorre se duas requisições pagarem o saldo simultaneamente; por que a mesma chave idempotente em títulos distintos exige coordenação própria; onde fica a fronteira entre confirmação local e envio externo; como o token de posse impede finalização por worker antigo; por que backup do mesmo PostgreSQL não prova recuperação de um provedor externo; como manter o saldo agregado ao paginar parcelas; como modelar URLs sem perder a intenção de pagamento.

O domínio é demonstrativo e a entrega externa é simulada. Não há evidência de produtividade ou escala de produção. Nenhum estilo visual ou textual isolado sustenta atribuir uso de IA; esta avaliação trata da qualidade verificável do

resultado.

Limitações e qualidade textual

- Arquivos extensos de CSS, respostas e testes foram lidos em trechos pertinentes; não se afirma inspeção de todas as linhas nem execução da totalidade dos testes.
- Não houve Docker, migração, banco PostgreSQL, worker ou integração com provedor real nesta auditoria.
- Avaliação visual usa screenshots históricas; a análise de cascade/tablet e navegação usa código atual, sem simular resultados medidos.
- Risco de payload crescente é deduzido da consulta sem limite de parcelas; não houve benchmark e não se declara lentidão da demonstração.
- Repositório original permaneceu limpo. Testes host rodaram em cópia de git archive externa, sem credenciais nem serviços do usuário.

loja-assistente

Objetivo: Consultar vendas fictícias em português, transformar a pergunta em plano limitado, autorizar organização/lojas e apresentar cálculo, recorte e resultado verificáveis.

Estágio observado: Aplicação local funcional com modo Demo sem modelo, modo LLM opcional, esclarecimentos, histórico, favoritos e evidências de avaliação preservadas. Produção e adoção com lojas reais não demonstradas.

Tecnologias: Python, FastAPI, SQLAlchemy, PostgreSQL, Pydantic, Next.js 16, React 19, TypeScript, OpenAI/Azure OpenAI opcional, pytest, Playwright, Docker Compose.

Arquivos examinados

- `README.md`
- `backend/pyproject.toml`
- `frontend/package.json`
- `.github/workflows/ci.yml`
- `compose.yaml (linhas 1-130)`
- `.gitignore`
- `backend/src/loja_assistente/config.py`
- `backend/src/loja_assistente/app.py`
- `backend/src/loja_assistente/auth/service.py`
- `backend/src/loja_assistente/auth/routes.py`
- `backend/src/loja_assistente/assistant/service.py`
- `backend/src/loja_assistente/assistant/routes.py`
- `backend/src/loja_assistente/assistant/interpreters/openai_adapter.py`
- `backend/src/loja_assistente/analytics/contracts.py`
- `backend/src/loja_assistente/analytics/service.py`
- `backend/src/loja_assistente/analytics/queries.py`
- `backend/src/loja_assistente/conversations/service.py`

- backend/src/loja_assistente/conversations/routes.py
- backend/src/loja_assistente/favorites/service.py
- frontend/src/features/assistant/use-workspace.ts (inicialização, pergunta, favoritos e recuperação)
- frontend/src/features/assistant/workspace.tsx (login, controles, resultados e estados)
- frontend/src/features/assistant/login.tsx
- frontend/src/features/assistant/analysis-sidebar.tsx
- frontend/src/features/assistant/question-composer.tsx
- frontend/src/features/assistant/analysis-filters.tsx
- frontend/src/features/assistant/period-selection.ts
- frontend/src/features/analytics/visualization.tsx
- frontend/src/features/analytics/result.tsx
- frontend/src/features/analytics/daily-series.ts
- frontend/src/lib/api.ts
- frontend/src/app/api/[...path]/route.ts
- frontend/src/lib/server/proxy-lifetime.ts
- frontend/src/app/globals.css (linhas 1-240)
- frontend/playwright.config.ts
- scripts/verify_evidence.py (validação de hashes e relatório)
- scripts/verify_uiux.py
- backend/tests/conftest.py
- backend/tests/test_interpreters.py (casos com MockTransport)
- backend/tests/test_budget_policy.py (casos iniciais)
- backend/tests/test_money_contract.py (linhas 1-70)
- backend/tests/test_clarifications_domain.py (linhas 1-70)
- backend/tests/test_input_matrix.py (linhas 1-45)
- docs/api-contract.md (consulta, histórico e limites)
- docs/interface.md (filtros, histórico e recuperação)
- docs/security.md (autorização e modos)
- docs/frontend-quality.md (verificações de UI)
- docs/local-setup.md (instalação local)
- docs/llm-integration.md
- docs/uiux-20261012.md (contexto e captura)
- docs/readme/home.png (inspeção visual histórica)
- docs/screenshots/uiux-20261012/after-chromium-pendente-390.png (inspeção visual histórica)

- `docs/screenshots/uiux-20261012/after-chromium-resultado-1440.png (inspeção visual histórica)`

Verificações executadas

Procedimento: git status --short; git ls-remote origin HEAD

Resultado: Árvore limpa antes e depois; HEAD local e remoto 075ea83a0a7b99ccef5868050609c3c36c4d907f.

Limite: Consulta do HEAD remoto, não auditoria de todos os branches.

Procedimento: python -B scripts/verify_evidence.py

Resultado: Exit 0. Duas páginas históricas byte a byte; 65 hashes de artefatos e 62 arquivos históricos de fonte verificados; 48 execuções e 55 chamadas históricas contabilizadas. Evidência preserva falha final-bf-04, repetição 2. Registra LLM 47/48, Demo 24/48 e 30/30 casos estruturados.

Limite: Confirma integridade e contabilidade da evidência histórica; não fez 55 chamadas novas nem reexecutou os 48 casos. Custo e tokens do arquivo são históricos.

Procedimento: python -B scripts/verify_uiux.py

Resultado: Exit 0: recibo de 25 estados pareados, dados e hashes verificados; estado de esclarecimento aparece no material.

Limite: Integridade do recibo/imagens, não 25 novas renderizações ou reexecução de Playwright.

Procedimento: Em cópia git archive HEAD externa, usando runtime Python existente: python -B -m pytest tests/test_interpreters.py tests/test_budget_policy.py tests/test_secure_config.py tests/test_clarifications_domain.py -p no:cacheprovider -q

Resultado: 61 testes passaram em 0,81 s; uma DeprecationWarning do alias BlockingPortal do Starlette. DEMO_MODE=true, LLM_ENABLED=false, sem chave OpenAI e sem TEST_DATABASE_URL.

Limite: Quatro arquivos de domínio; provider apenas por MockTransport. O runtime disponível era o .venv de EvidenceDesk, não instalação limpa do lock de Loja. Não reproduz toda a suíte, banco, build ou navegador.

Procedimento: Inspeção visual de três PNGs versionados

Resultado: Home anterior, esclarecimento em 390 px e resultado em 1440 px avaliados.

Limite: Capturas históricas; sem inspeção atual de navegador, contraste medido, desempenho ou leitor de tela.

Problemas por categoria

Confiabilidade e uso de recursos

PROBLEMA LOJ-01 - Reenvio de pergunta após resposta perdida pode criar outro resultado e outra chamada paga

- **Repositório:** loja-assistente.
- **Categoria:** Confiabilidade e uso de recursos.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/assistant/use-workspace.ts:348 e :398; backend/src/loja_assistente/assistant/service.py:66 e :154.
- **Esforço:** médio (médio - 1 a 2 dias).
- **Prioridade:** P1.

Problema identificado:

Reenvio de pergunta após resposta perdida pode criar outro resultado e outra chamada paga

Evidência:

ask restaura a pergunta depois de erro, inclusive transporte/timeout, e libera nova execução. A chamada não carrega chave idempotente. O serviço cria novo UUID e persiste/commita antes de devolver a resposta. Já perform(execution=true) trata 0/408/503/504 como resultado incerto e orienta verificar histórico, mas ask não usa esse caminho.

Por que isso é um problema:

Não receber resposta não prova que a consulta não foi concluída. A trava da conversa impede concorrência simultânea, mas não identifica replay depois do commit ou nova conversa sem ID conhecido.

Impacto:

O usuário pode repetir a consulta, gerar respostas/conversas duplicadas e consumir outra chamada LLM. Em acompanhamento de conversa, o segundo envio também pode usar um contexto já alterado. Nenhuma duplicação paga foi provocada nesta auditoria.

Correção recomendada:

Dar à intenção de consulta uma identidade recuperável e tratar transporte incerto antes de permitir repetição.

Implementação sugerida:

Gerar client_request_id antes do primeiro envio, com unicidade por organização/usuário e fingerprint do corpo no backend. Persistir reserva/estado da intenção e devolver resultado existente para replay; não repetir chamada externa cujo resultado permaneça desconhecido. Expor recuperação por ID. Como primeiro patch, aplicar a mesma mensagem de incerteza de perform, preservar texto e exigir recarregar histórico antes de executar nova intenção.

Arquivos afetados: `frontend/src/features/assistant/use-workspace.ts`, `frontend/src/lib/api.ts`, `backend/src/loja_assistente/assistant/routes.py`, `backend/src/loja_assistente/assistant/service.py`, `backend/src/loja_assistente/assistant/contracts.py`, `backend/migrations (nova migração de intenções)`, `docs/api-contract.md`.

Como validar: Simular resposta perdida após commit. Repetir mesma chave deve produzir uma resposta e uma chamada ao provider; corpo diferente com mesma chave deve retornar 409. Nova chave deve ser nova intenção explícita. Estado incerto do provider não pode ser convertido em retry pago automático.

UI/UX e tolerância a falhas

PROBLEMA LOJ-02 - Falha de favoritos impede carregar histórico e restaurar esclarecimento pendente

- **Repositório:** loja-assistente.
- **Categoria:** UI/UX e tolerância a falhas.
- **Gravidade:** Média.
- **Localização:** frontend/src/features/assistant/use-workspace.ts:104 e :111; frontend/src/features/assistant/workspace.tsx:148.
- **Esforço:** médio (médio - 0,5 a 1 dia).
- **Prioridade:** P1.

Problema identificado:

Falha de favoritos impede carregar histórico e restaurar esclarecimento pendente

Evidência:

O bootstrap define session antes de Promise.all entre GET /conversations e fetchFavorites. fetchFavorites registra seu erro e o relança. Se favoritos falhar, setHistory e restauração do pending abaixo do await não executam. O catch genérico só define notice; o componente mostra notice no Login, que já foi substituído pela área autenticada.

Por que isso é um problema:

Duas leituras independentes foram ligadas num único sucesso obrigatório. Existe estado de erro de favoritos, mas ele não explica por que o histórico válido desapareceu.

Impacto:

Um 503 de favoritos deixa a lista de conversas vazia e impede retomar um esclarecimento, mesmo que o endpoint de histórico tenha respondido corretamente. A tela pode apresentar ausência de conteúdo no lugar de falha de carga.

Correção recomendada:

Carregar histórico e favoritos de modo independente, com estados e recuperação separados.

Implementação sugerida:

Usar operações separadas ou Promise.allSettled, preservar os guards de geração/revisão e tratar 401/403 pela rotina global. Hidratar histórico e pending assim que a leitura de conversas chegar. Criar historyLoading/historyError com botão de recarga e mostrar esse erro na região de histórico; manter erro próprio dos favoritos.

Arquivos afetados: `frontend/src/features/assistant/use-workspace.ts`, `frontend/src/features/assistant/analysis-sidebar.tsx`, `frontend/src/features/assistant/workspace.tsx`.

Como validar: Com sessão válida, histórico existente e pending, responder 503 somente a /favorites: histórico e pending devem aparecer; favoritos devem exibir erro próprio. Falha somente em /conversations não pode virar “Nenhuma conversa”. 401/403 continuam limpando o estado protegido.

UI/UX e acesso ao histórico

PROBLEMA LOJ-03 - Limites de 50 conversas e 100 respostas são silenciosos na experiência de histórico

- **Repositório:** loja-assistente.
- **Categoria:** UI/UX e acesso ao histórico.
- **Gravidade:** Média.
- **Localização:** backend/src/loja_assistente/conversations/routes.py:41 e :103; frontend/src/features/assistant/analysis-sidebar.tsx.
- **Esforço:** médio (médio - 1 a 2 dias).
- **Prioridade:** P1.

Problema identificado:

Limites de 50 conversas e 100 respostas são silenciosos na experiência de histórico

Evidência:

A listagem busca no máximo 50 conversas; o detalhe mantém as 100 respostas mais recentes. A UI usa a quantidade carregada como “conversas” e não oferece cursor, carregar anteriores ou indicação desses recortes. docs/api-contract.md informa os limites, mas a tela não.

Por que isso é um problema:

Limitar a consulta é razoável; apresentar o subconjunto sem informar a limitação impede distinguir retenção, paginação e perda de histórico. A filtragem de acesso ocorre depois do limite da listagem, podendo ainda reduzir a página visível.

Impacto:

Depois de ultrapassar os limites, conversas antigas somem da navegação e mensagens anteriores não podem ser alcançadas na conversa. O usuário não sabe se os dados foram apagados ou omitidos.

Correção recomendada:

Explicitar a amostra e fornecer paginação estável de conversas e respostas autorizadas.

Implementação sugerida:

Responder items/next_cursor/has_more, ordenando por created_at e id. Aplicar o escopo autorizado antes de formar a página, ou preencher a página sem vazar metadados. Adicionar “Carregar conversas anteriores” e “Carregar respostas anteriores”. Enquanto isso, rotular “Últimas 50 conversas” e “100 respostas mais recentes” apenas quando o limite for atingido, sem inventar total.

Arquivos afetados: `backend/src/loja_assistente/conversations/routes.py`, `frontend/src/features/assistant/use-workspace.ts`, `frontend/src/features/assistant/analysis-sidebar.tsx`, `frontend/src/features/assistant/workspace.tsx`, `docs/api-contract.md`.

Como validar: Fixtures com 51 conversas e 101 respostas devem permitir acessar os itens mais antigos ou, na correção inicial, indicar a limitação. Paginar com datas iguais não deve repetir/pular itens. Revogação de loja não pode expor conversa nem contagem proibida.

UI/UX e linguagem do domínio

PROBLEMA LOJ-04 - Filtro pede ao lojista que raciocine sobre uma data final excluída

- **Repositório:** loja-assistente.
- **Categoria:** UI/UX e linguagem do domínio.
- **Gravidade:** Baixa.
- **Localização:** frontend/src/features/assistant/analysis-filters.tsx:130; frontend/src/features/assistant/period-selection.ts.
- **Esforço:** baixo (pequeno - 2 a 4 horas).
- **Prioridade:** P2.

Problema identificado:

Filtro pede ao lojista que raciocine sobre uma data final excluída

Evidência:

O input é rotulado “Fim (excluído)”, enquanto o resultado e outros percursos apresentam o período humano com data final incluída. Para pedir somente um dia pelo formulário, a pessoa precisa escolher o dia seguinte como fim.

Por que isso é um problema:

Intervalo semiaberto é apropriado ao contrato técnico, mas demanda uma conversão mental evitável na tarefa de consultar vendas por dia. Há inconsistência entre edição e leitura do mesmo período.

Impacto:

Escolha frequente de um dia a menos, erro em consultas de um único dia e dúvida se as vendas da data final entraram no cálculo.

Correção recomendada:

Editar datas inicial/final incluídas na UI e converter a data final para o limite exclusivo da API.

Implementação sugerida:

Rotular “Até (incluído)”. Exibir shiftDate(period.end,-1) e converter seleção com shiftDate(valor,1), usando o utilitário de data civil existente. Validar período com a mesma regra de 90 dias e lidar explicitamente com o maior dia suportado. Manter o intervalo [start,end) no backend e nos detalhes técnicos.

Arquivos afetados: `frontend/src/features/assistant/analysis-filters.tsx`, `frontend/src/features/assistant/period-selection.ts`, `docs/interface.md`.

Como validar: Selecionar início=fim visível deve representar um dia; testar virada de mês/ano, ano bissexto e 90 dias. O período exibido após executar deve ser idêntico ao escolhido, sem depender do fuso do navegador.

Consistência de UI/UX

PROBLEMA LOJ-05 - Histórico e resposta mostram o mesmo horário em fusos diferentes

- **Repositório:** loja-assistente.
- **Categoria:** Consistência de UI/UX.
- **Gravidade:** Baixa.
- **Localização:** frontend/src/features/assistant/analysis-sidebar.tsx:170; frontend/src/features/analytics/result.tsx:49.
- **Esforço:** baixo (pequeno - 1 a 2 horas).
- **Prioridade:** P2.

Problema identificado:

Histórico e resposta mostram o mesmo horário em fusos diferentes

Evidência:

analysis-sidebar usa toLocaleString('pt-BR') sem timeZone, portanto adota o navegador. A data da resposta usa timeZone='America/Sao_Paulo'. Para pessoas fora desse fuso, o mesmo registro muda de horário e pode mudar de data entre as duas áreas.

Por que isso é um problema:

O produto tem um fuso analítico definido, mas aplica duas políticas de apresentação sem explicá-las.

Impacto:

Dificuldade de associar conversa ao resultado, especialmente perto da meia-noite, e aparência de divergência temporal no próprio histórico.

Correção recomendada:

Adotar uma única política explícita para timestamps apresentados.

Implementação sugerida:

Extrair formatTimestamp com America/Sao_Paulo para os dois componentes, incluir identificação legível do fuso no detalhe/tooltip e preservar dateTime ISO. Alternativamente usar fuso local em ambos, se essa for a decisão de produto; documentar a escolha.

Arquivos afetados: `frontend/src/features/assistant/analysis-sidebar.tsx`, `frontend/src/features/analytics/result.tsx`, `frontend/src/lib (utilitário compartilhado de formato)`.

Como validar: Renderizar o mesmo instante com navegador em UTC, America/Los_Angeles e America/Sao_Paulo; sidebar e resultado devem concordar. Incluir instante próximo à troca de data.

Documentação e apresentação profissional

PROBLEMA LOJ-06 - Resultados de várias rodadas competem pela leitura rápida no README

- **Repositório:** loja-assistente.
- **Categoria:** Documentação e apresentação profissional.
- **Gravidade:** Baixa.
- **Localização:** README.md:55, :57 e :156.
- **Esforço:** baixo (pequeno - 1 a 2 horas).
- **Prioridade:** P2.

Problema identificado:

Resultados de várias rodadas competem pela leitura rápida no README

Evidência:

O README apresenta 477/57/79, logo depois 477/57/85, e mais adiante 69 casos Playwright de outro commit. Os links e datas permitem distinguir as rodadas; não há evidência de falsificação ou contradição, mas a repetição exige investigação para entender qual conjunto é o mais recente.

Por que isso é um problema:

A porta de entrada deve dar um retrato curto e apontar para a proveniência detalhada. Repetir denominadores parecidos dispersa a evidência técnica mais forte do projeto.

Impacto:

Recrutador ou revisor pode comparar números que pertencem a escopos distintos ou gastar a primeira leitura reconciliando contagens.

Correção recomendada:

Manter uma rodada principal com data/escopo e uma tabela curta das anteriores; centralizar detalhes no guia de verificação.

Implementação sugerida:

Consolidar os dois parágrafos próximos em uma seção de evidências que destaque a revisão UI/UX de 12/10/2026 e preserve a evolução de 79 casos como rodada anterior. Identificar os 69 casos de 22/09 como histórico e sua composição de 39 puros/30 navegador. Não somar rodadas nem afirmar que a auditoria reexecutou 477 testes.

Arquivos afetados: `README.md`, `docs/verification.md`.

Como validar: A primeira leitura deve identificar a rodada principal, distinguir testes de domínio/avaliação/navegador e alcançar os recibos em um clique. Conferir datas/contagens contra cada recibo e rodar os verificadores offline

existentes.

Parecer para contratação

O projeto sustenta uma conversa técnica sobre fronteira entre interpretação probabilística e cálculo determinístico. Evidências: adapter limita interpretação; analytics/contracts.py e queries.py definem operações e valores; auth/service.py confere recorte; serviço de conversa mantém contexto; scripts verificam evidência preservada. O modo Demo é uma alternativa funcional explícita, não deve ser confundido com falha silenciosa do LLM.

Perguntas úteis: (1) Como uma pergunta vira plano e onde se impede SQL livre? (2) Qual a diferença entre centavos, Decimal e arredondamento na apresentação? (3) O que acontece se uma loja autorizada no momento da resposta for revogada antes de abrir histórico? (4) Como recuperar uma chamada cujo cliente perdeu a resposta, sem gastar outra vez? (5) Por que um 503 de favoritos interfere no histórico e como separar as leituras? (6) O que 47/48 versus 30/30 avaliam, e por que a falha preservada deve continuar publicada? Pedir demonstração nos arquivos e alteração de um cenário de borda.

A evidência é compatível com um protótipo bem desenvolvido de aplicação com IA opcional, autorização e preocupação de avaliação. Não permite inferir adoção real, escala operacional ou autoria individual de cada trecho. A utilização de IA explicitamente documentada pode ser discutida; padrões de escrita e acabamento visual não provam geração automática.

Limitações e qualidade textual

- Nenhuma chamada paga, credencial real, serviço externo de negócio ou mudança nos repositórios.
- Sem banco, build, UI ou Playwright executados nesta auditoria; análise de fluxo atual é estática.
- 61 testes selecionados usaram runtime Python preexistente compartilhado, não ambiente limpo do projeto.
- Os resultados de 477/57/85, 47/48 e custos são históricos preservados; apenas scripts de integridade e 61 testes foram executados agora por este agente.
- Capturas datadas não demonstram o comportamento de todas as telas atuais.
- Não houve auditoria completa de todos os arquivos, histórico Git, dependências transitivas ou certificação de segurança/acessibilidade.

varejo-data-pipeline

Objetivo: Conferir entregas e revisões de vendas sintéticas, publicar um fechamento consistente em tabelas Delta e oferecer relatório HTML auditável.

Estágio observado: Demonstração local avançada de engenharia de dados, com recuperação, perfil, proveniência e interface elaborados; não demonstrada como plataforma em produção.

Tecnologias: Python, Apache Spark/PySpark, Delta Lake, Java/JVM, Docker Compose, pytest, JSON Schema, OpenLineage, HTML/CSS/JavaScript, Playwright e axe em harness de desenvolvimento.

Arquivos examinados

- `README.md`
- `pyproject.toml`
- `requirements.lock`
- `compose.yaml`
- `.env.example`

- Dockerfile
- .github/workflows/ci.yml
- scripts/pipeline.ps1
- scripts/pipeline.sh
- scripts/render_report_fixtures.py
- scripts/dashboard-review.cjs
- scripts/proof_contracts.py
- src/retail_pipeline/publication.py
- src/retail_pipeline/pipeline.py
- src/retail_pipeline/ingestion.py
- src/retail_pipeline/batch_contracts.py
- src/retail_pipeline/input_limits.py
- src/retail_pipeline/contracts.py
- src/retail_pipeline/report_server.py
- src/retail_pipeline/reporting.py
- src/retail_pipeline/report_model.py
- src/retail_pipeline/report_view.py
- src/retail_pipeline/report_charts.py
- src/retail_pipeline/report.css
- src/retail_pipeline/report.js
- src/retail_pipeline/cli.py
- src/retail_pipeline/transformations.py
- src/retail_pipeline/references.py
- src/retail_pipeline/spark.py
- src/retail_pipeline/profiling.py
- tests/unit/test_reporting.py
- tests/unit/test_report_server.py
- tests/unit/test_rebuilt_jars.py
- tests/unit/test_state_proof.py
- tests/unit/test_operator_references.py
- tests/fixtures/reports/README.md
- tests/fixtures/reports/fixture-audit.json
- docs/frontend-quality.md
- docs/interface.md
- docs/data-contract.md
- docs/padrao-documentacao.md

- `docs/verification.md`
- `docs/state-recovery.md`

Verificações executadas

Procedimento: git status --short; git rev-parse HEAD; git ls-remote origin HEAD

Resultado: Checkout limpo antes e depois; HEAD local e remoto iguais: cd8bff90ce9d1ef37f727ec6f7fd9d8cbe615134.

Limite: Consulta pontual do remoto em 13/10/2026; nenhum fetch/commit/push.

Procedimento: docker info

Resultado: Docker CLI disponível, mas o daemon Linux não estava ativo: npipe dockerDesktopLinuxEngine ausente.

Limite: Build, Spark/Delta, integração, scan e recuperação de container não foram reexecutados; isso é limitação de ambiente, não falha do projeto.

Procedimento: Python 3.11/pytest 9.0.3 em git archive externo: pytest tests/unit -q

Resultado: Coleta interrompida no módulo test_operator_references.py porque PySpark não estava instalado no ambiente reduzido.

Limite: Instaladas somente dependências para testes puros; o runtime Docker documentado não foi substituído por esse ambiente.

Procedimento: Mesma cópia: pytest tests/unit --ignore=tests/unit/test_operator_references.py -q --junitxml=varejo-unit-selected.xml

Resultado: 393 passed, 3 skipped e 2 errors de setup/teardown do mesmo caso com parâmetro de 1 MiB. JUnit: 398 registros, zero falhas de asserção; 17,202 s.

Limite: Não equivale à suíte completa. Os erros são a limitação Windows de PYTEST_CURRENT_TEST descrita em VDP-04; os skips são verificações específicas de sistema.

Procedimento: render_report_fixtures.py tests/fixtures/reports _auditoria_2026-10-13/previews/varejo-current

Resultado: 22 HTMLs gerados com o renderer do HEAD, corpus-after.json e hashes preservados fora do repositório.

Limite: Snapshots/fixtures versionados; nenhuma nova entrega ou leitura Spark.

Procedimento: Navegador: historical-demo30k-report.html em 1440, 768 e 320 px

Resultado: Zero pageerrors e scrollWidth igual a innerWidth no estado inicial nas três larguras. Screenshot desktop revisada: composição limpa e hierarquia coerente. Recibos: reports-browser.json e varejo-{width}.png.

Limite: Amostra offline sintética. Não é reexecução do harness completo, teste de carga, leitor de tela ou certificação de acessibilidade.

Procedimento: Reprodução isolada: _read_attempts → make_archive → restore_archive → _read_attempts

Resultado: Última tentativa mudou de a-new/PUBLISHED para z-old/BLOCKED; bytes dos arquivos permaneceram idênticos.

Limite: Fixture mínima de duas tentativas, usando as funções reais; não envolve valores Delta. Recibo: varejo-restore-order-repro.json.

Problemas por categoria

Consistência e recuperação

PROBLEMA VDP-01 - A restauração pode trocar a tentativa apresentada como mais recente

- **Repositório:** varejo-data-pipeline.
- **Categoria:** Consistência e recuperação.
- **Gravidade:** Média.
- **Localização:** src/retail_pipeline/reporting.py:24; scripts/proof_contracts.py:146.
- **Esforço:** médio (Médio: 0,5-1 dia).
- **Prioridade:** P1.

Problema identificado:

A restauração pode trocar a tentativa apresentada como mais recente

Evidência:

_read_attempts ordena attempt.json por st_mtime_ns. restore_archive recria cada arquivo com open("xb") sem conservar esse metadado. A reprodução com os métodos reais retornou a-new/PUBLISHED antes da cópia e z-old/BLOCKED depois, com todos os bytes idênticos; recibo: _auditoria_2026-10-13/varejo-restore-order-repro.json.

Por que isso é um problema:

A ordem operacional passa a depender da ordem de extração dos arquivos, não da cronologia registrada pela aplicação.

Impacto:

A área Qualidade pode apresentar uma falha antiga como última tentativa após uma recuperação válida. O achado não demonstra alteração dos valores Delta publicados.

Correção recomendada:

Ordenar tentativas por um campo temporal persistido e validado ou uma sequência durável; definir desempate estável.

Implementação sugerida:

Ler e validar started_at em UTC antes da ordenação, adotar run_id como desempate e tratar explicitamente registros legados inválidos. Conferir se a intenção é ordem de início ou conclusão e documentá-la. Preservar mtime no backup pode ajudar ferramentas externas, mas não deve ser o contrato de ordenação de domínio.

Arquivos afetados: `src/retail_pipeline/reporting.py`, `tests/unit/test_reporting.py`, `tests/unit/test_state_proof.py`, `docs/state-recovery.md`.

Como validar: Criar tentativas cujos IDs ordenem ao contrário da cronologia, copiar/restaurar com make_archive/restore_archive e exigir igualdade de latest e last_failed antes/depois; incluir empate e registro inválido.

Confiabilidade da interface

PROBLEMA VDP-02 - O HTML servido é sobrescrito diretamente, sem publicação atômica

- **Repositório:** varejo-data-pipeline.
- **Categoria:** Confiabilidade da interface.

- **Gravidade:** Média.
- **Localização:** src/retail_pipeline/reporting.py:138; src/retail_pipeline/report_server.py:89.
- **Esforço:** médio (Médio: 0,5-1 dia).
- **Prioridade:** P1.

Problema identificado:

O HTML servido é sobrescrito diretamente, sem publicação atômica

Evidência:

generate_report usa output.write_text(...), que abre/trunca o destino existente. O servidor abre o mesmo arquivo, fixa Content-Length e lê blocos. O próprio comentário do servidor prevê crescimento durante a resposta, mas não evita truncamento ou conteúdo substituído.

Por que isso é um problema:

O snapshot de dados tem publicação atômica; a exportação HTML visível ao operador ainda pode ficar pela metade durante escrita ou interrupção.

Impacto:

Regerar report.html enquanto ele é servido pode produzir resposta incompleta ou inconsistente; falha de gravação pode eliminar o último HTML íntegro. Esta corrida foi identificada estaticamente, não observada em carga.

Correção recomendada:

Gravar a exportação completa em arquivo temporário na mesma pasta e substituir o destino somente ao terminar.

Implementação sugerida:

Renderizar antes de tocar no destino; usar temporário com nome exclusivo, flush/fsync, os.replace e fsync do diretório no runtime Linux, com limpeza do temporário em erro. Reaproveitar o padrão de publicação existente, sem serializar HTML como JSON.

Arquivos afetados: `src/retail_pipeline/reporting.py`, `tests/unit/test_reporting.py`, `tests/unit/test_report_server.py`.

Como validar: Forçar erro antes da substituição e verificar preservação byte a byte do relatório anterior; servir durante sucessivas exportações e aceitar apenas documentos completos da versão anterior ou da nova.

Reprodutibilidade e testes de UI

PROBLEMA VDP-03 - A verificação de navegador depende de ferramentas externas sem lock próprio

- **Repositório:** varejo-data-pipeline.
- **Categoria:** Reprodutibilidade e testes de UI.
- **Gravidade:** Média.
- **Localização:** docs/frontend-quality.md:29; scripts/dashboard-review.cjs:12; .github/workflows/ci.yml:15.
- **Esforço:** médio (Médio: 1 dia).
- **Prioridade:** P1.

Problema identificado:

A verificação de navegador depende de ferramentas externas sem lock próprio

Evidência:

O guia exige Playwright e @axe-core/playwright em artifacts/browser-tools e oferece caminhos absolutos por variável, mas não fornece manifesto/lock e instalação versionada dessas ferramentas. O workflow executa build, checks, pytest e scan; não executa o harness de navegador. Os recibos históricos de Edge/Firefox existem e têm escopo declarado.

Por que isso é um problema:

É possível repetir o renderer Python, mas outro avaliador precisa reconstruir o ambiente do harness. Alterações futuras de CSS/JS não têm esse gate de navegador no CI mostrado.

Impacto:

A prova de UI fica mais difícil de reproduzir e regressões de navegação/reflow podem passar pelos testes que conferem apenas o HTML produzido.

Correção recomendada:

Versionar as dependências do harness e dar um comando completo de instalação/execução; incluir uma amostra representativa em CI.

Implementação sugerida:

Criar um pequeno pacote de desenvolvimento em tools/browser com package.json e lock, fixar Playwright e axe, documentar npm ci e instalação do navegador. Ajustar a resolução de módulos do harness. Renderizar fixtures sem Spark e executar os estados de publicação, bloqueio, ausência e comparação no CI; conservar matriz extensa como execução complementar.

Arquivos afetados: `docs/frontend-quality.md`, `scripts/dashboard-review.cjs`, `scripts/profile-report-review.cjs`, `.github/workflows/ci.yml`, `tools/browser/package.json (novo)`, `tools/browser/package-lock.json (novo)`.

Como validar: Em checkout limpo, instalar pelo lock, renderizar corpus e executar amostra sem módulos globais; remover propositalmente um valor/controle e confirmar falha do gate.

Experiência de desenvolvimento

PROBLEMA VDP-04 - Um caso parametrizado de 1 MiB impede a execução do teste no Windows

- **Repositório:** varejo-data-pipeline.
- **Categoria:** Experiência de desenvolvimento.
- **Gravidade:** Baixa.
- **Localização:** tests/unit/test_rebuilt_jars.py:115.
- **Esforço:** baixo (Pequeno: menos de 1 hora).
- **Prioridade:** P2.

Problema identificado:

Um caso parametrizado de 1 MiB impede a execução do teste no Windows

Evidência:

O parâmetro b" " * (1024 * 1024 + 1) não tem ID curto. Na execução isolada com pytest 9.0.3/Python 3.11 em Windows, a representação do parâmetro foi incluída em PYTEST_CURRENT_TEST e excedeu 32767 caracteres: erro de setup e de teardown do mesmo caso. O JUnit também ficou inflado pelo identificador.

Por que isso é um problema:

O teste de limite é útil, mas seu nome automático transporta o próprio payload gigante para metadados e variáveis do processo.

Impacto:

A verificação desse helper puro não conclui nesse ambiente. Não é evidência de falha do batch Linux nem das garantias financeiras.

Correção recomendada:

Atribuir IDs curtos e estáveis aos dois parâmetros.

Implementação sugerida:

Usar pytest.param(b"[]", id="invalid-root") e pytest.param(payload, id="over-limit") ou ids=[...], preservando integralmente os dados e a asserção de segurança.

Arquivos afetados: `tests/unit/test_rebuilt_jars.py`.

Como validar: Executar os dois casos no Windows e no runtime Linux e confirmar nomes curtos no JUnit, mantendo a rejeição do provenance inválido.

Parecer para contratação

Sinal forte para entrevista em dados/backend: o projeto trata um problema concreto de publicação entre várias tabelas e mostra decisões sobre idempotência, revisão integral, entradas imutáveis e recuperação. A interface ajuda o avaliador a entender o domínio. O custo de manter Spark/Delta e dependências JVM reconstruídas merece discussão, sem presumir que seja erro.

Perguntas: explique a janela de falha entre duas Gold e o que o leitor observa; por que o manifesto resolve a consistência entre tabelas; como escolhe a revisão válida e impede mudança parcial de data de uma venda; qual invariável a restauração de bytes prova e qual não prova; como investigaria VDP-01; como mediria capacidade além dos 30 mil registros sintéticos.

Não há medição de impacto em negócio real nem prova de operação em produção. Estilo de código ou prosa não permite atribuir autoria por IA; defeitos, evidência histórica e autoria são questões diferentes.

Limitações e qualidade textual

- Inspeção de módulos extensos foi dirigida aos fluxos de entrada/publicação/relatório; arquivos da lista foram efetivamente lidos, alguns em trechos relevantes, e não se afirma revisão de todas as linhas do repositório.
- PySpark, imagem Linux e integração não executados nesta auditoria por ausência do daemon Docker.
- UI atual renderizada a partir de snapshots e fixtures sintéticos; somente estado inicial do dashboard examinado nas três larguras pela sessão principal.
- Scans de vulnerabilidade históricos foram lidos como evidência datada; não houve scan novo nem certificação de ausência de vulnerabilidades.
- Somente arquivos da auditoria e cópias temporárias externas receberam gravações; repositório original permaneceu limpo.

api-sentinel

Objetivo: Laboratório local de consultas comerciais por organização, controle de carga, integração ERP sintética e central de incidentes. O resultado comercial conhecido permite conferir correção junto com comportamento sob falha.

Estágio observado: Laboratório funcional com backend, observabilidade, interface própria, suítes de unidade/integração/HTTP e provas históricas versionadas. HEAD local e remoto: a0e1375bfecabcdf0a5e98802598bff63bbe44f6.

Tecnologias: Python 3.12, FastAPI, SQLAlchemy, PostgreSQL, Redis/Lua, SQLite, NGINX, Docker Compose, Prometheus, Alertmanager, Grafana, OpenTelemetry/Jaeger, HTML/CSS/JavaScript, pytest, Ruff, mypy, Schemathesis.

Arquivos examinados

- `README.md`
- `pyproject.toml`
- `Dockerfile`
- `compose.yml`
- `deploy/proxy/nginx.conf`
- `.github/workflows/ci.yml`
- `.github/workflows/secrets.yml`
- `.gitignore`
- `.dockerignore`
- `src/api_sentinel/app.py`
- `src/api_sentinel/auth.py`
- `src/api_sentinel/admission.py`
- `src/api_sentinel/cache.py`
- `src/api_sentinel/cursor.py`
- `src/api_sentinel/db.py`
- `src/api_sentinel/erp.py`
- `src/api_sentinel/queries.py`
- `src/api_sentinel/config.py`
- `src/api_sentinel/telemetry.py`
- `src/api_sentinel/seed.py (linhas 1-110)`
- `alert_receiver/app.py`
- `alert_receiver/config.py`
- `alert_receiver/contracts.py`
- `alert_receiver/storage.py`
- `alert_receiver/ui.py`
- `alert_receiver/snapshot.js`
- `alert_receiver/diagnostics.py`
- `alert_receiver/visual_summary.py (linhas 1-95)`
- `alert_receiver/styles.css (linhas 1-190)`
- `scripts/render_ui_preview.py`

- tools/browser-checks/server.py
- tools/browser-checks/audit.cjs (linhas 1-70)
- tests/unit/test_receiver_ui.py (linhas 1-180)
- tests/unit/test_receiver_retention.py
- tests/unit/test_data_private_file.py
- tests/unit/test_runtime.py (linhas 1-90)
- tests/integration/test_auth_db.py
- docs/demo.md
- docs/incident-console.md
- docs/security.md (trechos recuperados por busca)
- docs/verification.md (início e seções da rodada atual)
- docs/decisoes-tecnicas.md (introdução e tabela de decisões)

Verificações executadas

Procedimento: git status --short; git rev-parse HEAD; git ls-remote origin HEAD

Resultado: Cópia inicialmente limpa; HEAD local e remoto iguais: a0e1375bfecabcdf0a5e98802598bff63bbe44f6.

Limite: Não equivale a execução dos workflows remotos.

Procedimento: Em cópia git archive fora do repositório: Python do ambiente .runtime/verifyvenv, PYTHONPATH da cópia, PYTHONDONTWRITEBYTECODE=1, pytest tests/unit -q -p no:cacheprovider

Resultado: 374 passed, 3 skipped, 1 failed; 15 subtests passed, em 13,40 s. A falha é test_first_secret_creation_is_private no Windows.

Limite: Ambiente Python existente, não instalado do zero. Testes Linux de UID e integração externa não executados. A tentativa anterior com .venv não encontrou pytest.

Procedimento: pytest tests/unit/test_data_private_file.py -q -p no:cacheprovider com Python -X utf8

Resultado: 1 passed, 3 skipped, 1 failed. UTF-8 elimina a primeira divergência; resta assert POSIX 0600 no Windows (modo observado 0666).

Limite: Falha de portabilidade da suíte local; não demonstra vazamento de segredo nem falha do runtime Linux suportado.

Procedimento: Fixture SQLite temporária usando AlertStore real: persistir ocorrência 1 resolvida; envelhecer last_activity_at; prune; persistir outra ocorrência

Resultado: Antes, incident(1).annotations={'summary':'Incident 1'}; depois, incident(1).annotations={'summary':'Incident 2'}. Reutilização de ID confirmada.

Limite: Fixture sem credenciais e sem banco da demonstração.

Procedimento: scripts/render_ui_preview.py --output /previews/api-static

Resultado: 21 páginas HTML geradas, além de styles.css, snapshot.js e manifest.json; diretório assets ausente.

Limite: Não representa stack real nem teste de disponibilidade. A revisão visual principal usa o servidor de fixture, que serve assets corretamente.

Procedimento: tools/browser-checks/server.py sobre git archive com --run-dir /previews/api-sentinel

Resultado: Fixture sintética HTTP pronta em loopback; rotas de central, detalhe e runbooks disponibilizadas ao auditor principal.

Limite: Dados e relógio sintéticos; probe desativado. Avaliação visual e capturas consolidadas pelo auditor principal.

Procedimento: Revisão no navegador pelo auditor principal: 1440, 768 e 320 px

Resultado: API e ContainerOps sem pageerror ou overflow global nos estados iniciais. Capturas desktop e API 320 inspecionadas; layout coerente. Evidências: _auditoria_2026-10-13/reports-browser.json e api-sentinel-{width}.png.

Limite: API em fixture sintética com probe desativado; não é validação de stack, credencial real ou disponibilidade. Não cobre todos os fluxos e estados.

Problemas por categoria

Segurança e confiabilidade

PROBLEMA API-01 - A retenção permite reutilizar o número público de uma ocorrência

- **Repositório:** api-sentinel.
- **Categoria:** Segurança e confiabilidade.
- **Gravidade:** Alta.
- **Localização:** alert_receiver/storage.py:37, persist:74 e prune:280; /incidents/{incident_id}.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

A retenção permite reutilizar o número público de uma ocorrência

Evidência:

`incidents.id` é `INTEGER PRIMARY KEY`, sem AUTOINCREMENT. A inserção não informa ID e `prune` apaga resolvidos. Fixture executada: após excluir o último registro, `incident(1)` mudou de 'Incident 1' para 'Incident 2'.

Por que isso é um problema:

SQLite pode reutilizar ROWID removido, inclusive voltar a 1 quando a tabela esvazia. O comportamento é previsto pela documentação SQLite. O número é usado como identidade de URL e de busca, portanto precisa sobreviver à exclusão lógica daquela ocorrência.

Impacto:

Um link guardado de incidente expirado pode abrir outro alerta, induzindo associação incorreta de histórico, runbook ou recuperação.

Correção recomendada:

Adotar IDs monotônicos não reutilizáveis para novas inserções e migrar bases existentes preservando IDs e delivery_events. Não basta editar CREATE TABLE IF NOT EXISTS.

Implementação sugerida:

Para bases novas: `id INTEGER PRIMARY KEY AUTOINCREMENT`. Para existentes: migração transacional, com escrita suspensa, cria tabela nova com o mesmo contrato, copia IDs explícitos, recria índices/chaves estrangeiras e verifica `PRAGMA foreign_key_check` antes de publicar. Preservar um high-water mark independente da retenção quando houver IDs históricos superiores ao maior ainda retido; não é possível inferir todos os IDs já apagados apenas da tabela atual. Se esse histórico não estiver disponível, documentar a fronteira de migração ou adotar novo namespace público/UUID.

Arquivos afetados: `alert_receiver/storage.py`, `tests/unit/test_receiver_retention.py`, `tests/unit/test_receiver_storage_snapshot.py`, `docs/incident-console.md`.

Como validar: Persistir A, guardar URL, expirar/apagar A, persistir B e provar que IDs diferem; URL antiga retorna 404. Repetir apagando só o maior ID. Migrar fixture com eventos e provar IDs, contadores e foreign_key_check preservados.

UI/UX

PROBLEMA API-02 - Não há como descobrir ocorrências além das 100 linhas sem conhecer seu ID

- **Repositório:** api-sentinel.
- **Categoria:** UI/UX.
- **Gravidade:** Média.
- **Localização:** alert_receiver/storage.py:155; alert_receiver/ui.py:60,293; alert_receiver/app.py /api/incidents.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Não há como descobrir ocorrências além das 100 linhas sem conhecer seu ID

Evidência:

page retorna LIMIT 100 por padrão e a API não expõe cursor/offset. A interface informa 'Fora da lista? Use o ID da ocorrência.'. O teste de retenção já cria 105 ocorrências e confirma que só 100 são mostradas.

Por que isso é um problema:

O aviso comunica o limite, mas não fornece um caminho para encontrar um incidente antigo cujo ID o operador desconhece. Com mais de 100 ativos, até um ativo pode ficar fora da fila explorável.

Impacto:

Investigação exige recorrer ao SQLite ou outra fonte de IDs; a tarefa central do produto fica incompleta em volume já previsto pelos testes.

Correção recomendada:

Adicionar paginação limitada à consulta e controles de navegação, preservando status e posição. Manter busca direta por ID como atalho.

Implementação sugerida:

Ordenar por uma chave estável e devolver `next_cursor` com `(status_rank, last_activity_at, id)` e filtro associado, ou usar paginação por ID em um recorte de leitura identificado. Consultar `LIMIT page_size + 1`; incluir 'Ocorrências seguintes' no fim da fila e faixa/quantidade. Não usar o total retido como se todos os registros tivessem sido apresentados. Tratar cursor inválido com erro orientado ao usuário.

Arquivos afetados: `alert_receiver/storage.py`, `alert_receiver/contracts.py`, `alert_receiver/app.py`, `alert_receiver/ui.py`, `alert_receiver/snapshot.js`, `tests/unit/test_receiver_retention.py`, `docs/incident-console.md`.

Como validar: Com 205 ocorrências e ao menos 105 ativas, percorrer todas por teclado e mouse sem conhecer IDs; não omitir/duplicar registros em snapshot estável. Preservar filtro ao abrir detalhe e retornar. Rótulos e foco visíveis a 320 px.

Testes e execução / UI/UX

PROBLEMA API-03 - O exportador de prévias não copia fontes, marca e favicon usados nas páginas

- **Repositório:** api-sentinel.
- **Categoria:** Testes e execução / UI/UX.
- **Gravidade:** Baixa.
- **Localização:** scripts/render_ui_preview.py:181; alert_receiver/ui.py:107; alert_receiver/styles.css:1.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

O exportador de prévias não copia fontes, marca e favicon usados nas páginas

Evidência:

O exportador copia apenas `styles.css` e `snapshot.js`. O HTML aponta para `/assets/mark-light.svg` e `/assets/favicon.svg`; o CSS aponta para dois WOFF2. Execução gerou 21 páginas e nenhum diretório assets.

Por que isso é um problema:

A prévia isolada não reproduz a tipografia e a marca do produto, mesmo quando servida corretamente na raiz de um servidor HTTP.

Impacto:

Capturas e comparação de layout feitas por esse helper podem avaliar outra fonte e mostrar ícone quebrado. O servidor browser-checks não apresenta essa omissão; são caminhos distintos.

Correção recomendada:

Copiar o diretório de assets públicos junto da prévia e documentar que ela deve ser servida como raiz HTTP, já que o HTML usa caminhos absolutos.

Implementação sugerida:

```
from shutil import copytree
copytree(ROOT / 'alert_receiver' / 'assets', output / 'assets', dirs_exist_ok=True)
```

Executar após copiar CSS/JS. Acrescentar teste do manifest/export para os arquivos referenciados; não copiar arquivos privados do runtime.

Arquivos afetados: `scripts/render_ui_preview.py`, `tests/unit/test_receiver_ui.py`, `docs/screenshots.md`.

Como validar: Gerar em diretório vazio, servir a saída na raiz loopback e confirmar HTTP 200 para os quatro assets citados; verificar `document.fonts.check('14px "IBM Plex Sans"')` e marca visível.

Documentação / Developer Experience

PROBLEMA API-04 - O roteiro Linux exige PowerShell no primeiro exemplo autenticado

- **Repositório:** api-sentinel.
- **Categoria:** Documentação / Developer Experience.
- **Gravidade:** Baixa.
- **Localização:** docs/demo.md:117-154.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

O roteiro Linux exige PowerShell no primeiro exemplo autenticado

Evidência:

Depois de 'Instalação persistente no Linux', a primeira consulta usa `$tokens = Get-Content ... | ConvertFrom-Json` e `Invoke-RestMethod`; PowerShell não consta como requisito dessa instalação.

Por que isso é um problema:

Uma pessoa que concluiu os comandos shell não consegue copiar o próximo exemplo no mesmo terminal. O título identifica PowerShell, mas falta uma alternativa para o fluxo Linux apresentado.

Impacto:

A primeira comprovação de funcionamento exige adaptação manual ou instalação extra não prevista.

Correção recomendada:

Adicionar exemplo Linux com Python padrão ou shell/curl que leia o token sem imprimi-lo. Manter o bloco PowerShell identificado.

Implementação sugerida:

Usar o trecho Python/urllib completo na seção de documentação desta auditoria: lê `.runtime/demo.json` em UTF-8, usa tokens['probe'], consulta a loja 7 e imprime apenas os três resultados comerciais.

Arquivos afetados: `docs/demo.md`, `README.md (somente link, se necessário)`.

Como validar: Em shell Linux com Python3 e stack preparada, copiar o bloco sem editar sintaxe, receber 12500/2/6250 e confirmar que o token não aparece na saída.

Testes e execução

PROBLEMA API-05 - Um teste de arquivo privado mistura UTF-8 e permissões POSIX sem restringir plataforma

- **Repositório:** api-sentinel.
- **Categoria:** Testes e execução.
- **Gravidade:** Baixa.
- **Localização:** tests/unit/test_data_private_file.py:14-18.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

Um teste de arquivo privado mistura UTF-8 e permissões POSIX sem restringir plataforma

Evidência:

`write_private_json` grava UTF-8; o teste lê com `read_text()` sem encoding e exige stat mode 0600 em todas as plataformas. No Windows a primeira execução falhou no acento; com -X utf8, falhou em 0666 != 0600.

Por que isso é um problema:

O caso combina uma verificação portável de conteúdo com uma asserção específica de permissões POSIX. Os três casos seguintes já são corretamente condicionados a Linux/root.

Impacto:

Gera falha local de unidade que não diagnostica defeito do runtime Linux e torna difícil distinguir regressão real de incompatibilidade do teste.

Correção recomendada:

Usar encoding explícito e separar o teste de conteúdo do teste de modo POSIX, aplicando skip/condição somente à asserção de permissão.

Implementação sugerida:

```
assert json.loads(target.read_text(encoding='utf-8')) == expected
if os.name == 'posix':
    assert stat.S_IMODE(target.stat().st_mode) == 0o600
```

Manter o teste Linux de UID/leitores; não interpretar chmod Windows como validação de DACL.

Arquivos afetados: `tests/unit/test_data_private_file.py`.

Como validar: Teste de conteúdo passa com o encoding padrão do Windows e com UTF-8; teste POSIX continua exigindo 0600 no container Linux. Não mudar a promessa de plataforma da aplicação.

Parecer para contratação

O projeto dá material suficiente para uma entrevista sobre backend e confiabilidade: autorização por organização/loja, proteção de trabalho em andamento, quota distribuída, consultas com dinheiro inteiro, deadline e fallback limitado. README e código tornam as decisões verificáveis. A interface tem preocupação operacional concreta, embora o limite de descoberta de registros e a reutilização do ID prejudiquem a confiança na investigação.

Perguntas úteis: (1) por que separar pools de autenticação e negócio e usar AUTOCOMMIT no primeiro? (2) como liberar trabalho quando cliente desconecta? (3) como evitar que duas réplicas multipliquem a quota? (4) qual é a diferença entre indisponibilidade do cache e do controle de quota? (5) como migrar IDs do receiver preservando referências e chaves estrangeiras? (6) quais resultados publicados continuam válidos para o HEAD atual? Evidência: módulos auth/admission/cache/db/telemetry, teste de reconnect, storage e recibos nomeados. Respostas pessoais, autoria efetiva e domínio das decisões ainda precisam ser confirmados em conversa técnica.

Limitações e qualidade textual

- Não foram executados build Docker, PostgreSQL/Redis reais, simulador ERP, carga, Prometheus/Grafana/Jaeger nem scanner de vulnerabilidades nesta subauditoria.
- Testes usaram dependências previamente presentes; não é prova de instalação a partir de clone limpo.
- Arquivos de evidências históricas, screenshots antigos, scripts extensos de revisão e todos os testes não foram integralmente lidos; o inventário delimita os arquivos/trechos inspecionados.
- Não foi realizada atribuição de autoria por IA. Nenhuma instrução de prompt esquecida foi encontrada nos trechos lidos; padrões estilísticos isolados não sustentam atribuição.

- Observabilidade local, tokens demo e portas loopback são escolhas documentadas. Não foram classificados como ausência indevida de autenticação de produção.

containerops

Objetivo: Laboratório de operação de API e worker com fila PostgreSQL: idempotência, recuperação por lease, troca de imagem, backup/restauração e relatório HTML de evidências.

Estágio observado: Laboratório funcional com infraestrutura local endurecida, isolamento de sessões, transporte de backup e provas operacionais históricas. HEAD local e remoto iguais: 57dc89474b8aa2067a1c8a925f33def0ceb27abe.

Tecnologias: Python 3.13 no runtime / Python 3.11+ no host, FastAPI, psycopg, PostgreSQL, Docker Compose/Buildx, NGINX, Trivy, OCI/SBOM/provenance, HTML/CSS/JavaScript, pytest/unittest, Ruff/mypy.

Arquivos examinados

- `README.md`
- `compose.yaml`
- `app/pyproject.toml`
- `app/requirements-test.lock`
- `.github/workflows/verify.yml`
- `.github/workflows/secrets.yml`
- `app/src/containerops/api.py`
- `app/src/containerops/domain.py`
- `app/src/containerops/config.py`
- `app/src/containerops/database.py`
- `app/src/containerops/repository.py`
- `app/src/containerops/worker.py`
- `app/src/containerops/worker_health.py`
- `app/src/containerops/migrations/001.sql`
- `app/src/containerops/migrations/002.sql`
- `scripts/runtime_context.py`
- `scripts/report.py (funções shown/resource_table/catalog/guide_urls; início e final de generate)`
- `scripts/report.js`
- `scripts/report.html`
- `scripts/report.css (regras de componentes, responsive e impressão)`
- `scripts/ops.py (linhas 555-930: drain, backup, restore_preflight, restore_test)`
- `scripts/backup_catalog.py (discover e índice de funções)`
- `scripts/backup_package.py (validate_backup, cópia/finalização, import_backup, preflight_image e índice de funções)`
- `scripts/checks.py (linhas 1-90)`
- `scripts/test_report.py (linhas 1-50; suíte executada)`

- tests/test_backup_package.py (linhas 1-100)
- tests/test_transfer_proof.py (linhas 1-220)
- tests/test_operations.py (índice de testes via busca)
- app/tests/conftest.py
- app/tests/test_integration.py (linhas 140-235)
- docker/proxy/nginx.conf
- docs/examples/report.html (HTML renderizado e trechos de recursos/links)
- docs/demo.md (início e roteiro)
- docs/frontend-quality.md
- docs/report-guide.md
- docs/data-contract.md
- docs/runbooks.md (linhas 1-100)
- docs/verification.md (linhas 1-65)

Verificações executadas

Procedimento: git status --short; git rev-parse HEAD; git ls-remote origin HEAD

Resultado: Cópia limpa na inspeção inicial e após as verificações; HEAD local igual ao remoto: 57dc89474b8aa2067a1c8a925f33def0ceb27abe.

Limite: Não demonstra aprovação remota do CI.

Procedimento: Em cópia git archive fora do repo: PYTHONDONTWRITEBYTECODE=1, python -m unittest discover -s tests -q

Resultado: 143 testes executados: 137 aprovados, 3 skips, 2 failures e 1 error, em 20,365 s. Os três casos não aprovados pertencem a test_transfer_proof e falham no guardrail de caminho antes do cenário.

Limite: Diagnóstico confirmou virtualização do AppData pelo app empacotado: resolve() muda o caminho para Packages/OpenAI.Codex.../LocalCache. docs/runbooks.md já documenta o bloqueio. Não é bug confirmado do produto e não se recomenda contornar a proteção.

Procedimento: python scripts/test_report.py em cópia isolada

Resultado: 71 testes aprovados em 8,265 s.

Limite: Testes da geração/contratos do relatório; não executam containers nem provam estado atual dos registros históricos.

Procedimento: Python do .venv existente, -X utf8, PYTHONPATH da cópia, pytest -q -p no:cacheprovider em app

Resultado: 108 aprovados, 18 skips de integração PostgreSQL, em 5,00 s.

Limite: Ambiente já instalado; não prova instalação limpa. Nenhuma flag de banco de testes foi habilitada e nenhum banco real foi limpo.

Procedimento: Invocação de report.guide_urls em diretório temporário; inspeção do link compose.yaml

Resultado: README copiado=true; link (`compose.yaml`) presente=true; destino compose.yaml existente=false.

Limite: Confirma a saída parcial dos guias copiados, não falha no link original do clone.

Procedimento: report.shown(0.25) e report.shown(0.75)

Resultado: Retornaram '0,2' e '0,8'. A tabela de recursos usa esse mesmo formatador em nano_cpus/1e9.

Limite: Não altera limites dos containers; erro de precisão da apresentação.

Procedimento: Auditor principal renderizou docs/examples/report.html em 1440, 768 e 320 px

Resultado: Sem pageerror ou overflow global no estado inicial; captura desktop inspecionada com layout coerente. Evidências em containerops-{width}.png e reports-browser.json.

Limite: HTML histórico de 12/10/2026 renderizado agora. Não representa novas execuções de backup/restore, não prova o estado atual de Docker e não cobre todas as nove vistas/estados.

Problemas por categoria

UI/UX / comunicação técnica

PROBLEMA OPS-01 - A tabela de recursos arredonda quotas de CPU para valores diferentes da configuração

- **Repositório:** containerops.
- **Categoria:** UI/UX / comunicação técnica.
- **Gravidade:** Baixa.
- **Localização:** scripts/report.py:32-42 e 144-172; docs/examples/report.html, painel Verificação → identidade dos processos.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

A tabela de recursos arredonda quotas de CPU para valores diferentes da configuração

Evidência:

`shown` formata todo float com uma casa decimal. `resource_table` passa `nano_cpus / 1_000_000_000`; limites 0.25 e 0.75 aparecem como 0,2 e 0,8. A chamada direta do formatador reproduziu ambos os valores.

Por que isso é um problema:

É aceitável arredondar uma duração resumida; um limite configurado deve ser apresentado com a precisão necessária para identificar a quota efetiva. 0,2 sugere 20% de CPU, enquanto o container tem 25%.

Impacto:

O relatório dificulta comparar Docker inspect/Compose com a evidência exibida e passa uma configuração incorreta ao avaliador.

Correção recomendada:

Permitir precisão por campo ou usar formatador específico para quota de CPU; preservar duas casas nesse campo e rótulo claro de CPUs.

Implementação sugerida:

```
from decimal import Decimal

def cpu_quota(nano_cpus: int) -> str:
    value = Decimal(nano_cpus) / Decimal(1_000_000_000)
    return format(value.normalize(), 'f').replace('.', ',')
```

Validar o tipo/intervalo antes de formatar; `250_000_000` deve produzir `0,25`. Não alterar a regra de resumo das durações.

Arquivos afetados: `scripts/report.py`, `scripts/test_report.py`, `docs/examples/report.html (regenerar)`.

Como validar: Gerar tabela com 250000000, 500000000 e 750000000 nanocpus e verificar 0,25 / 0,5 / 0,75; comparar com o JSON de hardening e garantir que a tabela ainda cabe nas larguras suportadas.

Documentação / UX

PROBLEMA OPS-02 - Guias copiados para a sessão conservam links relativos para arquivos ausentes

- **Repositório:** containerops.
- **Categoria:** Documentação / UX.
- **Gravidade:** Média.
- **Localização:** scripts/report.py:415-458, guide_urls; docs/report-guide.md → Gerar um relatório.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Guias copiados para a sessão conservam links relativos para arquivos ausentes

Evidência:

`guide_urls` copia uma lista de Markdown sem transformar os links. A cópia de README.md contém `(compose.yaml)` e links para app/src, scripts e imagens que não acompanham a pasta. Fixture confirmou README presente, referência Compose presente e destino inexistente.

Por que isso é um problema:

O texto já informa que imagens e código continuam no repositório, mas os links relativos da cópia não alcançam esse repositório. Saber da limitação não transforma o clique em um destino utilizável.

Impacto:

Quem abre o artefato de CI/sessão consegue chegar ao guia inicial e encontra imagens ausentes e caminhos quebrados justamente ao conferir implementação e arquitetura.

Correção recomendada:

Reescrever no pacote os links para arquivos não copiados usando URLs do commit que originou o relatório, ou copiar dependências públicas necessárias preservando caminhos. Manter links entre Markdown que estão no pacote.

Implementação sugerida:

Na geração do bundle, resolver cada destino relativo contra o caminho original; se o arquivo fizer parte do bundle, manter caminho relativo; se for público e externo ao bundle, apontar para `https://github.com/arthurjoanes/containerops/blob/<sha>/<path>` (raw para imagens, quando necessário). Não incluir runtime, dumps ou segredos. Incluir aviso de que links de código exigem rede. Para conteúdo local não commitado, marcar que o bundle não possui permalink fiel; não atribuir ao HEAD bytes diferentes.

Arquivos afetados: `scripts/report.py`, `scripts/test_report.py`, `docs/report-guide.md`, `docs/verification.md`.

Como validar: Gerar bundle em diretório temporário e verificar cada link relativo de Markdown/HTML: deve existir dentro da pasta ou virar URL explícita do commit. Abrir o pacote sem o clone ao lado e conferir Como executar → Compose/Arquitetura.

Documentação / Developer Experience

PROBLEMA OPS-03 - Comandos copiáveis do catálogo atendem só ao shell PowerShell

- **Repositório:** containerops.
- **Categoria:** Documentação / Developer Experience.
- **Gravidade:** Baixa.
- **Localização:** scripts/report.py:241-246 e 320-324; catálogo Cópias de backup.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

Comandos copiáveis do catálogo atendem só ao shell PowerShell

Evidência:

O gerador sempre prefixa `$env:CONTAINEROPS_SESSION='...'` ou `Remove-Item Env:CONTAINEROPS_SESSION` e identifica o bloco como PowerShell. README também suporta Linux com Python 3.11+, Compose e Buildx, sem exigir PowerShell.

Por que isso é um problema:

O rótulo evita ambiguidade, mas o usuário Linux não recebe um comando copiável para o mesmo fluxo; precisa traduzir configuração de sessão manualmente.

Impacto:

Pequena quebra no onboarding de quem reproduz o projeto em Linux/CI, especialmente na seleção correta do contexto de backup.

Correção recomendada:

Oferecer variantes Shell POSIX e PowerShell claramente identificadas. Não detectar o sistema do navegador como substituto do shell escolhido pelo usuário.

Implementação sugerida:

Para POSIX: `CONTAINEROPS_SESSION=backup-lab python3 scripts/ops.py restore-test --backup <id>`; para contexto padrão: `(unset CONTAINEROPS_SESSION; python3 scripts/ops.py backups list)`. Preservar a variante PowerShell atual e a exigência explícita de confiança para cópias importadas. Escapar argumentos pelo shell correspondente e aceitar apenas os slugs/IDs já validados.

Arquivos afetados: `scripts/report.py`, `scripts/report.html`, `scripts/report.js (se houver seletor)`, `scripts/test_report.py`, `docs/report-guide.md`.

Como validar: Copiar variante POSIX para bash e PowerShell para pwsh usando ID fixture; confirmar argumento/ambiente sem executar restore real. Seleção do shell e feedback de cópia devem ser acessíveis pelo teclado.

Código e manutenibilidade / artefatos de edição

PROBLEMA OPS-04 - O CSS mantém declarações de espaçamento e borda anuladas no mesmo bloco

- **Repositório:** containerops.
- **Categoria:** Código e manutenibilidade / artefatos de edição.

- **Gravidade:** Baixa.
- **Localização:** scripts/report.css:51,53,110,116,157.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

O CSS mantém declarações de espaçamento e borda anuladas no mesmo bloco

Evidência:

Exemplos: `.surface-panel { margin-bottom:20px; ... margin:0; }`; `.panel-toolbar` define margin-bottom e depois margin:0; `.notice` define border-left e depois border:0; `.record-details` define padding-block:12px e logo padding:0.

Por que isso é um problema:

Essas declarações não participam do resultado final. Diferem de overrides intencionais entre breakpoints: estão no mesmo bloco e tornam a regra efetiva menos clara ao editar o componente.

Impacto:

Um ajuste feito na primeira declaração não muda a tela; aumenta tentativas e risco de regressão em manutenção. É evidência objetiva de acúmulo de edição, não prova de autoria por IA.

Correção recomendada:

Remover somente declarações comprovadamente anuladas e agrupar as regras base por componente, preservando media queries e exceções relevantes.

Implementação sugerida:

Por exemplo, em `.surface-panel`, conservar `margin:0` e remover `margin-bottom:20px` se esse for o layout desejado; em `.notice`, remover border-left anulada e manter `border:0; border-top:1px solid var(--line)`. Em `.record-details`, conservar a regra final de padding e excluir a anterior sem efeito.

Arquivos afetados: `scripts/report.css`, `docs/examples/report.html (regenerar)`.

Como validar: Comparar screenshots e estilos computados antes/depois em 320/768/1440, com details aberto/fechado e impressão. A limpeza não deve alterar o resultado visual; não precisa criar testes que apenas espelhem cada declaração.

Parecer para contratação

É um dos projetos mais fortes para discutir engenharia de operação: a tarefa de contar palavras é pequena e serve como resultado verificável; o trabalho relevante está no ciclo de vida dos jobs, idempotência, limites, posse temporária, migração, backup e evidência. O código lido fornece contrapontos concretos a uma apresentação apenas baseada em Dockerfiles. Os achados confirmados desta subauditoria se concentram na fidelidade e portabilidade do relatório, não em uma falha demonstrada do protocolo de fila.

Perguntas de entrevista: (1) por que o singleton de operações serializa admissão e despacho, e onde isso limita throughput? (2) por que um lease token impede resultado tardio, mas não garante execução única de efeitos externos? (3) o que snapshot/checksum/new-job demonstram e o que não demonstram sobre um restore? (4) como rollback de imagem convive com schema expansivo? (5) por que importar bytes não equivale a confiar no SQL de um dump? (6) como impedir limpeza de recursos de outra sessão? (7) como os registros são vinculados à imagem e ao código executado? Evidências: repository, worker, ops.restore_test, backup_package, runtime_context e guias. Não inferir senioridade pessoal apenas pelo volume de infraestrutura; pedir demonstração e explicação das escolhas.

Limitações e qualidade textual

• Não foram reexecutados build, scan, PostgreSQL real, SIGKILL, TLS, export/import de imagem, rollback ou restore com containers. Provas datadas existentes não foram tratadas como execuções desta auditoria.

• Três testes de transferência foram bloqueados pela virtualização do host Codex/MSIX, exatamente pelo mecanismo documentado de segurança do runtime. Reexecutá-los num terminal não virtualizado é o próximo passo; não desativar o guardrail.

• Somente os arquivos/trechos listados foram lidos; o código extenso de oci_audit/supply/proof e todos os manifests históricos não recebeu revisão integral.

• Os testes de aplicação usaram dependências existentes, não instalação nova. 18 testes dependentes de PostgreSQL ficaram explicitamente skipped.

• Não há base para atribuir autoria por IA. A duplicação de declarações CSS é problema de manutenção verificável; textos claros, comentários e artefatos extensos não são provas de geração automatizada.

• Não foi identificada falha confirmada nos controles de segurança e concorrência lidos. Isso não é certificação nem substitui a execução das provas isoladas.

cycleops

Objetivo: Organizar estações do Oslo Bysykkel sem bicicletas ou vagas, explicar prioridades e reproduzir gravações GBFS.

Estágio observado: Demonstração pública funcional; stack local com worker, API SSE e PostgreSQL. HEAD 330e4c6bfd61e264956add9785557857456f5aff, igual ao remoto.

Tecnologias: Python 3.14, FastAPI, PostgreSQL, SQLAlchemy, React, TypeScript, Vite, Zustand, MapLibre, Docker.

Arquivos examinados

• `README.md`

• `CONTRIBUTING.md`

• `apps/backend/pyproject.toml`

• `apps/backend/src/cycleops/domain/engine.py (abertura e step)`

• `apps/backend/src/cycleops/api/routes.py`

• `apps/backend/src/cycleops/api/stream.py`

• `apps/backend/src/cycleops/api/tailer.py`

• `apps/backend/src/cycleops/application/replay.py (geração de hashes)`

• `apps/web/src/app/App.tsx`

• `apps/web/src/app/useDataSession.ts`

• `apps/web/src/app/useHashState.ts`

• `apps/web/src/features/stations/StationDetails.tsx`

• `apps/web/src/features/priorities/Indicators.tsx`

• `apps/web/src/features/priorities/Indicators.module.css`

• `apps/web/src/styles/tokens.css`

• `apps/web/src/streams/artifact.ts`

- `apps/web/tests/unit/artifact-loading.test.ts`
- `apps/web/public/replay/recorded/manifest.json`
- `apps/web/public/replay/recorded/catalog.json (estrutura inicial)`
- `compose.yaml (serviços principais)`
- `.github/workflows/ci.yml (backend)`

Verificações executadas

Procedimento: Python 3.14.8 existente: python -m pytest CycleOps/apps/backend/tests -q -p no:cacheprovider -o addopts=""; PYTHONDONTWRITEBYTECODE=1

Resultado: 304 passaram, 58 pulados, 72,66 s.

Limite: Ambiente virtual existente, sem reinstalar o lock. Integrações PostgreSQL puladas. Não equivale ao CI completo.

Procedimento: Playwright + Edge 155; demo pública em 1440, 768, 390 e 320 px, altura 1000

Resultado: Sem pageerror ou overflow horizontal global nos estados iniciais. Teste de seta entre abas falhou; catálogo adulterado foi aceito.

Limite: Não cobre todos os estados do live, leitores de tela, Safari ou Firefox. Interceptação alterou somente a resposta no navegador da auditoria.

Problemas por categoria

Segurança e confiabilidade

PROBLEMA CYC-01 - Catálogo e eventos do replay não têm seus hashes conferidos

- **Repositório:** cycleops.
- **Categoria:** Segurança e confiabilidade.
- **Gravidade:** Média.
- **Localização:** apps/web/src/streams/artifact.ts:72-124; manifesto catalogSha256/eventsSha256.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Catálogo e eventos do replay não têm seus hashes conferidos

Evidência:

loadArtifact valida schemas, stream e sequências, mas calcula SHA-256 somente de diagnostics.json. Em uma interceptação local de catalog.json, o nome da estação foi alterado para AUDITORIA_HASH_ALTERADO; a demo exibiu esse nome com o manifesto original. Recibo: browser-checks.json, catalogHashAccepted=1.

Por que isso é um problema:

Campos semanticamente diferentes continuam válidos no schema. O manifesto e o link compartilhado deixam de identificar os bytes efetivamente usados. Isso não demonstra invasão do servidor.

Impacto:

Um arquivo trocado ou uma publicação inconsistente pode apresentar dados diferentes com a identidade do artefato anterior.

Correção recomendada:

Ler o catálogo como texto, conferir seu hash e o texto descomprimido dos eventos antes de JSON.parse/parseEvents. Usar a mesma codificação UTF-8 da geração Python. Manter a validação estrutural existente.

Implementação sugerida:

```
const [catalogText, eventText] = await Promise.all([
  fetchOk(`${base}catalog.json`, signal).then(r => r.text()),
  loadEventText(base, signal), // extrair a descompressão já existente
]);
if (await sha256(catalogText) !== manifest.catalogSha256 ||
    await sha256(eventText) !== manifest.eventsSha256) {
  throw new InvalidPayloadError("artifact hash");
}
const catalog: unknown = JSON.parse(catalogText);
const events = parseEvents(eventText);
```

Integrar esse trecho ao Promise.all atual, preservando a leitura paralela de diagnostics. loadEventText é uma função a extrair, não uma API já existente.

Arquivos afetados: `apps/web/src/streams/artifact.ts`, `apps/web/tests/unit/artifact-loading.test.ts`.

Como validar: Alterar um nome e uma contagem sem violar os schemas: ambos devem gerar InvalidPayloadError. Arquivos originais devem carregar, com e sem Content-Encoding:gzip. Repetir a interceptação do recibo.

UI/UX e acessibilidade

PROBLEMA CYC-02 - Abas Lista/Mapa anunciam um padrão de teclado que não implementam

- **Repositório:** cycleops.
- **Categoria:** UI/UX e acessibilidade.
- **Gravidade:** Média.
- **Localização:** apps/web/src/app/App.tsx:187-203.
- **Esforço:** baixo.
- **Prioridade:** P1.

Problema identificado:

Abas Lista/Mapa anunciam um padrão de teclado que não implementam

Evidência:

Botões têm role=tab e aria-selected, ambos tabIndex=0, nenhum aria-controls. Em 390 px, ArrowRight com foco em Lista manteve o foco e a seleção em Lista (browser-checks.json).

Por que isso é um problema:

O padrão de abas espera navegação por setas e associação ao painel; usuários de tecnologia assistiva recebem semântica incompleta. Enter e clique continuam possíveis. Referência: https://www.w3.org/WAI/ARIA/apg/patterns/tabs/.

Impacto:

Navegação móvel por teclado inconsistente; não é bloqueio total da troca de visão.

Correção recomendada:

Como são duas opções simples de visualização, a correção menor é usar grupo de botões pressionáveis. Alternativamente implementar tabs completas com foco móvel e tabpanel.

Implementação sugerida:

```
<div role="group" aria-label="Visão">
  {(["list", "map"] as const).map(tab => (
    <button key={tab} type="button"
      aria-pressed={hash.tab === tab}
      onClick={() => setHash({ tab })}>
      {tab === "list" ? "Lista" : "Mapa"}
    </button>
  ))}
</div>
```

Manter as classes e os ícones atuais. Se a opção for manter role=tab, usar aria-controls, IDs nos painéis, tabIndex 0/-1 e setas esquerda/direita.

Arquivos afetados: `apps/web/src/app/App.tsx`, `apps/web/tests/e2e/uiux.spec.ts`.

Como validar: Em 320 e 390 px, navegar somente com teclado e conferir nome, estado pressionado e foco visível; se mantiver tabs, ArrowRight/Left alternam o foco e existe somente uma entrada de Tab no grupo.

Documentação

PROBLEMA CYC-03 - Guia chama de pura uma função que modifica o estado recebido

- **Repositório:** cycleops.
- **Categoria:** Documentação.
- **Gravidade:** Baixa.
- **Localização:** CONTRIBUTING.md:10; apps/backend/src/cycleops/domain/engine.py:1-6, 70-82.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

Guia chama de pura uma função que modifica o estado recebido

Evidência:

O guia diz "pure, no I/O, no wall clock". O módulo explica que step changes state in place e step atribui state.clock_now e state.policy_version.

Por que isso é um problema:

Pureza inclui ausência de mutação observável do argumento. Isolamento de I/O e determinismo são propriedades diferentes.

Impacto:

Quem reutiliza o estado anterior em comparação ou teste pode assumir uma garantia inexistente.

Correção recomendada:

Corrigir a descrição do guia; não refatorar o motor só para satisfazer um adjetivo.

Implementação sugerida:

Substituir a linha da seção Layout por:

domain/: the engine. step(state, input, policy) -> (state, events) is deterministic, performs no database/network access or system-clock reads, and updates the supplied state in place. It may emit diagnostic warnings through logging. Callers that need the previous state must copy it before calling step.

Arquivos afetados: CONTRIBUTING.md.

Como validar: Ler a assinatura e o contrato lado a lado. Um teste de identidade deve continuar mostrando que o retorno contém o mesmo objeto recebido, e o guia deve declarar isso.

Parecer para contratação

Demonstra contratos compartilhados, estado de domínio, reconexão por cursor, prioridade explicável e tratamento de qualidade de dados. A demo permite avaliação imediata. O achado de hash pede uma explicação sobre identidade do artefato; a documentação de pureza é uma imprecisão localizada. Perguntas: por que pg_notify não basta como fonte dos eventos? Como o cliente detecta lacunas de sequência? O que diferencia uma estação sem bicicleta de um incidente confirmado? Como evitar misturar arquivos de dois builds? Não comprova operação com tráfego real ou pesquisa com operadores de bicicletas.

Limitações e qualidade textual

- Backend PostgreSQL/Compose, carga, latência e live não executados; 58 testes pulados.
- Revisão manual de código dirigida aos arquivos listados, sem leitura integral de todas as migrações e testes.
- Nenhuma prova de autoria automatizada inferida. Contratos/Ajv gerados são artefatos técnicos esperados; a imprecisão CYC-03 é um problema objetivo de documentação.

quake-exposure

Objetivo: Calcular ativos de uma carteira fictícia próximos a terremotos ou acima de intensidade MMI, preservando revisões e publicações.

Estágio observado: Demo pública de snapshot funcional; stack local de CDC e PostGIS. Snapshot auditado do GitHub: a928c1f6e7faa5ee542f127e243320515c9ceab4.

Tecnologias: Python 3.14, FastAPI, PostGIS, Kafka, Debezium, TypeScript, Leaflet, Vite, Docker.

Arquivos examinados

- README.md (visão, demo, execução/verificação e limites)
- pyproject.toml
- web/package.json
- .github/workflows/ci.yaml
- docs/operacao.md (primeira carga, carteira, recuperação)
- src/quakeexposure/api/__init__.py (tenants, eventos, publicações, ativos, diff, região)
- src/quakeexposure/exposure/worker.py (claim/run/run_pending)
- src/quakeexposure/domain/exposure.py
- src/quakeexposure/domain/grid.py
- src/quakeexposure/ingestion/http.py
- tests/unit/test_grid.py (oráculo e grids inválidos)

- `web/src/main.ts (estado, mapa, publicação, erros e ciclo)`
- `web/src/api.ts`
- `web/src/refresh.ts`
- `web/src/navigation-state.ts`
- `web/src/map-view.ts (camadas, eventos, seleção por área e teclado)`
- `web/src/style.css (tokens e principais componentes)`

Verificações executadas

Procedimento: npm ci --ignore-scripts; npm test; npm run typecheck em cópia de auditoria

Resultado: Instalação completou; npm reportou 0 vulnerabilidades nessa instalação. 15 arquivos/129 testes passaram; typecheck terminou com código 0.

Limite: Não certifica dependências Python, imagens Docker ou histórico Git. Sem teste de integração CDC/PostGIS.

Procedimento: repro_grid.py contra o parser original; defusedxml 0.7.1 instalado somente na pasta da auditoria

Resultado: Grid normal retorna MMI 7,0; com as duas linhas centrais permutadas retorna 3,0 para a mesma coordenada. Ambos aceitos.

Limite: Entrada sintética malformada, não evidência de que uma captura real atual contenha esse erro.

Procedimento: Playwright + Edge155 em 1440/768/390/320 px; comparação no desktop

Resultado: Sem pageerror/overflow global no estado inicial. Comparação mostrou 45→46 classificados e +US$16.131,63.

Limite: A tentativa breve de desenho por teclado não concluiu um polígono válido; resultado inconclusivo, não classificado como falha.

Problemas por categoria

Código e confiabilidade

PROBLEMA QEX-01 - Parser confere apenas os cantos do grid e aceita células intermediárias fora de ordem

- **Repositório:** quake-exposure.
- **Categoria:** Código e confiabilidade.
- **Gravidade:** Alta.
- **Localização:** src/quakeexposure/domain/grid.py:96-115; Grid.mmi_at:34-40.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Parser confere apenas os cantos do grid e aceita células intermediárias fora de ordem

Evidência:

O loop descarta as coordenadas intermediárias e acrescenta MMI por ordem física. Só first/last são confrontados com a extensão. repro_grid.py permuta as linhas centrais de um grid 2×2: a coordenada (1,1) muda de MMI 7 para 3 sem rejeição.

Por que isso é um problema:

mmi_at usa índice linha×nlon+col e pressupõe uma malha ordenada. Conferir quantidade e cantos não garante essa premissa.

Impacto:

Entrada fora de ordem pode excluir um ativo que passa do limiar MMI 6. O erro é silencioso e afeta a função central do projeto. Não foi encontrado em uma captura USGS real nesta auditoria.

Correção recomendada:

Validar a coordenada esperada de cada linha, incluindo normalização de longitude, antes de acrescentar MMI. Rejeitar a malha inconsistente com UnsupportedGrid.

Implementação sugerida:

```
row_index, col_index = divmod(n, nlon)
expected_lon = lon_min + col_index * (lon_max - lon_min) / (nlon - 1)
expected_lat = lat_max - row_index * (lat_max - lat_min) / (nlat - 1)
if (not _same_lon(lon, expected_lon)
        or abs(lat - expected_lat) > COORD_TOLERANCE):
    raise UnsupportedGrid(f"coordenada inesperada na linha {n + 1}")
mmi.append(value)
```

Inserir a validação no loop após as verificações de valores finitos, antes do append existente. Manter apenas um mmi.append(value). Preservar tolerâncias e testes de antimeridiano.

Arquivos afetados: `src/quakeexposure/domain/grid.py`, `tests/unit/test_grid.py`.

Como validar: Permutar duas linhas internas, repetir uma coordenada e deslocar uma coordenada interna: os três casos devem ser rejeitados. Reexecutar o oráculo das capturas reais e antimeridiano. Os valores originais devem permanecer idênticos.

UI/UX e confiabilidade

PROBLEMA QEX-02 - Consulta pendurada impede o próximo ciclo automático de atualização

- **Repositório:** quake-exposure.
- **Categoria:** UI/UX e confiabilidade.
- **Gravidade:** Média.
- **Localização:** web/src/api.ts:126-136; web/src/main.ts:624-628.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Consulta pendurada impede o próximo ciclo automático de atualização

Evidência:

get usa fetch sem signal/deadline; tick faz await refresh antes de agendar setTimeout. Uma promessa pendente em eventos, revisões ou publicação mantém esse ciclo sem conclusão. Mudanças de seleção podem iniciar um novo tick. O botão retryAnalysis também dispara tick, mas fica oculto durante loading e aparece em estado de erro; não oferece saída enquanto a primeira requisição permanece pendente.

Por que isso é um problema:

Tratamento catch só funciona quando a requisição termina com erro. Não cobre conexão que permanece aberta sem completar a resposta.

Impacto:

O painel pode conservar Carregando a análise ou dados antigos por tempo indefinido, sem acionar o feedback de falha previsto. Na demo pública o transporte usa snapshots; o principal impacto é na API local.

Correção recomendada:

Adicionar prazo explícito e cancelamento por mudança da seleção. Cobrir também leitura do corpo, além dos headers. Preservar o último resultado com horário e reutilizar o botão existente Tentar novamente quando o prazo expirar.

Implementação sugerida:

```
const controller = new AbortController();
const timeout = window.setTimeout(() => controller.abort(), 15_000);
try {
  const r = await fetch(url, {
    headers: { Accept: "application/json" },
    signal: controller.signal,
  });
  // manter o tratamento existente de 404, 409 e demais status
  return await r.json() as T;
} finally {
  window.clearTimeout(timeout);
}
```

Exemplo parcial para integrar em get: construir url como hoje. Se receber sinal externo, combinar cancelamento da seleção e prazo. 15 s é proposta inicial, não medição de SLA.

Arquivos afetados: `web/src/api.ts`, `web/src/main.ts`, `web/src/api.test.ts`, `web/src/refresh.test.ts`.

Como validar: Em transporte simulado, manter headers/corpo pendentes além de 15 s. Esperar aborto e mensagem recuperável, permitir retry e próximo ciclo. Trocar evento durante uma consulta lenta e assegurar que o resultado anterior não reaparece. Não testar indisponibilidade contra USGS.

Código e documentação

PROBLEMA QEX-03 - User-Agent anuncia versão diferente da versão do pacote

- **Repositório:** quake-exposure.
- **Categoria:** Código e documentação.
- **Gravidade:** Baixa.
- **Localização:** src/quakeexposure/ingestion/http.py:37,107; pyproject.toml:3.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

User-Agent anuncia versão diferente da versão do pacote

Evidência:

USER_AGENT = "quake-exposure/0.0.1"; versão declarada do projeto = "0.3.0".

Por que isso é um problema:

Uma chamada do coletor não identifica a versão instalada corretamente.

Impacto:

Diagnóstico de compatibilidade e rastreamento de logs confundem revisões do cliente.

Correção recomendada:

Derivar a versão da metadata instalada e testar o cabeçalho emitido.

Implementação sugerida:

```
from importlib.metadata import version
USER_AGENT = f"quake-exposure/{version('quake-exposure')}"
```

O comando uv sync instala o pacote. Se os testes rodarem sem instalação, documentar essa condição e usar um fallback explícito development, sem fingir uma versão publicada.

Arquivos afetados: `src/quakeexposure/ingestion/http.py`, `tests/unit/test_http.py`.

Como validar: Capturar o header com MockTransport e comparar com importlib.metadata.version("quake-exposure"). Não é preciso chamar a fonte real.

Parecer para contratação

Demonstra engenharia de dados geográficos, versionamento temporal, limites do domínio, separação de dinheiro por moeda e publicação consistente. A demo e as referências tornam o projeto examinável. O parser de grid precisa de correção antes de usar sua validação como argumento forte de qualidade. Perguntas: por que exposição não é estimativa de perda? Qual diferença entre validade temporal e conhecimento da carteira? Como o CAS impede publicação obsoleta? Como excluir um titular sem reintroduzi-lo por CDC antigo? A última pergunta requer revisão/execução adicional do módulo de privacidade, não integralmente auditado aqui.

Limitações e qualidade textual

- Sem execução de PostGIS, Kafka, Debezium, coleta LIVE, recuperação de backup ou exclusão de titular.
- Módulos de privacidade/CDC não tiveram leitura integral; conclusões sobre eles se limitam à arquitetura e documentação examinadas.
- Sem inferência de autoria IA. USER_AGENT desatualizado é inconsistência objetiva; código gerado de contratos e fixtures declaradas não são, por si, problemas.

delta

Objetivo: Corrigir exemplos Python de encadeamento do DeltaTableBuilder e o texto table name/location.

Estágio observado: Fork de contribuição. Branch autoral docs/fix-builder-example-syntax, commit cffa94f9e2e9a4d672e994021755f3f8ec125fc7; branch padrão master ainda contém exemplo anterior. PR aberto, merged_at nulo na consulta de 13/10/2026: https://github.com/delta-io/delta/pull/7846.

Tecnologias: Python, Spark/Scala/Java (upstream, não atribuídos ao autor).

Arquivos examinados

- `python/delta/tables.py nas versões padrão e autoral`
- `diff completo do commit autoral`
- `refs remotos e metadados públicos do PR`

Verificações executadas

Procedimento: forks_probe.py; ast.parse dos exemplos Delta; execução real de paginate com venv existente do fork

Resultado: Os dois exemplos de master causam IndentationError ao serem extraídos e analisados com ast.parse. Os dois exemplos da branch corrigida compilam; não foi executado Spark.

Limite: Validação da contribuição delimitada; não é teste integral do upstream ou reinstalação do lock.

Problemas por categoria

Não foi encontrado defeito adicional no diff autoral examinado. Os exemplos da branch padrão ainda contêm a versão anterior, e os PRs corretivos permanecem abertos. Isso é estado de integração, não justificativa para modificar a contribuição ou atribuir ao autor toda a manutenção do upstream.

Parecer para contratação

Os dois exemplos de master causam IndentationError ao serem extraídos e analisados com ast.parse. Os dois exemplos da branch corrigida compilam; não foi executado Spark. A contribuição demonstra leitura crítica de exemplos e correção contida. Não sustenta alegação de autoria da biblioteca. Perguntar qual entrada reproduz o defeito, por que a alteração basta e como evitar regressão documental.

Limitações e qualidade textual

- Revisão integral do diff autoral e do exemplo afetado; o restante do grande projeto upstream não foi auditado arquivo por arquivo.
- PR aberto não é contribuição aceita/mesclada. Não foi encontrado outro defeito na correção proposta; não há motivo para inventar tarefas de implementação.
- Comentários e documentação herdados não permitem inferir uso de IA pelo dono do fork.

fastapi-pagination

Objetivo: Corrigir o cálculo do total no exemplo de paginação customizada.

Estágio observado: Fork de contribuição. Branch autoral docs/count-before-pagination, commit b626a76fd4f32d4f9328d3bfc1376bfa16a68109; branch padrão main ainda contém exemplo anterior. PR aberto, merged_at nulo na consulta de 13/10/2026: https://github.com/uriyyo/fastapi-pagination/pull/2077.

Tecnologias: Python, FastAPI (upstream).

Arquivos examinados

- `docs/learn/tutorial_advanced/custom_paginate.md nas versões padrão e autoral`
- `diff completo do commit autoral`
- `refs remotos e metadados públicos do PR`

Verificações executadas

Procedimento: forks_probe.py; ast.parse dos exemplos Delta; execução real de paginate com venv existente do fork

Resultado: Executei o exemplo com 100 itens, página 2 e tamanho 10: main produz total=10/pages=1; a branch produz total=100/pages=10 com os mesmos itens 10..19.

Limite: Validação da contribuição delimitada; não é teste integral do upstream ou reinstalação do lock.

Problemas por categoria

Não foi encontrado defeito adicional no diff autoral examinado. Os exemplos da branch padrão ainda contêm a versão anterior, e os PRs corretivos permanecem abertos. Isso é estado de integração, não justificativa para modificar a contribuição ou atribuir ao autor toda a manutenção do upstream.

Parecer para contratação

Executei o exemplo com 100 itens, página 2 e tamanho 10: main produz total=10/pages=1; a branch produz total=100/pages=10 com os mesmos itens 10..19. A contribuição demonstra leitura crítica de exemplos e correção contida. Não sustenta alegação de autoria da biblioteca. Perguntar qual entrada reproduz o defeito, por que a alteração basta e como evitar regressão documental.

Limitações e qualidade textual

- Revisão integral do diff autoral e do exemplo afetado; o restante do grande projeto upstream não foi auditado arquivo por arquivo.
- PR aberto não é contribuição aceita/mesclada. Não foi encontrado outro defeito na correção proposta; não há motivo para inventar tarefas de implementação.
- Comentários e documentação herdados não permitem inferir uso de IA pelo dono do fork.

Parte 3 - Revisão de documentação

Os pareceres individuais acima registram o diagnóstico inicial. Os trechos desta edição descrevem as correções locais revisadas, com destinos definidos. Preservam-se os READMEs considerados bons; não é necessário substituí-los integralmente. As instruções editoriais ficam fora do conteúdo copiável. Resultados históricos continuam ligados às datas, commits e recibos originais.

arthurjoanes

Manter a biografia e as experiências declaradas pelo autor. O ajuste necessário é a descoberta das duas demonstrações pelo navegador; não acrescentar impacto comercial não demonstrado.

Destino: `profile-readme/README.md`, seção de projetos em destaque. Conteúdo para inserir ou substituir somente nessa seção:

```
Os projetos são demonstrações pessoais. Os cenários de varejo e operações usam dados sintéticos; CycleOps e
  QuakeExposure também usam dados públicos, com as fontes e os limites descritos nos repositórios.

- [CycleOps](https://arthurjoanes.github.io/cycleops/): disponibilidade de estações de Oslo, prioridades e r
  eplay de uma gravação GBFS.
- [QuakeExposure](https://arthurjoanes.github.io/quake-exposure/): exposição de uma carteira fictícia a terr
  emotos, com mapa e comparação de publicações.
```

Destino: `profile-readme/README.en.md`, seção de projetos em destaque. Conteúdo para inserir ou substituir somente nessa seção:

```
These projects are personal demonstrations. Retail and operations scenarios use synthetic data; CycleOps and
   QuakeExposure also use public data, with sources and limits described in their repositories.

- [CycleOps](https://arthurjoanes.github.io/cycleops/): Oslo bike-share availability, priorities and replay
  of a recorded GBFS feed.
- [QuakeExposure](https://arthurjoanes.github.io/quake-exposure/): earthquake exposure for a fictional portf
  olio, with a map and publication comparisons.
```

evidencedesk

Manter propósito, casos, autoria e limites. Corrigir apenas os contratos de exportação, importação e navegação de snapshots.

Destino: `evidencedesk/docs/api-contract.md`, exportações. Conteúdo para inserir ou substituir somente nessa seção:

```
A exportação de uma revisão aprovada admite `queued`, `running`, `retry_wait`, `succeeded`, `failed`, `cance
  lled` e `expired`. O download só fica disponível após sucesso, dentro da validade de 24 horas e com acesso
   autorizado no momento da consulta.

Uma resposta incerta mantém a chave da intenção em andamento. Preparar uma nova exportação, após término con
  firmado, cria outra intenção; perder a resposta dessa nova intenção também deve conservar sua chave ao rep
  etir.
```

Destino: `evidencedesk/docs/frontend.md`, recuperação e coleções. Conteúdo para inserir ou substituir somente nessa seção:

```
Na mesma janela, repetir a criação de uma importação após resposta perdida reutiliza a chave e recupera o lo
  te original. A chave em memória não oferece retomada persistente depois de recarregar ou fechar a página.

O seletor de snapshots carrega páginas autorizadas de até 50 opções e permite buscar as anteriores. Cada pág
  ina aplica novamente as permissões; a lista recebida não deve ser interpretada como inventário completo.
```

gestao-recebiveis

Preservar o README, os exemplos financeiros e a galeria. As correções necessárias são localizadas no contrato HTTP, navegação e interpretação das capturas.

Destino: `gestao-recebiveis/docs/architecture.md`, fronteira HTTP. Conteúdo para inserir ou substituir somente nessa seção:

```
O frontend usa `/api/v1` para autenticação, formulários e ações operacionais; as leituras financeiras pagina
  das usam `/api/v2`. A listagem v2 evita carregar todas as parcelas por título. O detalhe pagina recebiment
  os, eventos e lembretes separadamente, conservando totais e saldo globais. O contrato v1 permanece disponí
  vel para clientes existentes.
```

Destino: `gestao-recebiveis/docs/frontend-quality.md`, navegação. Conteúdo para inserir ou substituir somente nessa seção:

```
Áreas, títulos, clientes e filtros de consulta têm endereço validado no navegador. Recarregar, abrir outra a
  ba ou usar Voltar/Avançar retoma esse contexto após autenticação. Rascunhos e intenções financeiras ficam
  separados da navegação e não são reenviados por uma mudança de URL.

Selecionar uma faixa de aging fixa a situação em Em aberto. O controle explica essa relação antes de enviar
  a consulta.
```

loja-assistente

Manter a separação entre interpretar, autorizar e calcular. Consolidar os recibos datados, sem somar suítes sobrepostas nem apresentar Demo como prova de LLM.

Destino: `loja-assistente/README.md`, Verificação e evidências. Conteúdo para inserir ou substituir somente nessa seção:

```
A revisão de UI/UX de 12/10/2026 registra 477 testes de backend, 57/57 avaliações offline e 85 casos Playwri
  ght. O [relatório da rodada](docs/uiux-20261012.md#validação-final) identifica fontes, dados, estados, com
  andos e limites.

As outras execuções estão em [verificação](docs/verification.md), cada uma com seu escopo. As contagens não
  devem ser somadas. Os verificadores de evidência conferem os arquivos preservados; não executam novamente
  chamadas ao modelo nem jornadas de navegador.
```

Destino: `loja-assistente/docs/interface.md`, falha de envio e histórico. Conteúdo para inserir ou substituir somente nessa seção:

```
Depois de uma falha de transporte, a consulta pode já ter sido aceita. A interface conserva a identidade da
  intenção pendente para recuperar seu resultado, sem tratar o timeout como autorização para uma nova chamad
  a paga. A chave mantida em memória não persiste após fechar ou recarregar a página.

Conversas e respostas antigas podem ser percorridas por páginas. Carregar um resultado existente não executa
   outra consulta; permissões continuam sendo verificadas pelo servidor.
```

varejo-data-pipeline

Manter apresentação, contas de referência, instalação e decisões. Não substituir o README inteiro para acrescentar uma ferramenta de QA.

Destino: `varejo-data-pipeline/docs/frontend-quality.md`, escopo dos resultados. Conteúdo para inserir ou substituir somente nessa seção:

```
As verificações de navegador usam o ambiente e as versões fixadas em `tools/browser`. O roteiro desta página
   identifica instalação, comando, cenários e destinos dos artefatos.

Cada recibo de execução se aplica às fontes que registra. Testes automatizados de geometria, teclado e axe n
  ão substituem leitor de tela, zoom nativo ou uma avaliação com usuários. A inspeção de um HTML histórico n
  ão valida novamente o processamento do pipeline.
```

api-sentinel

Manter o README e o roteiro Linux. O guia precisa explicar descoberta de ocorrências e diferenciar prévia sintética de monitoramento ativo.

Destino: `api-sentinel/docs/incident-console.md`, localização de ocorrências. Conteúdo para inserir ou substituir somente nessa seção:

```
A fila permite percorrer as ocorrências retidas em páginas de até 100 registros. O filtro é aplicado antes d
  a paginação; as ocorrências ativas aparecem primeiro. O campo ID do incidente continua disponível para abr
  ir diretamente uma ocorrência conhecida.

Uma prévia exportada usa dados sintéticos e mantém o probe desativado. Ela serve para examinar a interface;
  não demonstra monitoramento em execução.
```

O comando Linux autenticado já foi aplicado em `docs/demo.md` na correção API-04. Preservar esse bloco completo e a alternativa PowerShell com o shell identificado; não duplicar uma terceira cópia neste relatório.

containerops

Manter a narrativa de operação e os runbooks. Os ajustes pertencem ao guia do relatório.

Destino: `containerops/docs/report-guide.md`, pacote, comandos e recursos. Conteúdo para inserir ou substituir somente nessa seção:

```
O HTML incorpora fonte, estilos, marca e JavaScript. Os guias selecionados acompanham a sessão em `documenta
  tion/<hash>/`; links entre arquivos incluídos funcionam dentro do pacote. Código e imagens ausentes do pac
  ote apontam para o commit registrado e exigem rede.

Escolha PowerShell ou Shell POSIX antes de copiar o comando. O navegador não executa a operação. Confira a o
  rigem antes de restaurar: checksum válido confirma os bytes, não a confiança no conteúdo.

Durações resumidas usam uma casa decimal. Limites de CPU preservam a configuração: `0,25` corresponde a um q
  uarto de CPU e `0,75`, a três quartos.
```

cycleops

O README distingue corretamente replay, simulação e live. Corrigir a descrição da mutação no motor, preservando a possibilidade real de warnings.

Destino: `CycleOps/CONTRIBUTING.md`, linha `domain/` da seção Layout. Conteúdo para inserir ou substituir somente nessa seção:

```
`domain/`: the engine. `step(state, input, policy) -> (state, events)` is deterministic, performs no databas
  e/network access or system-clock reads, and updates the supplied state in place. It may emit diagnostic wa
  rnings through logging. Callers that need the previous state must copy it before calling `step`.
```

O recibo anterior dizia incorretamente “ausência de logging”; `engine.py` importa logging, cria o logger e emite warnings. Essa errata não muda o achado sobre mutação in place. A alternância corrigida em CYC-02 é **Lista/Mapa**.

quake-exposure

Preservar modos, origem pública dos eventos, carteiras fictícias e limites de exposição.

Destino: `quake-exposure/README.md`, Limites e segurança. Conteúdo para inserir ou substituir somente nessa seção:

```
A leitura de ShakeMap confere as coordenadas de cada célula e recusa malhas inconsistentes antes do cálculo.
   Os blobs reutilizados também têm sua identidade SHA-256 conferida; uma divergência interrompe o processam
  ento em vez de publicar um resultado com bytes diferentes do registro.
```

delta e fastapi-pagination

Não reescrever READMEs upstream. A contribuição deve ser apresentada no perfil ou índice pessoal, limitada ao diff autoral. Não declarar merge ou aprovação sem consultar o estado correspondente.

Destino: índice pessoal de contribuições, junto dos links dos PRs. Conteúdo para inserir ou substituir somente nessa seção:

```
- [Delta Lake #7846](https://github.com/delta-io/delta/pull/7846): correção de exemplos Python de encadeamen
  to do DeltaTableBuilder e do texto table name/location.
- [fastapi-pagination #2077](https://github.com/uriyyo/fastapi-pagination/pull/2077): correção do cálculo do
   total antes do recorte no exemplo de paginação customizada.
```

Parte 4 - Revisão de UI/UX

Conferência posterior de todas as evidências documentais

A matriz visual da revisão posterior complementa esta análise histórica com seis dimensões por projeto: paleta/contraste, tipografia, layout/espaçamento/proporção, ícones/coerência, gráficos/propósito e estados. Foram examinados 459 arquivos de mídia, 31 Mermaid e os HTMLs documentais. Os dois vídeos desse conjunto foram amostrados em seis quadros cada. Os registros por arquivo distinguem capturas de página, recortes, propostas e resultados históricos.

Projeto	Evidência visual adicional	Conclusão e limite
EvidenceDesk	37 arquivos e seis diagramas; workspace, fonte móvel, conflito e identidade.	Recorte de divergências e JSON citado mostram relação com a fonte; capturas do HTML offline não comprovam execução autenticada.
Recebíveis	46 arquivos e três diagramas; carteira, títulos, baixa e restore.	Contas financeiras conferidas; dois prints ainda carregando foram identificados. Arquitetura atual distingue v1 e leituras v2.
Loja Assistente	172 arquivos e quatro diagramas; cinco larguras, antes/depois, gráfico e cálculo.	Soma semanal confere; seleção pendente e filtros móveis melhoram visivelmente. README passou a ligar o cálculo à imagem correta.
Varejo	35 arquivos, sete HTMLs e três diagramas.	Indicadores e categorias coerentes; massas de publicação/recuperação diferentes têm contexto próprio.
API Sentinel	49 arquivos, um HTML e três diagramas.	Contagens do gráfico conferem com o recorte da lista; dados sintéticos e HTML histórico são identificados.
ContainerOps	27 arquivos, quatro HTMLs com 33 painéis e três diagramas.	Resultados, datas e evidências legíveis; snapshot não atesta saúde atual.
CycleOps	39 arquivos, incluindo dois vídeos amostrados, e sete diagramas.	Mapa/lista e prioridades vazias coerentes com o instante; imagem chamada hash-test não comprova rejeição de hash.
QuakeExposure	35 arquivos e dois diagramas; mapa, distribuição, comparação e operação.	Denominadores, moedas e deltas conferidos; CDC não executado e tempo não medido permanecem explícitos.

As conclusões numéricas e limitações das imagens acompanham a matriz. Não foi feita nova medição integral de contraste, teste com leitor de tela ou estudo com pessoas. As capturas originais foram preservadas; o texto abaixo mantém a perspectiva da auditoria inicial.

As capturas desta auditoria usam Edge 155 via Playwright. Não observar overflow horizontal global é uma constatação do estado capturado; não comprova todos os estados responsivos. Tabelas podem ter rolagem local intencional. Nenhuma tela não aberta é apresentada como visualmente validada.

Projeto	Base visual usada	Larguras atuais	Limite principal
CycleOps	Site público	1440, 768, 390, 320	Replay; live não executado
QuakeExposure	Site público e comparação	1440, 768, 390, 320	Snapshot; CDC não executado
API Sentinel	Servidor de fixture do HEAD	1440, 768, 320	Probe desligado, sem stack real

Projeto	Base visual usada	Larguras atuais	Limite principal
ContainerOps	HTML de exemplo servido nesta auditoria	1440, 768, 320	Conteúdo operacional histórico
Varejo Data Pipeline	Renderer atual com snapshot sintético	1440, 768, 320	Sem nova execução Spark
EvidenceDesk	Código e capturas históricas preservadas	Não reexecutadas	Fluxos autenticados não navegados
Gestão de Recebíveis	Código/CSS e material registrado no projeto	Não reexecutadas	Viewports e filtros pendentes de reprodução
Loja Assistente	Código e capturas históricas preservadas	Não reexecutadas	Histórico/chat não navegados ao vivo

evidencedesk

Escopo visual

Análise estática do código atual e inspeção de três PNGs versionados. Não houve servidor/navegador atual nem medição de contraste, desempenho, zoom ou leitor de tela. A imagem `docs/readme/home.png` é identificada no README como captura anterior; `workbench-desktop.png` mostra um laboratório separado. Não se pode transferir a aparência desse laboratório para o produto principal.

Fila e abertura de incidente

A captura da fila apresenta navegação lateral, tabela com título legível e contagens contextualizadas. A densidade faz sentido para triagem técnica. O componente de fila tem busca e estados de consulta; esses comportamentos foram lidos, não executados. O maior risco concreto do detalhe é a lista de snapshots silenciosamente limitada (EVD-04).

Importação

O fluxo apresenta manifesto, upload e retomada com estado persistido após conhecer o lote. A recuperação inicial ainda admite duplicação de reserva quando a resposta de criação se perde (EVD-03). A instrução de próxima ação deve distinguir repetir envio de recuperar um lote já criado.

Evidência e citação

A captura mobile de citação conserva o contexto da alegação acima do JSON e indica a fonte com clareza. Fonte monoespaçada e metadados favorecem inspeção técnica; não há evidência visual de overflow nessa imagem. Leitor de PDF e navegação por fonte foram revisados estaticamente. Acessibilidade do PDF não foi certificada.

Editor e revisão

Há esforço real em diálogo, mensagens, proteção de rascunho e revisão-base. Os formulários repetidos precisam apontar cada lista inválida (EVD-05). Após devolução, a CTA hoje contraria o backend (EVD-01). O contador de inconclusões deve preservar a semântica das regras (EVD-06).

Exportação

É positivo informar revisão e expiração junto ao download, mas a recuperação de estados terminais está incompleta (EVD-02). O estado final deve oferecer uma ação possível e evitar o texto “Preparando” quando já não existe trabalho em curso.

Identidade e responsividade

As capturas têm direção visual própria, hierarquia moderada e conteúdo específico do domínio. Não há base para acusar layout genérico ou geração por IA a partir da estética. A imagem mobile dá evidência de um fluxo estreito, não de todos os breakpoints ou interações.

gestao-recebiveis

Escopo - análise estática do frontend atual e inspeção de três capturas históricas versionadas. Não houve sessão autenticada atual; Docker/PostgreSQL não estavam ativos.

Login - labels, papéis e contas demo têm contexto explícito no código. As contas de demonstração combinam com o escopo local declarado, sem presumir que sejam credenciais de produção.

Visão geral - screenshot de capa organiza saldo aberto, valores vencidos e recebidos com bom peso visual; navegação azul e tabelas formam uma identidade consistente. O nome muito extenso de um cliente de teste ocupa destaque no ranking: serve ao teste, mas uma nova capa pode usar massa mais representativa. É refinamento editorial, não defeito de cálculo.

Importação - fluxo separa seleção, prévia/diagnóstico e confirmação, e o contrato rejeita lote conflitante por inteiro. Validação e feedback aparecem próximos ao processo; não foi refeito upload pelo navegador.

Carteira e filtros - há busca, situação, datas, cliente e faixa. REC-02 permite uma combinação rejeitada e REC-03 anula parte do modo tablet. A lista financeira não precisa do histórico completo devolvido pela API (REC-04).

Detalhe e recebimento - screenshot histórica mostra valor original, recebido e saldo residual com ações e trilha de eventos; o código preserva a intenção idempotente após incerteza de resposta. A separação de valores merece ser mantida. O endereço do título não existe na navegação atual (REC-01).

Aging e extrato - buckets e totais deixam o saldo residual visível; o extrato pagina recebimentos. Existem textos como "1 títulos" e resumo de filtro com enum bruto (REC-06).

Acessibilidade - código inclui labels, aria-invalid, região de erro, retornos de foco e testes automáticos. REC-05 melhora a sustentação do scanner. A inspeção não comprova leitor de tela, zoom nativo ou WCAG integral; não atribuo ausência de acessibilidade a partir do número de violações históricas.

loja-assistente

Escopo visual

Análise estática atual e leitura visual de `home.png`, `after-chromium-pendente-390.png` e `after-chromium-resultado-1440.png`. Os dois últimos pertencem à rodada de 12/10/2026. O verificador confirma integridade/proveniência do material; não transforma capturas históricas em teste de navegador realizado hoje.

Entrada e descoberta

A home histórica oferece perguntas de exemplo em linguagem de loja e separa Demo sem IA. O README usa a tela de resultado atualizada como apresentação principal, escolha mais informativa do que apenas uma tela vazia. A paleta sóbria e a tipografia dão identidade consistente; não há motivo demonstrado para uma reformulação estética completa.

Preparar consulta

Lojas e período ficam próximos da ação. A representação do fim excluído expõe um detalhe de contrato ao lojista e deve ser convertida para data final incluída (LOJ-04). O histórico acessível não deve desaparecer por falha isolada de favoritos (LOJ-02).

Esclarecer

Na captura de 390 px, a dúvida vem antes de executar a análise, as opções de rádio têm área legível, o escopo está explícito e a confirmação é identificável. Isso comunica que o sistema não inventou uma interpretação. A imagem não demonstra navegação por teclado nem todos os estados de validação.

Conferir resultado

A captura de 1440 px coloca recorte e modo Demo perto dos valores, divide totais e série diária e mantém alternativa de tabela/cálculo. A hierarquia prioriza a resposta, e o gráfico usa rótulos sem saturar o eixo. As explicações específicas de recorte e cobertura são uma força do produto, não devem ser removidas para obter uma aparência mais vazia.

Histórico, favoritos e falhas

O código prevê bloqueio de execução incerta em favoritos/esclarecimentos, mas não estende o mesmo cuidado ao envio de pergunta (LOJ-01). Falha parcial e ausência de conversas precisam de estados diferentes (LOJ-02). Listas limitadas exigem indicação e navegação (LOJ-03). Horários devem concordar entre sidebar e resultado (LOJ-05).

Responsividade e acessibilidade

A captura mobile observada não mostra overflow horizontal; o conteúdo segue verticalmente para além do viewport, o que por si só não é defeito. Sem execução atual não se atestam contraste, foco, leitor de tela, orientação, zoom ou todos os breakpoints. Os testes históricos continuam sendo evidência histórica específica de seus recibos.

varejo-data-pipeline

Visão geral - renderer atual aplicado ao snapshot histórico de 30 mil linhas; navegador em 1440/768/320 px sem erro JS ou overflow global no estado inicial. A hierarquia começa pelo período/publicação, apresenta quatro métricas e depois séries/ranking/mix; a identidade em petróleo é consistente. Valores e contexto do denominador evitam gráficos decorativos.

Lojas - leitura estática do renderer, CSS e JS: matriz distingue zero, ausência e negativos, com valores exatos e alternativas tabulares. Não medi o fluxo de seleção/cópia neste turno.

O que mudou - código e fixtures deixam estados inicial, comparável, incomparável e amostra insuficiente explícitos; o corpus foi renderizado, mas nem todos os estados foram operados manualmente.

Qualidade - separa publicação consultada da tentativa recente, decisão importante para não apresentar falha como perda do fechamento. VDP-01 compromete a ordenação dessa área após restauração.

Arquivos - IDs, origem e versões tornam a auditoria rastreável. A densidade é apropriada para consulta técnica secundária. Não inferi conformidade WCAG nem resultado de leitor de tela a partir de screenshots.

Entrega - VDP-02 pode comprometer a integridade do HTML durante regeneração. VDP-03 torna o QA visual histórico mais difícil de repetir. Não há evidência para acusar template genérico ou origem por IA a partir da paleta/estrutura.

api-sentinel

Central / fila. A leitura está organizada em situação, amostra diária, probe e fila. Rótulos de estado acompanham cor; o código preserva filtro/fragmento e inclui estados vazio, inválido e indisponível. O problema funcional confirmado é a falta de descoberta além de 100 registros (API-02); a busca exata por ID não resolve a tarefa quando o operador só conhece o período ou o alerta. Proposta: controles Anteriores/Próximas ocorrências abaixo da fila, rótulo de faixa e filtro preservado, sem redesenhar a identidade existente.

Detalhe. `incident_detail` diferencia firing, recuperação recebida e reconciliação administrativa, mantém orientação original e apresenta eventos do receiver separadamente do período declarado. O ID precisa permanecer estável após retenção (API-01). O histórico limita 100 eventos e informa esse limite; não foi tratado como perda silenciosa de dados.

Runbooks. Há índice e sumário interno, código escapado e retorno ao incidente. O renderer suporta deliberadamente um subconjunto de Markdown; não afirmar suporte a links/ênfase completos. Não encontrei, no trecho lido, razão para adicionar uma biblioteca de Markdown só por padronização.

Visual e acessibilidade. A subauditoria fez inspeção estática de estrutura, estilos e testes. O auditor principal renderizou a fixture com recursos locais em 1440, 768 e 320 px e não observou pageerror ou overflow global nos estados iniciais; inspecionou as capturas desktop e 320 px e considerou o layout coerente. Evidências em `api-sentinel-1440.png`, `api-sentinel-768.png`, `api-sentinel-320.png` e `reports-browser.json`, dentro de `_auditoria_2026-10-13`. Contraste automatizado, zoom e percurso completo por teclado não foram aprovados por essa verificação. A prévia exportada por `render_ui_preview.py` omite os próprios assets (API-03), o que pode distorcer uma revisão visual.

Critérios após correções. A 320/768/1440 px, manter hierarquia e identidade, nenhum overflow horizontal de página, foco visível nos novos controles e percurso de 205 ocorrências sem lacuna, repetição ou perda de filtro. Comparar preview com fontes/ícones carregados e verificar Network sem 404 em assets.

containerops

Visão geral / verificação. A composição usa navegação lateral por operação, hierarquia simples e detalhes progressivos, com rótulos de aprovação separados de suas fontes. O relatório não se apresenta como painel vivo. A tabela de recursos precisa preservar quotas exatas de CPU (OPS-01).

Catálogo de backups. Busca por ID/origem, filtro por recibo, mensagens sem resultados e separação entre integridade e restauração estão implementados. Comando copiável dá feedback e seleciona texto quando clipboard falha. Variantes de shell melhorariam a tarefa no Linux (OPS-03), sem alterar a identidade visual.

Restore, release e artefatos. Há explicação de identidade, data, imagem e origem. O HTML não deve fundir provas de execuções diferentes; o código seleciona evidências e mantém estados incompletos. A abertura de guias da sessão termina em referências ausentes (OPS-02). Não foi confirmada falha visual específica em todas essas vistas: a revisão de navegador cobriu o estado inicial do catálogo.

Render efetivo. O auditor principal abriu o HTML histórico agora em 1440, 768 e 320 px. Não houve pageerror nem overflow global no estado inicial; a captura desktop inspecionada apresentou layout coerente. Arquivos `containerops-1440.png`, `containerops-768.png`, `containerops-320.png` e `reports-browser.json` estão em `_auditoria_2026-10-13`. O conteúdo mostrado é um snapshot histórico, não resultado de nova operação Docker.

Acessibilidade e responsividade. O código contém skip link, aria-current, status da filtragem, foco após navegação, details nativo, tratamento sem JavaScript e regras de impressão. Essas implementações são evidência de intenção e cobertura de geração; leitor de tela, zoom 200/400%, todas as vistas abertas e clipboard negado ainda precisam de validação manual. O CSS tem duplicações anuladas que podem ser removidas preservando pixels (OPS-04).

cycleops

A home tem marca própria em azul petróleo, tipografia Inter e símbolos distintos para indisponibilidade. Em 1440 px, fila à esquerda e mapa à direita; em 320/390 px, a interface troca para Lista/Mapa. Não houve overflow global nas quatro capturas. A lista inicialmente vazia corresponde ao instante inicial do replay; o mapa diferencia contagem instantânea e incidente confirmado, mas a explicação precisa continuar acessível pela legenda.

O defeito confirmado é CYC-02. Preservar paleta, espaçamentos de 4/8/12/16/24/32 px e foco visível. A análise em modal abriu; a primeira captura pegou o carregamento e não serve como validação do conteúdo final. Não foram certificados contraste de cada estado, zoom a 200%, leitor de tela nem live SSE.

Capturas atuais: `_auditoria_2026-10-13/cycleops-1440.png`, `cycleops-768.png`, `cycleops-390.png`, `cycleops-320.png`. A captura `cycleops-hash-test.png` é um teste com resposta interceptada e não uma tela normal do produto.

quake-exposure

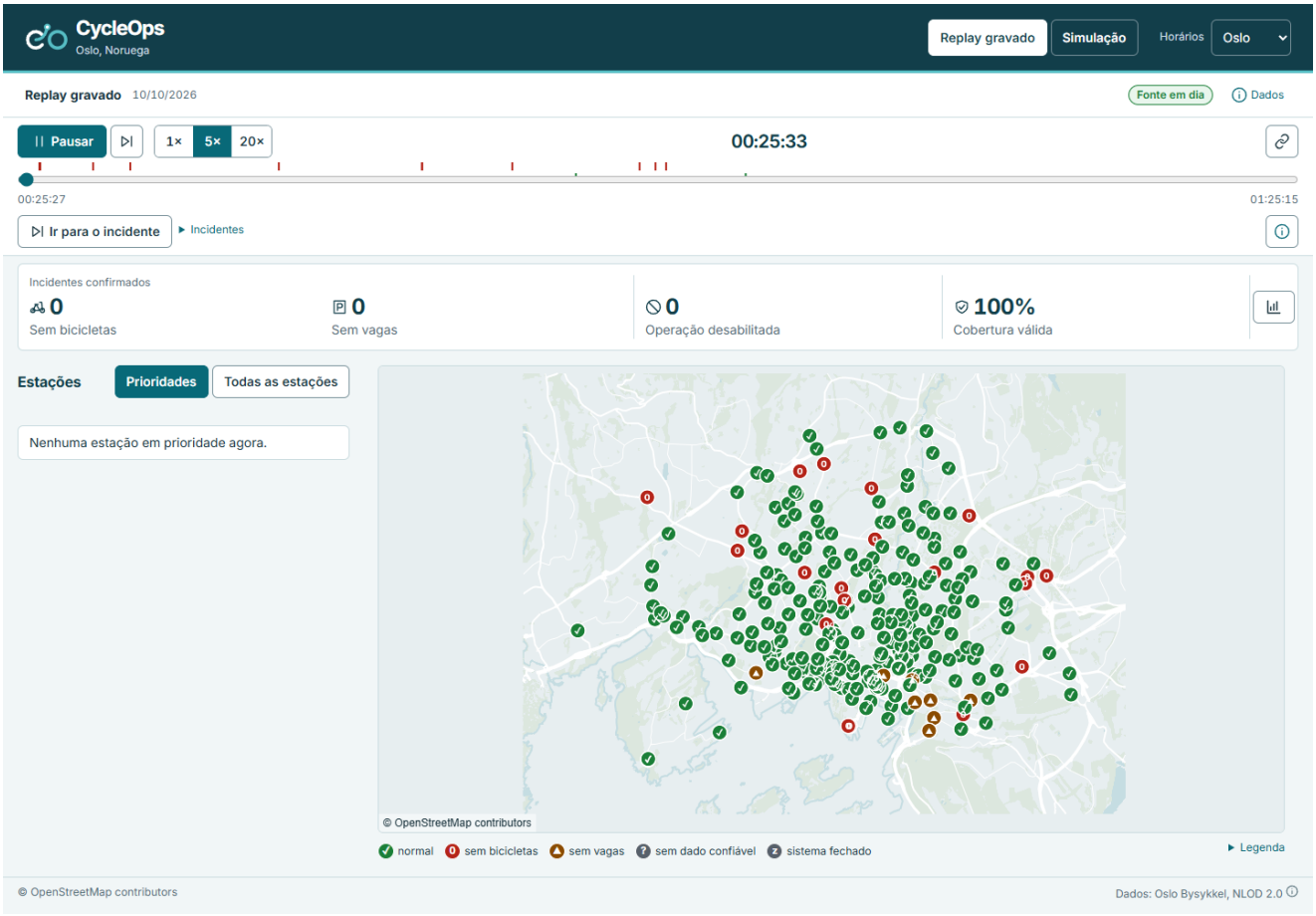
Home/mapa: identidade azul petróleo com laranja para classificados, legenda explícita e resumo por moeda. Desktop dispõe mapa e resumo lado a lado; 320/390 px recolhem filtros e empilham conteúdos. Não houve overflow global; a tabela tem área própria de rolagem, que deve continuar acessível por teclado.

Comparação: a tela atual exibiu publicação anterior/atual, +1 classificado, BRL sem mudança e +US$16.131,63. Isso corresponde ao exemplo do README. Operação abriu como snapshot, sem declarar CDC executado. QEX-02 trata a recuperação da consulta local; preservar o resultado anterior e deixar o aviso junto do horário, com botão Tentar novamente de no mínimo 40 px de altura.

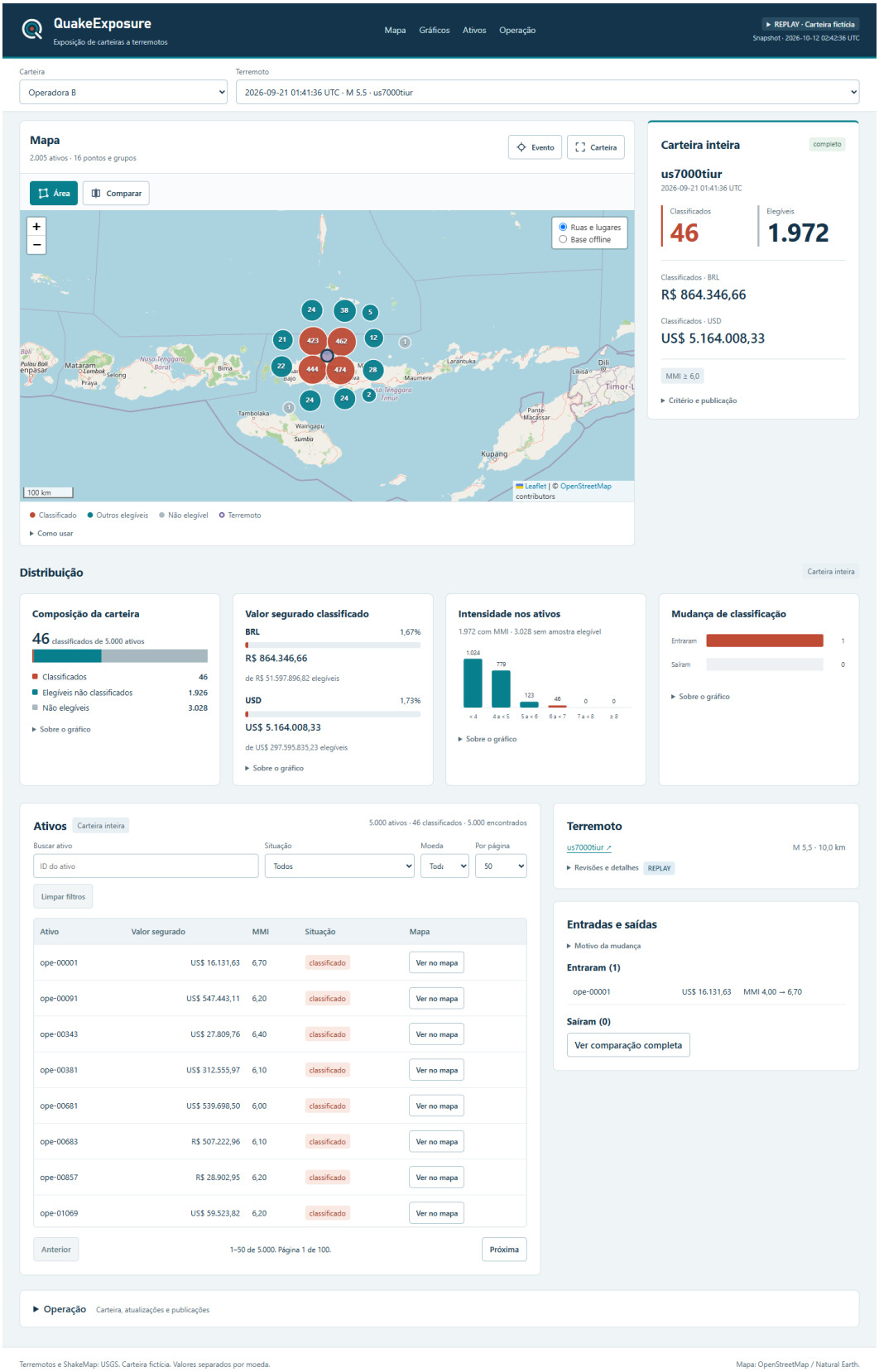
Não há evidência suficiente para recomendar outra paleta, dashboard novo ou troca de biblioteca. Capturas atuais: `_auditoria_2026-10-13/quake-exposure-1440.png`, `quake-exposure-768.png`, `quake-exposure-390.png`, `quake-exposure-320.png`, `quake-comparison.png` e `quake-operations.png`. Desenho por teclado recebeu inspeção de código, mas o roteiro executado não concluiu seleção válida; precisa de verificação adicional.

Capturas reais da auditoria

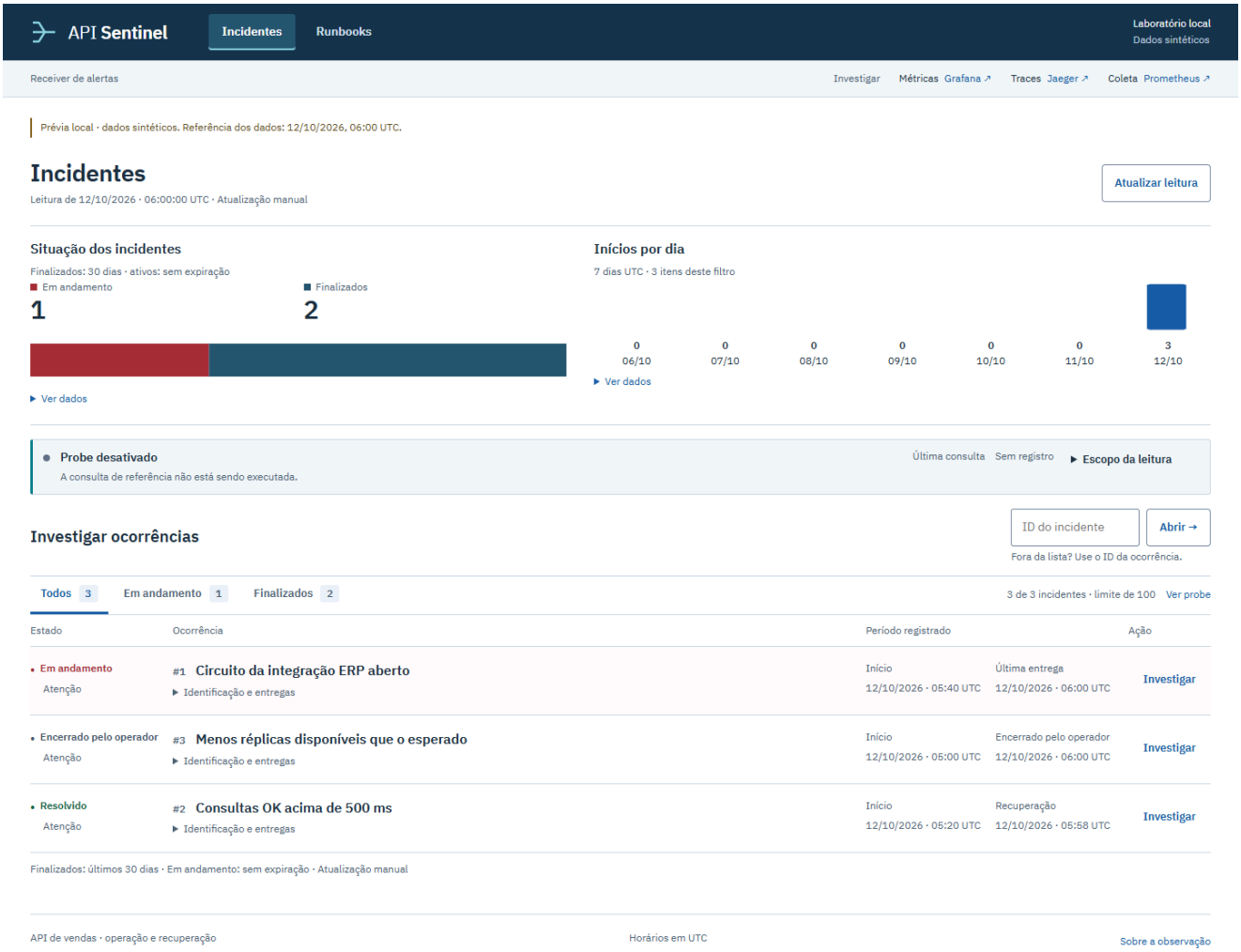
Imagens de apoio; abrir os arquivos originais para examinar pixels e detalhes. O documento não contém mockups ou telas inventadas.



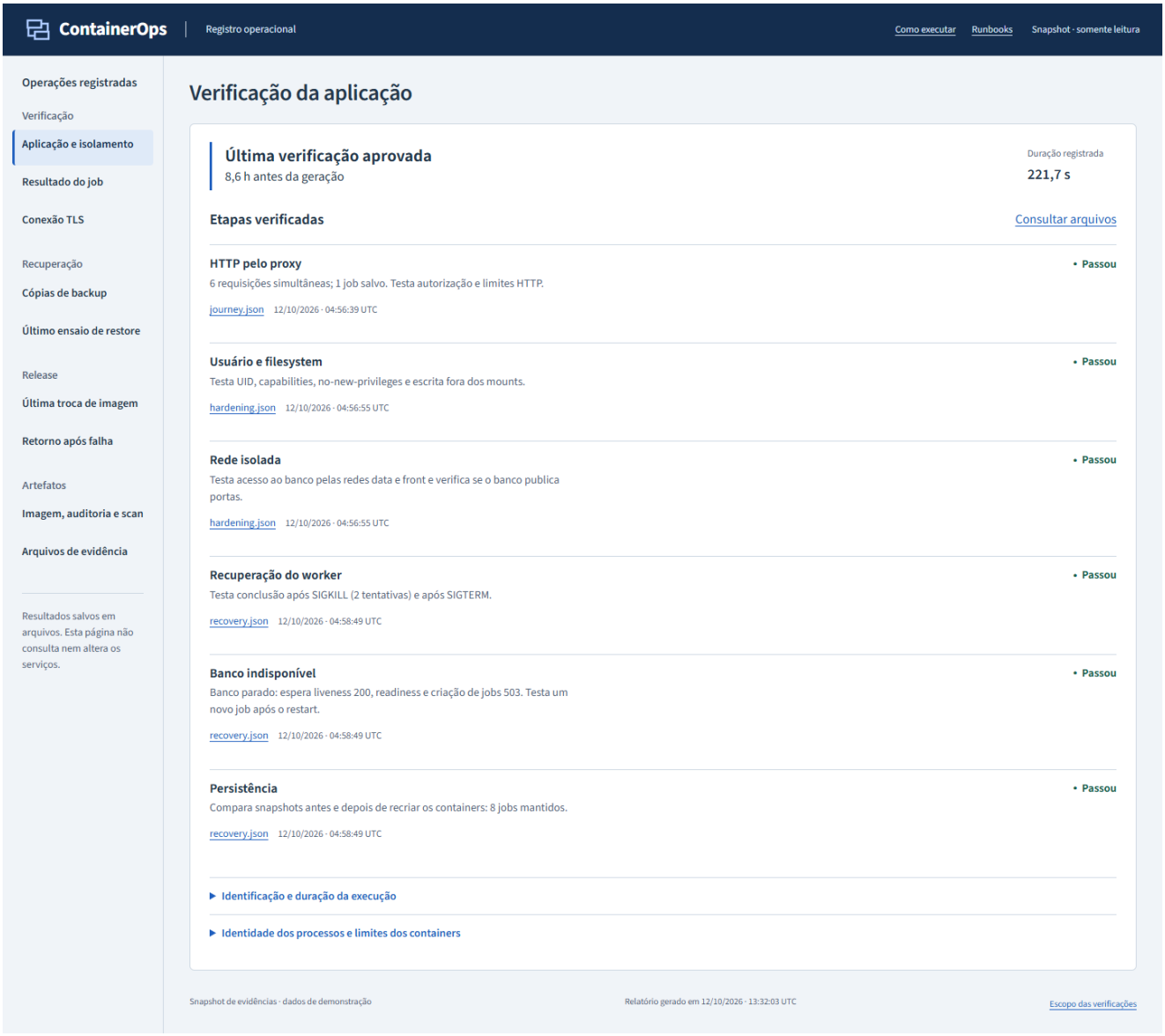
CycleOps, demo pública em 1440 px.



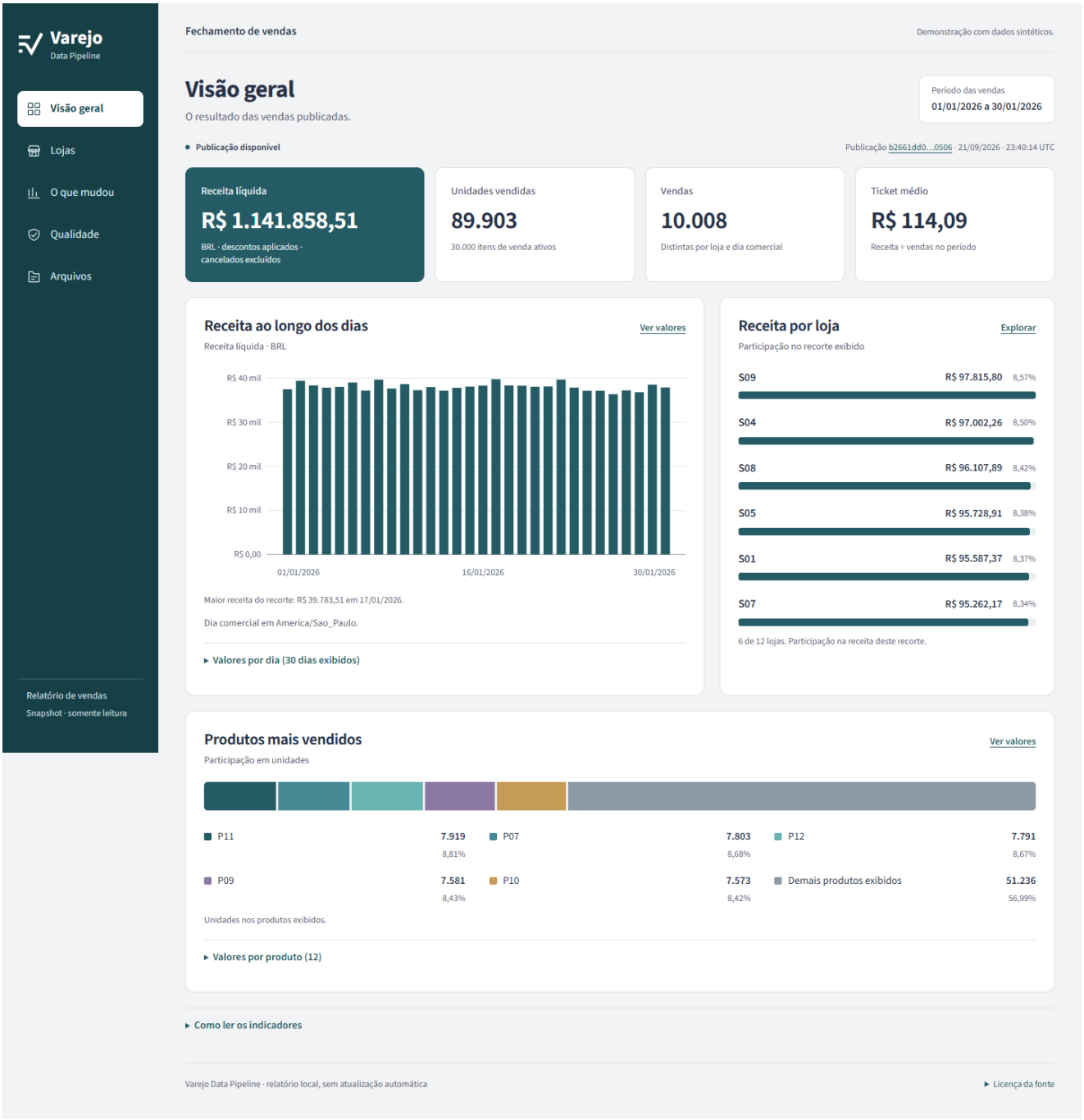
QuakeExposure, demo pública em 1440 px.



API Sentinel, fixture atual em 1440 px.



ContainerOps, snapshot servido em 1440 px.



Varejo, snapshot sintético pelo renderer atual em 1440 px.

Parte 5 - Plano de correção consolidado

Os 47 IDs estão reunidos abaixo: 38 originais e nove complementares. A prioridade conserva a avaliação inicial (24 P1, 23 P2); ela não é um novo score após correção. O diagnóstico detalhado continua nos links dos IDs. Cada linha também aponta ao recibo de correção. O registro de revalidação explica os ajustes posteriores de EVD-02/EVD-05 e as ressalvas.

Ordem: consistência e barreiras de segurança; recuperação e navegação; apresentação e manutenção. Dependências de schema, API, interface e teste devem ser aplicadas no mesmo fluxo.

ID / rodada	Repositório	Problema e recibo	Categoria	Prioridade	Esforço	Arquivo
LOJ-07 · complemento	loja-assistente	Login permite concorrência de Argon2 incompatível com o limite de memória do contêiner (recibo)	Autenticação e disponibilidade	P1	médio; estimativa: 0,5-1 dia	backend/src/loja_assistente/auth/service.py:18; backend/src/loja_assistente/auth/routes.py:68-70; backend/src/loja_assistente/database.py:13-24; backend/src/loja_assistente/auth/admission.py:16-18; compose.yaml:46
OPS-05 · complemento	containerops	Importação interrompida após publicar o pacote perde as marcas de origem externa e proteção (recibo)	Segurança, backup e recuperação de falhas	P1	médio	scripts/ops.py:1422-1431; scripts/backup_package.py:661-687; scripts/backup_catalog.py:350-360,415-425; scripts/ops.py:760-766
QEX-04 · complemento	quake-exposure	Blob armazenado é reutilizado sem conferir a identidade SHA-256 (recibo)	Integridade de armazenamento e recuperação	P1	médio	src/quakeexposure/ingestion/blobs.py:13-31; ingestion/projection.py:117; exposure/worker.py:184-189
PER-01 · original	arthurjoanes	Perfil omite os dois projetos que podem ser avaliados diretamente no navegador (recibo)	Clareza do propósito e apresentação	P1	baixo	README.md:19-45; README.en.md:19-45
EVD-01 · original	evidencedesk	Revisão devolvida oferece um envio que o servidor sempre recusa (recibo)	UI/UX e fluxo de negócio	P1	baixo (1 a 3 horas)	frontend/src/features/dossiers/dossier-view.tsx:370; backend/src/evidencedesk/reviews/service.py:300
EVD-02 · original	evidencedesk	Exportação expirada quebra o schema e a mesma tela não cria uma nova tentativa após falha (recibo)	Contratos de API, confiabilidade e UI/UX	P1	médio (0,5 a 1 dia)	backend/src/evidencedesk/reviews/routes.py:218; frontend/src/lib/contracts.ts:364; frontend/src/features/dossiers/dossier-view.tsx:194 e :238
EVD-03 · original	evidencedesk	Criação inicial de importação não pode ser repetida com segurança após resposta perdida (recibo)	Confiabilidade e recursos	P1	médio (1 a 2 dias)	frontend/src/features/imports/new-import.tsx:56; backend/src/evidencedesk/ingestion/routes.py:27; backend/src/evidencedesk/ingestion/service.py:69

ID / rodada	Repositório	Problema e recibo	Categoria	Prioridade	Esforço	Arquivo
EVD-04 · original	evidencedesk	Recortes antigos ficam inacessíveis no seletor quando há mais de 50 snapshots (recibo)	UI/UX e contrato de dados	P1	médio (1 dia)	backend/src/evidencedesk/incidents/service.py:237; frontend/src/lib/contracts.ts:96; frontend/src/features/incidents/incident-workspace.tsx:408
EVD-05 · original	evidencedesk	Erros nas listas de lacunas não identificam qual campo ou alegação precisa de ajuste (recibo)	Acessibilidade e usabilidade de formulários	P1	médio (0,5 a 1 dia)	frontend/src/features/dossiers/dossier-editor.tsx:252, :498 e :595; frontend/src/lib/form-errors.ts:1
LOJ-01 · original	loja-assistente	Reenvio de pergunta após resposta perdida pode criar outro resultado e outra chamada paga (recibo)	Confiabilidade e uso de recursos	P1	médio (1 a 2 dias)	frontend/src/features/assistant/use-workspace.ts:348 e :398; backend/src/loja_assistente/assistant/service.py:66 e :154
LOJ-02 · original	loja-assistente	Falha de favoritos impede carregar histórico e restaurar esclarecimento pendente (recibo)	UI/UX e tolerância a falhas	P1	médio (0,5 a 1 dia)	frontend/src/features/assistant/use-workspace.ts:104 e :111; frontend/src/features/assistant/workspace.tsx:148
LOJ-03 · original	loja-assistente	Limites de 50 conversas e 100 respostas são silenciosos na experiência de histórico (recibo)	UI/UX e acesso ao histórico	P1	médio (1 a 2 dias)	backend/src/loja_assistente/conversations/routes.py: 41 e :103; frontend/src/features/assistant/analysis-sidebar.tsx
API-01 · original	api-sentinel	A retenção permite reutilizar o número público de uma ocorrência (recibo)	Segurança e confiabilidade	P1	médio	alert_receiver/storage.py:37, persist:74 e prune:280; /incidents/{incident_id}
API-02 · original	api-sentinel	Não há como descobrir ocorrências além das 100 linhas sem conhecer seu ID (recibo)	UI/UX	P1	médio	alert_receiver/storage.py:155; alert_receiver/ui.py:60,293; alert_receiver/app.py /api/incidents
REC-01 · original	gestao-recebiveis	A navegação financeira não pode ser retomada pelo endereço do navegador (recibo)	UI/UX e navegação	P1	médio (1-2 dias)	frontend/src/features/workspace.tsx:38; frontend/src /components/workspace-navigation.tsx:42
REC-02 · original	gestao-recebiveis	Os filtros oferecem combinações que a própria API rejeita (recibo)	UI/UX e validação	P1	médio (/médio: 0,5 dia)	frontend/src/features/receivables.tsx:153; backend/src/gestao_recebiveis/reporting.py:69
VDP-01 · original	varejo-data-pipeline	A restauração pode trocar a tentativa apresentada como mais recente (recibo)	Consistência e recuperação	P1	médio (0,5-1 dia)	src/retail_pipeline/reporting.py:24; scripts/proof_contracts.py:146
VDP-02 · original	varejo-data-pipeline	O HTML servido é sobrescrito diretamente, sem publicação atômica (recibo)	Confiabilidade da interface	P1	médio (0,5-1 dia)	src/retail_pipeline/reporting.py:138; src/retail_pipeline/report_server.py:89

ID / rodada	Repositório	Problema e recibo	Categoria	Prioridade	Esforço	Arquivo
VDP-03 · original	varejo-data-pipeline	A verificação de navegador depende de ferramentas externas sem lock próprio (recibo)	Reprodutibilidade e testes de UI	P1	médio (1 dia)	docs/frontend-quality.md:29; scripts/dashboard-review.cjs:12; .github/workflows/ci.yml:15
OPS-02 · original	containerops	Guias copiados para a sessão conservam links relativos para arquivos ausentes (recibo)	Documentação / UX	P1	médio	scripts/report.py:415-458, guide_urls; docs/report-guide.md → Gerar um relatório
CYC-01 · original	cycleops	Catálogo e eventos do replay não têm seus hashes conferidos (recibo)	Segurança e confiabilidade	P1	médio	apps/web/src/streams/artifact.ts:72-124; manifesto catalogSha256/eventsSha256
CYC-02 · original	cycleops	Abas Lista/Mapa anunciam um padrão de teclado que não implementam (recibo)	UI/UX e acessibilidade	P1	baixo	apps/web/src/app/App.tsx:187-203
QEX-01 · original	quake-exposure	Parser confere apenas os cantos do grid e aceita células intermediárias fora de ordem (recibo)	Código e confiabilidade	P1	médio	src/quakeexposure/domain/grid.py:96-115; Grid.mmi_at:34-40
QEX-02 · original	quake-exposure	Consulta pendurada impede o próximo ciclo automático de atualização (recibo)	UI/UX e confiabilidade	P1	médio	web/src/api.ts:126-136; web/src/main.ts:624-628
EVD-06 · original	evidencedesk	Resumo atribui toda avaliação inconclusiva à falta de cobertura (recibo)	Clareza analítica e UI/UX	P2	baixo (até 1 hora)	frontend/src/features/dossiers/dossier-view.tsx:316; backend/src/evidencedesk/reconciliation/rules.py:113 e :214
EVD-07 · co mplemento	evidencedesk	Erros rejeitados pelo limite de corpo apresentam dois IDs de rastreamento (recibo)	Observabilidade e contrato de erro	P2	baixo; estimativa: 1-2 horas	backend/src/evidencedesk/body_limit.py:28-43; backend/src/evidencedesk/app.py:73,107-112
LOJ-04 · original	loja-assistente	Filtro pede ao lojista que raciocine sobre uma data final excluída (recibo)	UI/UX e linguagem do domínio	P2	baixo (2 a 4 horas)	frontend/src/features/assistant/analysis-filters.tsx:130; frontend/src/features/assistant/period-selection.ts
LOJ-05 · original	loja-assistente	Histórico e resposta mostram o mesmo horário em fusos diferentes (recibo)	Consistência de UI/UX	P2	baixo (1 a 2 horas)	frontend/src/features/assistant/analysis-sidebar.tsx:170; frontend/src/features/analytics/result.tsx:49
LOJ-06 · original	loja-assistente	Resultados de várias rodadas competem pela leitura rápida no README (recibo)	Documentação e apresentação profissional	P2	baixo (1 a 2 horas)	README.md:55, :57 e :156

ID / rodada	Repositório	Problema e recibo	Categoria	Prioridade	Esforço	Arquivo
LOJ-08 · complemento	loja-assistente	Erro de configuração pode incluir partes de valores sensíveis no diagnóstico de inicialização (recibo)	Privacidade e configuração	P2	baixo; estimativa: 1-3 horas para ocultar entradas e cobrir o erro; até 0,5 dia com migração dos consumidores para SecretStr	backend/src/loja_assistente/config.py:11,13,17,21,55-67
API-03 · original	api-sentinel	O exportador de prévias não copia fontes, marca e favicon usados nas páginas (recibo)	Testes e execução / UI/UX	P2	baixo	scripts/render_ui_preview.py:181; alert_receiver/ui.py:107; alert_receiver/styles.css:1
API-04 · original	api-sentinel	O roteiro Linux exige PowerShell no primeiro exemplo autenticado (recibo)	Documentação / Developer Experience	P2	baixo	docs/demo.md:117-154
API-05 · original	api-sentinel	Um teste de arquivo privado mistura UTF-8 e permissões POSIX sem restringir plataforma (recibo)	Testes e execução	P2	baixo	tests/unit/test_data_private_file.py:14-18
REC-03 · original	gestao-recebiveis	Regras posteriores anulam o layout de filtros previsto para tablet (recibo)	UI/UX e CSS responsivo	P2	baixo (0,5 dia)	frontend/src/app/financial-workspace.css:115,571,963
REC-04 · original	gestao-recebiveis	A página de títulos carrega todo o histórico de parcelas de cada item (recibo)	Eficiência e contrato de API	P2	médio (1-2 dias)	backend/src/gestao_recebiveis/reporting.py:119; backend/src/gestao_recebiveis/responses.py:52; backend/src/gestao_recebiveis/views.py:57
REC-05 · original	gestao-recebiveis	O teste de acessibilidade usa axe-core sem declarar a dependência direta (recibo)	Reprodutibilidade de testes	P2	baixo (menos de 1 hora)	frontend/tests/uiux-accessibility.spec.ts:4; frontend/package.json:21
REC-06 · original	gestao-recebiveis	Alguns resumos mostram códigos de faixa e contagem sem concordância (recibo)	Texto de interface	P2	baixo (menos de 1 hora)	frontend/src/features/receivables.tsx:112; frontend/src/features/reports.tsx:372
REC-07 · complemento	gestao-recebiveis	O roteiro de atualização descreve a migração atual como apenas aditiva (recibo)	Documentação operacional e migrações	P2	baixo; estimativa: Pequeno: 1-2 horas	docs/security.md:32; backend/migrations/versions/e71c2f_partial_payments.py:14
REC-08 · complemento	gestao-recebiveis	Campos textuais JSON aceitam NUL que a persistência não representa (recibo)	Validação de entrada e confiabilidade da API	P2	médio; estimativa: Pequeno/médio: 0,5 dia	backend/src/gestao_recebiveis/schemas.py:19; backend/src/gestao_recebiveis/auth.py:64; backend/src/gestao_recebiveis/app.py:79
VDP-04 · original	varejo-data-pipeline	Um caso parametrizado de 1 MiB impede a execução do teste no Windows (recibo)	Experiência de desenvolvimento	P2	baixo (menos de 1 hora)	tests/unit/test_rebuilt_jars.py:115

ID / rodada	Repositório	Problema e recibo	Categoria	Prioridade	Esforço	Arquivo
OPS-01 · original	containerops	A tabela de recursos arredonda quotas de CPU para valores diferentes da configuração (recibo)	UI/UX / comunicação técnica	P2	baixo	scripts/report.py:32-42 e 144-172; docs/examples/report.html, painel Verificação → identidade dos processos
OPS-03 · original	containerops	Comandos copiáveis do catálogo atendem só ao shell PowerShell (recibo)	Documentação / Developer Experience	P2	baixo	scripts/report.py:241-246 e 320-324; catálogo Cópias de backup
OPS-04 · original	containerops	O CSS mantém declarações de espaçamento e borda anuladas no mesmo bloco (recibo)	Código e manutenibilidade / artefatos de edição	P2	baixo	scripts/report.css:51,53,110,116,157
CYC-03 · original	cycleops	Guia chama de pura uma função que modifica o estado recebido (recibo)	Documentação	P2	baixo	CONTRIBUTING.md:10; apps/backend/src/cycleops/domain/engine.py:1-6, 70-82
CYC-04 · complemento	cycleops	Configuração aceita quota não finita e desativa a suspensão por tamanho (recibo)	Configuração e limites de recursos	P2	baixo	apps/backend/src/cycleops/worker/main.py:95-99; worker/processor.py:119-135
CYC-05 · complemento	cycleops	Documentação apresenta a limpeza do arquivo bruto como teto rígido de armazenamento (recibo)	Documentação operacional e retenção	P2	baixo	SECURITY.md:11; apps/backend/src/cycleops/worker/archive.py:1-2,51-60,67-79,98
QEX-03 · original	quake-exposure	User-Agent anuncia versão diferente da versão do pacote (recibo)	Código e documentação	P2	baixo	src/quakeexposure/ingestion/http.py:37,107; pyproject.toml:3

A execução local foi autorizada após a auditoria. Esta tabela preserva o plano e não substitui os resultados de validação nem a ressalva adicional de dependência de desenvolvimento.

Parte 6 - Checklist prático de implementação

arthurjoanes

• [ ] **PER-01 (P1)** - Acrescentar um bloco curto de demos com links de código e execução; ajustar a frase sobre dados sintéticos para reconhecer fontes abertas reais. Arquivo inicial: `README.md`.

• [ ] **Validar PER-01** - Abrir os dois links em janela anônima, sem credenciais; conseguir acessar demo e código a partir do perfil. Conferir que a frase sobre origem dos dados é verdadeira em ambos os idiomas.

evidencedesk

• [ ] **EVD-01 (P1)** - Exibir envio somente no rascunho e destacar a criação de nova revisão quando houver changes_requested. Arquivo inicial: `frontend/src/features/dossiers/dossier-view.tsx`.

• [ ] **Validar EVD-01** - Criar revisão, submeter e devolver com alterações. Confirmar ausência de envio direto no estado devolvido, motivo visível e nova revisão editável; salvar e enviar a nova versão com sucesso. Requisição direta de submissão da antiga deve continuar retornando 409.

• [ ] **EVD-02 (P1)** - Definir estado de exportação que inclua expired e criar uma ação explícita para nova exportação em estados terminais. Arquivo inicial: `frontend/src/lib/contracts.ts`.

• [ ] **Validar EVD-02** - Aceitar payload expired no teste de schema; testar falha, cancelamento e expiração sem spinner infinito. Repetir a mesma intenção deve retornar o mesmo recurso; iniciar nova exportação após término deve retornar ID novo. Simular perda da resposta inicial e comprovar que a recuperação não duplica job.

• [ ] **EVD-03 (P1)** - Adicionar idempotência à admissão do lote e preservar a chave antes de começar a chamada. Arquivo inicial: `backend/src/evidencedesk/ingestion/routes.py`.

• [ ] **Validar EVD-03** - Teste de integração simula commit seguido de resposta perdida, repete POST com mesma chave e confere mesmo batch_id, uma reserva e um conjunto de arquivos. Corpo diferente com mesma chave deve falhar. Teste da UI deve retomar o lote sem duplicá-lo.

• [ ] **EVD-04 (P1)** - Propagar a flag e oferecer navegação paginada pelos snapshots autorizados. Arquivo inicial: `frontend/src/lib/contracts.ts`.

• [ ] **Validar EVD-04** - Com mais de 50 snapshots autorizados, a indicação aparece e um recorte antigo pode ser carregado e selecionado. Alterar autorização não deve permitir recuperar snapshots proibidos por cursor ou URL.

• [ ] **EVD-05 (P1)** - Associar erro a cada textarea e manter campo/índice na lista de erros. Arquivo inicial: `frontend/src/features/dossiers/dossier-editor.tsx`.

• [ ] **Validar EVD-05** - Inserir 21 linhas ou 1.001 caracteres em cada lista, incluindo segunda alegação. Verificar mensagem específica, associação acessível, foco e persistência do rascunho. Não basta testar a função que deduplica strings.

• [ ] **EVD-06 (P2)** - Nomear o agregado “avaliações inconclusivas” e encaminhar aos motivos individuais. Arquivo inicial: `frontend/src/features/dossiers/dossier-view.tsx`.

• [ ] **Validar EVD-06** - Usar fixture com cobertura suficiente e eventos de mesma identidade conflitantes; o resumo não deve dizer que falta cobertura, e a regra detalhada deve mostrar conflito de identidade.

gestao-recebiveis

• [ ] **REC-01 (P1)** - Dar endereço às áreas e detalhes e serializar filtros de consulta na URL. Arquivo inicial: `frontend/src/app/page.tsx`.

• [ ] **Validar REC-01** - Abrir título a partir de filtro, copiar URL, recarregar, usar Voltar/Avançar e abrir em nova aba; exigir contexto equivalente após autenticação e ausência de submissão financeira involuntária.

• [ ] **REC-02 (P1)** - Explicitar que aging consulta saldo aberto e impedir a combinação inválida antes da requisição. Arquivo inicial: `frontend/src/features/receivables.tsx`.

• [ ] **Validar REC-02** - Cobrir cada situação com e sem faixa, especialmente Vencidos+1-30 e Pagos+faixa; nenhuma combinação oferecida como válida deve terminar em 422 inesperado.

• [ ] **REC-03 (P2)** - Consolidar as regras responsivas após a base, em ordem consistente, e remover declarações contraditórias. Arquivo inicial: `frontend/src/app/financial-workspace.css`.

• [ ] **Validar REC-03** - Verificar computedStyle em 900, 901, 1024, 1100 e 1101 px; em 1024 exigir uma coluna externa e filtros em duas. Conferir foco, números, ações e abertura/fechamento dos filtros em cada modo.

• [ ] **REC-04 (P2)** - Separar o resumo de título do detalhe e limitar historicos de longa duração. Arquivo inicial: `backend/src/gestao_recebiveis/reporting.py`.

• [ ] **Validar REC-04** - Criar títulos com centenas de parcelas e verificar que o payload da lista não cresce com o histórico, mantendo os mesmos saldos. Na paginação do detalhe, conferir ausência de perdas/duplicações e total igual ao agregado.

• [ ] **REC-05 (P2)** - Declarar axe-core como devDependency e resolver o arquivo pela resolução de módulos. Arquivo inicial: `frontend/package.json`.

• [ ] **Validar REC-05** - Executar npm ci e o teste em instalação limpa e comprovar que remover a dependência transitiva de ESLint não afeta a resolução do scanner.

• [ ] **REC-06 (P2)** - Reutilizar rótulos de faixa e formatar contagens no singular/plural. Arquivo inicial: `frontend/src/features/receivables.tsx`.

• [ ] **Validar REC-06** - Conferir as cinco faixas no resumo e contagens 0, 1 e 2 nos cards e extrato; nenhum enum com underscore deve aparecer como rótulo.

loja-assistente

• [ ] **LOJ-01 (P1)** - Dar à intenção de consulta uma identidade recuperável e tratar transporte incerto antes de permitir repetição. Arquivo inicial: `frontend/src/features/assistant/use-workspace.ts`.

• [ ] **Validar LOJ-01** - Simular resposta perdida após commit. Repetir mesma chave deve produzir uma resposta e uma chamada ao provider; corpo diferente com mesma chave deve retornar 409. Nova chave deve ser nova intenção explícita. Estado incerto do provider não pode ser convertido em retry pago automático.

• [ ] **LOJ-02 (P1)** - Carregar histórico e favoritos de modo independente, com estados e recuperação separados. Arquivo inicial: `frontend/src/features/assistant/use-workspace.ts`.

• [ ] **Validar LOJ-02** - Com sessão válida, histórico existente e pending, responder 503 somente a /favorites: histórico e pending devem aparecer; favoritos devem exibir erro próprio. Falha somente em /conversations não pode virar “Nenhuma conversa”. 401/403 continuam limpando o estado protegido.

• [ ] **LOJ-03 (P1)** - Explicitar a amostra e fornecer paginação estável de conversas e respostas autorizadas. Arquivo inicial: `backend/src/loja_assistente/conversations/routes.py`.

• [ ] **Validar LOJ-03** - Fixtures com 51 conversas e 101 respostas devem permitir acessar os itens mais antigos ou, na correção inicial, indicar a limitação. Paginar com datas iguais não deve repetir/pular itens. Revogação de loja não pode expor conversa nem contagem proibida.

• [ ] **LOJ-04 (P2)** - Editar datas inicial/final incluídas na UI e converter a data final para o limite exclusivo da API. Arquivo inicial: `frontend/src/features/assistant/analysis-filters.tsx`.

• [ ] **Validar LOJ-04** - Selecionar início=fim visível deve representar um dia; testar virada de mês/ano, ano bissexto e 90 dias. O período exibido após executar deve ser idêntico ao escolhido, sem depender do fuso do navegador.

• [ ] **LOJ-05 (P2)** - Adotar uma única política explícita para timestamps apresentados. Arquivo inicial: `frontend/src/features/assistant/analysis-sidebar.tsx`.

• [ ] **Validar LOJ-05** - Renderizar o mesmo instante com navegador em UTC, America/Los_Angeles e America/Sao_Paulo; sidebar e resultado devem concordar. Incluir instante próximo à troca de data.

• [ ] **LOJ-06 (P2)** - Manter uma rodada principal com data/escopo e uma tabela curta das anteriores; centralizar detalhes no guia de verificação. Arquivo inicial: `README.md`.

• [ ] **Validar LOJ-06** - A primeira leitura deve identificar a rodada principal, distinguir testes de domínio/avaliação/navegador e alcançar os recibos em um clique. Conferir datas/contagens contra cada recibo e rodar os verificadores offline existentes.

varejo-data-pipeline

• [ ] **VDP-01 (P1)** - Ordenar tentativas por um campo temporal persistido e validado ou uma sequência durável; definir desempate estável. Arquivo inicial: `src/retail_pipeline/reporting.py`.

• [ ] **Validar VDP-01** - Criar tentativas cujos IDs ordenem ao contrário da cronologia, copiar/restaurar com make_archive/restore_archive e exigir igualdade de latest e last_failed antes/depois; incluir empate e registro inválido.

• [ ] **VDP-02 (P1)** - Gravar a exportação completa em arquivo temporário na mesma pasta e substituir o destino somente ao terminar. Arquivo inicial: `src/retail_pipeline/reporting.py`.

• [ ] **Validar VDP-02** - Forçar erro antes da substituição e verificar preservação byte a byte do relatório anterior; servir durante sucessivas exportações e aceitar apenas documentos completos da versão anterior ou da nova.

• [ ] **VDP-03 (P1)** - Versionar as dependências do harness e dar um comando completo de instalação/execução; incluir uma amostra representativa em CI. Arquivo inicial: `docs/frontend-quality.md`.

• [ ] **Validar VDP-03** - Em checkout limpo, instalar pelo lock, renderizar corpus e executar amostra sem módulos globais; remover propositalmente um valor/controle e confirmar falha do gate.

• [ ] **VDP-04 (P2)** - Atribuir IDs curtos e estáveis aos dois parâmetros. Arquivo inicial: `tests/unit/test_rebuilt_jars.py`.

• [ ] **Validar VDP-04** - Executar os dois casos no Windows e no runtime Linux e confirmar nomes curtos no JUnit, mantendo a rejeição do provenance inválido.

api-sentinel

• [ ] **API-01 (P1)** - Adotar IDs monotônicos não reutilizáveis para novas inserções e migrar bases existentes preservando IDs e delivery_events. Não basta editar CREATE TABLE IF NOT EXISTS. Arquivo inicial: `alert_receiver/storage.py`.

• [ ] **Validar API-01** - Persistir A, guardar URL, expirar/apagar A, persistir B e provar que IDs diferem; URL antiga retorna 404. Repetir apagando só o maior ID. Migrar fixture com eventos e provar IDs, contadores e foreign_key_check preservados.

• [ ] **API-02 (P1)** - Adicionar paginação limitada à consulta e controles de navegação, preservando status e posição. Manter busca direta por ID como atalho. Arquivo inicial: `alert_receiver/storage.py`.

• [ ] **Validar API-02** - Com 205 ocorrências e ao menos 105 ativas, percorrer todas por teclado e mouse sem conhecer IDs; não omitir/duplicar registros em snapshot estável. Preservar filtro ao abrir detalhe e retornar. Rótulos e foco visíveis a 320 px.

• [ ] **API-03 (P2)** - Copiar o diretório de assets públicos junto da prévia e documentar que ela deve ser servida como raiz HTTP, já que o HTML usa caminhos absolutos. Arquivo inicial: `scripts/render_ui_preview.py`.

• [ ] **Validar API-03** - Gerar em diretório vazio, servir a saída na raiz loopback e confirmar HTTP 200 para os quatro assets citados; verificar `document.fonts.check('14px "IBM Plex Sans"')` e marca visível.

• [ ] **API-04 (P2)** - Adicionar exemplo Linux com Python padrão ou shell/curl que leia o token sem imprimi-lo. Manter o bloco PowerShell identificado. Arquivo inicial: `docs/demo.md`.

• [ ] **Validar API-04** - Em shell Linux com Python3 e stack preparada, copiar o bloco sem editar sintaxe, receber 12500/2/6250 e confirmar que o token não aparece na saída.

• [ ] **API-05 (P2)** - Usar encoding explícito e separar o teste de conteúdo do teste de modo POSIX, aplicando skip/condição somente à asserção de permissão. Arquivo inicial: `tests/unit/test_data_private_file.py`.

• [ ] **Validar API-05** - Teste de conteúdo passa com o encoding padrão do Windows e com UTF-8; teste POSIX continua exigindo 0600 no container Linux. Não mudar a promessa de plataforma da aplicação.

containerops

• [ ] **OPS-02 (P1)** - Reescrever no pacote os links para arquivos não copiados usando URLs do commit que originou o relatório, ou copiar dependências públicas necessárias preservando caminhos. Manter links entre Markdown que estão no pacote. Arquivo inicial: `scripts/report.py`.

• [ ] **Validar OPS-02** - Gerar bundle em diretório temporário e verificar cada link relativo de Markdown/HTML: deve existir dentro da pasta ou virar URL explícita do commit. Abrir o pacote sem o clone ao lado e conferir Como executar → Compose/Arquitetura.

• [ ] **OPS-01 (P2)** - Permitir precisão por campo ou usar formatador específico para quota de CPU; preservar duas casas nesse campo e rótulo claro de CPUs. Arquivo inicial: `scripts/report.py`.

• [ ] **Validar OPS-01** - Gerar tabela com 250000000, 500000000 e 750000000 nanocpus e verificar 0,25 / 0,5 / 0,75; comparar com o JSON de hardening e garantir que a tabela ainda cabe nas larguras suportadas.

• [ ] **OPS-03 (P2)** - Oferecer variantes Shell POSIX e PowerShell claramente identificadas. Não detectar o sistema do navegador como substituto do shell escolhido pelo usuário. Arquivo inicial: `scripts/report.py`.

• [ ] **Validar OPS-03** - Copiar variante POSIX para bash e PowerShell para pwsh usando ID fixture; confirmar argumento/ambiente sem executar restore real. Seleção do shell e feedback de cópia devem ser acessíveis pelo teclado.

• [ ] **OPS-04 (P2)** - Remover somente declarações comprovadamente anuladas e agrupar as regras base por componente, preservando media queries e exceções relevantes. Arquivo inicial: `scripts/report.css`.

• [ ] **Validar OPS-04** - Comparar screenshots e estilos computados antes/depois em 320/768/1440, com details aberto/fechado e impressão. A limpeza não deve alterar o resultado visual; não precisa criar testes que apenas espelhem cada declaração.

cycleops

• [ ] **CYC-01 (P1)** - Ler o catálogo como texto, conferir seu hash e o texto descomprimido dos eventos antes de JSON.parse/parseEvents. Usar a mesma codificação UTF-8 da geração Python. Manter a validação estrutural existente. Arquivo inicial: `apps/web/src/streams/artifact.ts`.

• [ ] **Validar CYC-01** - Alterar um nome e uma contagem sem violar os schemas: ambos devem gerar InvalidPayloadError. Arquivos originais devem carregar, com e sem Content-Encoding:gzip. Repetir a interceptação do recibo.

• [ ] **CYC-02 (P1)** - Como são duas opções simples de visualização, a correção menor é usar grupo de botões pressionáveis. Alternativamente implementar tabs completas com foco móvel e tabpanel. Arquivo inicial: `apps/web/src/app/App.tsx`.

• [ ] **Validar CYC-02** - Em 320 e 390 px, navegar somente com teclado e conferir nome, estado pressionado e foco visível; se mantiver tabs, ArrowRight/Left alternam o foco e existe somente uma entrada de Tab no grupo.

• [ ] **CYC-03 (P2)** - Corrigir a descrição do guia; não refatorar o motor só para satisfazer um adjetivo. Arquivo inicial: `CONTRIBUTING.md`.

• [ ] **Validar CYC-03** - Ler a assinatura e o contrato lado a lado. Um teste de identidade deve continuar mostrando que o retorno contém o mesmo objeto recebido, e o guia deve declarar isso.

quake-exposure

• [ ] **QEX-01 (P1)** - Validar a coordenada esperada de cada linha, incluindo normalização de longitude, antes de acrescentar MMI. Rejeitar a malha inconsistente com UnsupportedGrid. Arquivo inicial: `src/quakeexposure/domain/grid.py`.

• [ ] **Validar QEX-01** - Permutar duas linhas internas, repetir uma coordenada e deslocar uma coordenada interna: os três casos devem ser rejeitados. Reexecutar o oráculo das capturas reais e antimeridiano. Os valores originais devem permanecer idênticos.

• [ ] **QEX-02 (P1)** - Adicionar prazo explícito e cancelamento por mudança da seleção. Cobrir também leitura do corpo, além dos headers. Preservar o último resultado com horário e reutilizar o botão existente Tentar novamente quando o prazo expirar. Arquivo inicial: `web/src/api.ts`.

• [ ] **Validar QEX-02** - Em transporte simulado, manter headers/corpo pendentes além de 15 s. Esperar aborto e mensagem recuperável, permitir retry e próximo ciclo. Trocar evento durante uma consulta lenta e assegurar que o resultado anterior não reaparece. Não testar indisponibilidade contra USGS.

• [ ] **QEX-03 (P2)** - Derivar a versão da metadata instalada e testar o cabeçalho emitido. Arquivo inicial: `src/quakeexposure/ingestion/http.py`.

• [ ] **Validar QEX-03** - Capturar o header com MockTransport e comparar com importlib.metadata.version("quake-exposure"). Não é preciso chamar a fonte real.

delta

• [ ] Reconsultar o PR indicado nesta seção antes de apresentar seu status; usar o link do PR/branch para mostrar a correção enquanto a branch padrão mantém o exemplo anterior.

• [ ] Após integração upstream, sincronizar o fork e repetir a reprodução do exemplo. Nenhuma alteração adicional do diff é solicitada por esta auditoria.

fastapi-pagination

• [ ] Reconsultar o PR indicado nesta seção antes de apresentar seu status; usar o link do PR/branch para mostrar a correção enquanto a branch padrão mantém o exemplo anterior.

• [ ] Após integração upstream, sincronizar o fork e repetir a reprodução do exemplo. Nenhuma alteração adicional do diff é solicitada por esta auditoria.

Parte 7 - Parecer final

1. **Projetos mais fortes:** CycleOps e QuakeExposure combinam domínio não trivial, documentação e demonstração navegável. Varejo Data Pipeline, API Sentinel e ContainerOps oferecem evidências de processamento, resiliência e operação, com a ressalva de que parte da infraestrutura não foi reexecutada. As falhas de integridade identificadas devem acompanhar qualquer avaliação desses pontos fortes. No Varejo, VDP-01 altera o status apresentado; não foi demonstrada corrupção dos valores Delta. VDP-02 é uma corrida identificada por inspeção estática, sem reprodução durante regeneração concorrente.

2. **Projetos que prejudicam a apresentação:** nenhum precisa ser eliminado apenas pelo material visto. EvidenceDesk e Loja Assistente podem prejudicar uma demonstração se os estados de revisão/exportação e recuperação de operações forem exercitados sem corrigir os achados. Em Gestão de Recebíveis, uma combinação de filtros previsível pode falhar. O perfil dificulta descobrir as duas demos públicas.

3. **Primeira atenção:** corrigir os P1 que alteram resultado, identidade ou conclusão de tarefa. Em seguida, executar os roteiros de integração pendentes em Docker e preparar uma demonstração curta com falha e recuperação reais. Não reordenar a estética antes dos defeitos de fluxo.

4. **Redundância:** há tema comum de varejo e operação, mas os problemas resolvidos diferem. EvidenceDesk investiga incidentes; Recebíveis acompanha títulos; Loja interpreta consultas; Varejo publica dados. Um índice que explique essas diferenças vale mais que criar outro CRUD. Os forks devem aparecer como contribuições delimitadas.

5. **Engenharia além do básico:** sim, no código examinado há transações, leases, isolamento, idempotência, publicação e contratos. Essas evidências justificam discussão técnica; testes históricos ou grande volume de arquivos não comprovam uso em produção.

6. **Qualidade visual:** as cinco interfaces renderizadas são adequadas a demonstrações de projetos e mostram hierarquia e identidade consistentes. Há refinamentos de acessibilidade e interação, sem motivo demonstrado para substituir todos os layouts. Para vagas com responsabilidade forte de frontend, ainda falta validar sistematicamente leitores de tela, zoom, dispositivos reais e os fluxos autenticados atuais.

7. **Documentação urgente:** alinhar estados suportados e comportamento de erro às ações da UI; explicitar limites de descoberta de incidentes e de resultados truncados; reparar links dos bundles; completar receitas Linux; atualizar o perfil com as demos. Corrigir documentação não substitui a correção do comportamento.

8. **Competências destacadas:** Python/backend, integração de dados, regras de acesso, processamento assíncrono, consultas e publicação de resultados, testes de contratos e preocupação com recuperação. As contribuições pequenas mostram capacidade de reproduzir e corrigir exemplos defeituosos.

9. **Lacunas de evidência:** operação contínua com usuários reais, métricas de produto, pesquisa de usabilidade, impacto pessoal em sistemas de empregador, custos/sustentação em cloud, escala de produção e manutenção ao longo de meses. Também faltam as verificações técnicas listadas como não executadas. Ausência de evidência pública não significa ausência de experiência.

10. **Entrevista técnica:** o material justifica uma entrevista para discutir backend, dados e aplicações de negócio. A decisão não depende de atribuir uso de IA pelo estilo. O autor deve conseguir reproduzir uma falha, explicar seus invariantes e justificar as soluções simples escolhidas. O nível de contratação exige entrevista, histórico e exercícios proporcionais à vaga; não pode ser determinado apenas por este portfólio.

Fontes e critérios para IA, qualidade e acessibilidade

A pesquisa precedeu a classificação dos artefatos. A análise usa três classes: evidência explícita de ferramenta/processo; defeito objetivo verificável; suspeita estilística inconclusiva. Arquivos gerados por schema, fixtures rotuladas e instruções de contribuição não demonstram conteúdo sem revisão. Não foi aplicado detector de autoria nem percentual de texto produzido por IA.

- GitHub: uso responsável de sugestões do Copilot: revisão humana e testes continuam necessários porque sugestões podem estar incorretas ou inseguras. Isso orienta a comparação entre documentação e implementação, sem atribuir automaticamente cada defeito à ferramenta.
- Fu et al., Security Weaknesses of Copilot-Generated Code in GitHub Projects, versão de 2025: estudo empírico encontrou fraquezas em amostras de código gerado. A amostra não permite estimar a taxa de falhas deste portfólio nem dos modelos atuais; reforça a necessidade de investigar o código concreto.
- Sadasivan et al., Can AI-Generated Text be Reliably Detected?, versão de 2025: analisa limitações e fragilidade de detectores sob transformações do texto. Organização, vocabulário e fluência não bastam para comprovar autoria.
- Microsoft Learn: geração de documentação com Copilot: descreve geração de explicações, documentação e comentários. A existência dessas capacidades não demonstra que foram usadas nestes arquivos; aqui a qualidade foi confrontada com comandos e código.
- W3C APG: padrão de abas: referência para foco, teclas e associação entre abas e painéis de CYC-02.
- Web Interface Guidelines: lista auxiliar para semântica, foco, estados e layout. Preferências editoriais dessa lista não foram tratadas como falhas normativas por si só.

Ocorrências concretas de edição acumulada, nomenclatura desatualizada ou documentação inexata estão nos problemas correspondentes. Não há recomendação de apagar personalidade, mascarar uso de IA ou remover documentação útil por parecer organizada.

Fontes adicionais de api-sentinel: - SQLite: AUTOINCREMENT

Registro de cobertura e evidências

`_auditoria_2026-10-13/inventario_github.json` preserva os metadados da consulta pública. Os JSON de revisão (`root.json`, `apps.json`, `backend_ops.json`, `data_billing.json`) guardam os achados estruturados. `browser-initial.json`, `browser-checks.json`, `reports-browser.json`, `quake-grid-repro.json`, `forks-probe.json` e `varejo-restore-order-repro.json` registram verificações direcionadas. Não contêm credenciais de produção.

Repositório	Tipo	Branch pública padrão	Cobertura efetiva
api-sentinel	Projeto	main	Arquivos e verificações discriminados na Parte 2
arthurjoanes	Perfil	main	Arquivos e verificações discriminados na Parte 2
containerops	Projeto	main	Arquivos e verificações discriminados na Parte 2
cycleops	Projeto	main	Arquivos e verificações discriminados na Parte 2
delta	Fork	master	Diff autoral e exemplos afetados; upstream restante fora da revisão profunda
evidencedesk	Projeto	main	Arquivos e verificações discriminados na Parte 2
fastapi-pagination	Fork	main	Diff autoral e exemplos afetados; upstream restante fora da revisão profunda
gestao-recebiveis	Projeto	main	Arquivos e verificações discriminados na Parte 2
loja-assistente	Projeto	main	Arquivos e verificações discriminados na Parte 2
quake-exposure	Projeto	main	Arquivos e verificações discriminados na Parte 2
varejo-data-pipeline	Projeto	main	Arquivos e verificações discriminados na Parte 2

Para reproduzir achados, usar as versões identificadas, um runtime isolado e os passos Como validar. As correções aqui propostas não foram aplicadas nem passam a ser comportamento existente por constarem neste documento.

Parte 8 - Revisão complementar: segurança, operação e contratos

Rodada 2: 13 de outubro de 2026. Complemento solicitado após a primeira entrega. O inventário público foi consultado novamente e mantém os mesmos 11 repositórios. O relatório inicial foi preservado em `_auditoria_2026-10-13/baseline/`. Os IDs anteriores permanecem válidos.

Esta rodada acrescentou **9 achados**, sendo 0 P0, 3 P1 e 6 P2, chegando a **47 achados** (24 P1 e 23 P2). Na edição inicial, o plano estava dividido entre 38 itens e este complemento. Na edição revisada, a Parte 5 reúne os 47 IDs; esta Parte 8 preserva o diagnóstico, o recorte e a checklist da segunda rodada.

Objetivo e limites desta rodada

A revisão voltou aos projetos por outras frentes: configuração e segredos, concorrência e orçamento de recursos, autorização e isolamento, integridade de arquivos, privacidade e recuperação, observabilidade, migrações e entrega contínua. Os achados anteriores de UI e documentação não foram contados outra vez. O número de problemas novos não mede a profundidade de um repositório: quando uma hipótese já estava tratada, foi registrada como controle observado.

O Docker Linux continua indisponível. Provas novas usam funções reais com substituições delimitadas, arquivos temporários ou adaptação de dados, sem efetuar restauração real, provocar OOM, encher disco, chamar LLM pago ou gerar carga contra sistemas externos. Não há nova validação visual nesta rodada. Os estados do GitHub foram consultados em leitura; os repositórios originais não foram editados.

As notas da primeira rodada são avaliações por dimensão, não contagens de defeitos; não foram recalculadas mecanicamente. O novo problema de confiança em backup e os limites de concorrência entram na prioridade operacional junto dos P1 anteriores. Não foi feita varredura exaustiva de CVEs de todos os lockfiles/imagens nem certificação de privacidade.

Cobertura complementar por repositório

Repositório	Tópicos adicionais	Resultado
arthurjoanes	Proveniência e comunicação pública	Nenhum novo defeito confirmado nos caminhos revisitados
evidencedesk	Autorização e isolamento por tenant, Sessão, Origin e CSRF, Privacidade de erros, logs e telemetria, Limites de upload e interpretação, Retenção, limpeza e recuperação, Reserva de custo e liberação de modelos, CI, dependências e configuração	EVD-07
gestao-recebiveis	Transações, concorrência e idempotência financeira, Sessão, CSRF, papéis e admissão de login, Importação integral e validação de datas/dinheiro, Lease, fencing, envio incerto e conciliação de lembretes, Privilégios PostgreSQL e migração financeira, Backup isolado, privacidade de evidências e guards de limpeza, CI, containers, locks e contratos de adaptação de dados	REC-07, REC-08
loja-assistente	Autorização por tenant e loja, Sessão, Origin, CSRF e proxy, Privacidade de logs e erros de configuração, Orçamento de recursos de autenticação, Limites de corpo e de uso de LLM, Retenção e limpeza, CI, configuração e dependências	LOJ-07, LOJ-08
varejo-data-pipeline	Consistência entre versões Delta e ponto de publicação, Idempotência, revisões e conflitos de uma venda, Validação de dinheiro, timestamps, manifests e cópia física de entrada, Backup integral, verificação de hashes e retenção conservadora, Proveniência OpenLineage e reconstrução a partir de commits duráveis, CI, isolamento de containers e dependências JVM fixadas	Nenhum novo defeito confirmado nos caminhos revisitados
api-sentinel	Autenticação, autorização por organização/loja/escopo e identidade do cursor, Segredos, sanitização de logs e exceções, Destino ERP/probe e referências remotas da ferramenta de contratos, Limites de entrada, recepção do corpo e cancelamento, Migração inicial, emissão/revogação e papéis de banco, Docker/Compose, CI, dependências, scan e escopo de publicação	Nenhum novo defeito confirmado nos caminhos revisitados
containerops	Autorização por proprietário, limites HTTP e sanitização de logs, Segredos de operação, Compose e exposição de rede, Migrações expansivas, backup, restore e rollback, Integridade de pacote portátil, confiança na origem e recuperação de importação, Catálogo, retenção e journal, Arquivo de imagem OCI/Docker, supply chain, CI, scan e dependências	OPS-05
cycleops	Configuração e limites de recursos, Retenção de dados, Segurança de rede e logs, CI/CD	CYC-04, CYC-05

Repositório	Tópicos adicionais	Resultado
quake-exposure	Integridade de armazenamento, Privacidade, backup e restauração, Fronteira de rede, CI/CD e implantação	QEX-04
delta	Escopo autoral, integração e atribuição	Nenhum novo defeito confirmado nos caminhos revisitados
fastapi-pagination	Escopo autoral, integração e atribuição	Nenhum novo defeito confirmado nos caminhos revisitados

Novos achados por tema

Confiança de backups e proteção de segredos

PROBLEMA OPS-05 - Importação interrompida após publicar o pacote perde as marcas de origem externa e proteção

- **Repositório:** containerops.
- **Categoria:** Segurança, backup e recuperação de falhas.
- **Gravidade:** Média.
- **Localização:** scripts/ops.py:1422-1431; scripts/backup_package.py:661-687; scripts/backup_catalog.py:350-360,415-425; scripts/ops.py:760-766.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Importação interrompida após publicar o pacote perde as marcas de origem externa e proteção

Evidência:

execute_backups chama import_backup, que finaliza o diretório no destino, e só depois chama register_backup(imported=True, protected=True). Esses flags não estão duravelmente associados à publicação. A prova isolada simulou OSError no registro após a cópia/rename reais. discover reabriu o pacote como valid/imported=false/protected=false; restore_test sem --trusted-source atingiu o preflight. Ao registrar corretamente a mesma cópia, o controle foi recusado antes do preflight. Outra cópia posterior da mesma origem fez a órfã aparecer como candidata em plan_retention(keep_last=0). Recibo e script: _auditoria_2026-10-13/containerops-import-registration-repro.json e probe_import_registration.py.

Por que isso é um problema:

O fallback de compatibilidade para backups sem registro atribui imported=False/protected=False. Uma falha entre duas gravações independentes converte ausência de informação em confiança de origem local e ausência de proteção. A importação retorna erro, mas o comando seguinte ainda descobre e seleciona os bytes publicados.

Impacto:

Depois de falha de escrita/interrupção nessa janela, restore pode avançar sem o reconhecimento explícito de confiança exigido para pacotes importados; a cópia também pode entrar em plano de retenção. PostgreSQL alerta que restauração executa instruções escolhidas pela origem. O restore continua usando banco descartável e papéis/mounts definidos: não foi demonstrado escape de container, execução real de dump malicioso nem exclusão de backup.

Correção recomendada:

Fazer a classificação de origem e a proteção sobreviverem à interrupção entre a publicação do diretório e o catálogo. Enquanto um pacote importado não tiver registro concluído, tratá-lo conservadoramente como pendente/protegido e nunca presumir origem local. Recuperar o registro antes de liberar retenção e manter o reconhecimento explícito de confiança para restore.

Implementação sugerida:

Gravar um journal/intenção de importação no runtime, sob operation_lock, antes de publicar o diretório; incluir ID, hashes esperados e imported/protected=true. Após o rename, concluir o registro do catálogo e só então marcar a intenção como concluída. discover/select_backup devem reconhecer a intenção pendente e impedir que defaults imported=false/protected=false a substituam. Alternativa mais simples para o contrato atual: pacotes portáteis sem registro íntegro ficam desconhecidos ou exigem confiança/proteção por padrão até adoção explícita. Não inferir confiança de campos do manifesto recebido nem apenas do prefixo do nome. Preservar política explícita para backups legados sem manifesto e testar a recuperação.

Arquivos afetados: `scripts/ops.py`, `scripts/backup_package.py`, `scripts/backup_catalog.py`, `tests/test_backup_package.py`, `tests/test_backup_catalog.py`, `tests/test_operations.py`, `docs/security.md`, `docs/runbooks.md`.

Como validar: Injetar falha antes do rename, depois do rename/antes do catálogo e durante a gravação do catálogo. Reabrir o runtime em novo processo e provar que nenhum pacote importado fica imported=false/protected=false, que restore sem --trusted-source não passa ao preflight e que retenção não o seleciona. Reexecutar importação normal e recuperação para provar conclusão idempotente, proteção preservada, hashes intactos e compatibilidade com backups legados. Usar somente fixtures sintéticas, sem pg_restore real.

PROBLEMA LOJ-08 - Erro de configuração pode incluir partes de valores sensíveis no diagnóstico de inicialização

- **Repositório:** loja-assistente.
- **Categoria:** Privacidade e configuração.
- **Gravidade:** Baixa.
- **Localização:** backend/src/loja_assistente/config.py:11,13,17,21,55-67.
- **Esforço:** baixo; estimativa: 1-3 horas para ocultar entradas e cobrir o erro; até 0,5 dia com migração dos consumidores para SecretStr.
- **Prioridade:** P2.

Problema identificado:

Erro de configuração pode incluir partes de valores sensíveis no diagnóstico de inicialização

Evidência:

SettingsConfigDict não habilita hide_input_in_errors e database_url, session_secret e openai_api_key são strings comuns. O módulo instancia Settings() durante o import, antes dos handlers HTTP que sanitizam erros. Com _env_file=None, segredo de sessão sintético válido e COOKIE_SECURE=false fora de DEMO_MODE, str(ValidationError) incluiu input_value e o sufixo c-key-NOT-A-CREDENTIAL da chave sintética. A prova registrou synthetic_key_visible_in_str_exception=false e synthetic_key_suffix_visible=true: não houve exposição do marcador completo nem uso de credencial real.

Por que isso é um problema:

Os validadores corretamente impedem uma configuração insegura, mas a representação padrão da falha também pode reproduzir partes do dicionário de configuração. A sanitização de erros HTTP não cobre a construção de Settings no import.

Impacto:

Diagnósticos de startup coletados por terminal, CI ou plataforma de logs podem conter fragmentos de valores sensíveis quando a configuração falha. A reprodução demonstrou somente exposição parcial de marcador artificial; não demonstrou vazamento de uma chave utilizável, acesso público aos logs ou vazamento real no projeto.

Correção recomendada:

Ocultar valores de entrada nas mensagens de validação de Settings e modelar campos sensíveis com tipos que mascaram sua representação.

Implementação sugerida:

Adicionar hide_input_in_errors=True a SettingsConfigDict. Usar SecretStr para chave do provedor, segredo de sessão e URL com credenciais, adaptando os pontos de consumo para get_secret_value() somente onde necessário. Ocultar inputs continua necessário mesmo com SecretStr, pois a validação pode falhar sobre dados brutos. Manter mensagens com nome do campo e causa segura; não registrar model_dump() nem errors() com input incluído.

Arquivos afetados: `backend/src/loja_assistente/config.py`, `backend/tests/test_secure_config.py`, `backend/src/loja_assistente/database.py`, `backend/src/loja_assistente/auth/service.py`, `backend/src/loja_assistente/auth/admission.py`, `backend/src/loja_assistente/auth/routes.py`, `backend/src/loja_assistente/assistant/interpretation.py`.

Como validar: Criar testes com marcadores sintéticos distintos para cada campo sensível e configurações inválidas por cookie/endpoint. Assegurar que str(ValidationError) e um diagnóstico de startup controlado não contêm o marcador nem seus fragmentos identificáveis, e que a causa da rejeição continua compreensível. Após a migração para SecretStr, verificar os usos legítimos de conexão, HMAC, presença da chave e cliente do provedor sem chamada externa.

Concorrência e configuração de recursos

PROBLEMA LOJ-07 - Login permite concorrência de Argon2 incompatível com o limite de memória do contêiner

- **Repositório:** loja-assistente.
- **Categoria:** Autenticação e disponibilidade.
- **Gravidade:** Média.
- **Localização:** backend/src/loja_assistente/auth/service.py:18; backend/src/loja_assistente/auth/routes.py:68-70; backend/src/loja_assistente/database.py:13-24; backend/src/loja_assistente/auth/admission.py:16-18; compose.yaml:46.
- **Esforço:** médio; estimativa: 0,5-1 dia.
- **Prioridade:** P1.

Problema identificado:

Login permite concorrência de Argon2 incompatível com o limite de memória do contêiner

Evidência:

PasswordHasher() usa 65536 KiB por verificação no runtime inspecionado. O login faz SELECT e verifica a senha de forma síncrona antes de encerrar a Session, mantendo sua conexão. O engine permite 5 conexões mais 10 de overflow, e o runtime AnyIO disponibiliza 40 threads. A admissão limita 5 tentativas por conta e 30 por origem em 60 segundos, sem um semáforo global de verificações. Quinze identidades distintas cabem nesse allowance inicial. A prova isolada, com admissão e hasher substituídos, confirmou 15 chamadas simultaneamente no ponto de verificação; também verificou a retenção da conexão por Session após um SELECT em SQLite. Quinze verificações no custo configurado representam 960 MiB de memória Argon2, enquanto o backend declara mem_limit=768m.

Por que isso é um problema:

Controle de tentativas por janela não limita suficientemente o número de operações caras simultâneas. Os limites de banco/thread e a configuração do hash permitem um orçamento de trabalho maior que a memória total do serviço, antes de considerar Python, conexões e demais requisições.

Impacto:

Uma rajada de logins para contas distintas pode competir por memória, CPU e conexões, degradando o login e outras rotas. Sob pressão, pode haver falhas ou reinício do contêiner; isso é risco deduzido da configuração, não OOM observado. O Compose publica em loopback, a origem é validada e já há limites por conta/origem, o que restringe o contexto de exposição e reduz a severidade. Não foi alegado ataque remoto ao ambiente do usuário.

Correção recomendada:

Adicionar limite explícito de verificações de senha simultâneas, dimensionado com a memória do contêiner e o número de processos, mantendo a admissão durável já existente.

Implementação sugerida:

Adquirir um slot por processo antes do trabalho Argon2 e liberá-lo em finally; na falta de slot, retornar erro transitório controlado com Retry-After, sem fila ilimitada. Para o processo único atual, começar com um limite conservador como duas verificações e validar a margem de memória. Documentar processos × slots × memória por hash, incluindo o restante do serviço. Não reduzir os parâmetros de senha automaticamente para compensar a falta de controle de concorrência. Se a leitura do usuário for desacoplada da Session antes do hash, revalidar estado/permissões antes de criar a sessão autenticada.

Arquivos afetados: `backend/src/loja_assistente/auth/service.py`, `backend/src/loja_assistente/auth/routes.py`, `backend/src/loja_assistente/config.py`, `backend/tests/test_login_admission.py`, `compose.yaml`, `docs/security.md`.

Como validar: Com hasher barato bloqueável, disparar mais tentativas do que os slots e demonstrar que nunca há mais verificações ativas que o limite, que os excedentes recebem resposta transitória e que slots são liberados em sucesso e exceção. Preservar testes de admissão por conta/origem. Em ambiente descartável com Docker, medir posteriormente pico de memória e latência com o hash real e o número de workers previsto; não tratar a prova atual como esse ensaio.

PROBLEMA CYC-04 - Configuração aceita quota não finita e desativa a suspensão por tamanho

- **Repositório:** cycleops.
- **Categoria:** Configuração e limites de recursos.
- **Gravidade:** Baixa.
- **Localização:** apps/backend/src/cycleops/worker/main.py:95-99; worker/processor.py:119-135.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

Configuração aceita quota não finita e desativa a suspensão por tamanho

Evidência:

Settings converte a variável com float e rejeita apenas quota <= 0. No probe, NaN, inf e 1e999 foram aceitos; maintain com tamanho simulado de 2048 MiB manteve quota.exceeded=False. O controle 1024 ativou a suspensão.

Por que isso é um problema:

Comparar qualquer tamanho finito com NaN ou infinito positivo não detecta estouro. Uma configuração inválida passa pelo fail-fast, apesar da mensagem prometer valor acima de zero.

Impacto:

Erro de configuração pode remover o limite operacional sem aviso de configuração. Não há entrada remota para alterar essa variável e não foi observado disco cheio.

Correção recomendada:

Rejeitar números não finitos ao ler CYCLEOPS_DB_QUOTA_MB, mantendo o erro de configuração e o código de saída já existentes.

Implementação sugerida:

```
import math

if not math.isfinite(quota) or quota <= 0:
    raise ConfigError("CYCLEOPS_DB_QUOTA_MB must be finite and above 0")
```

Acrescentar NaN, inf, -inf e 1e999 aos casos de configuração recusada, com IDs curtos nos testes.

Arquivos afetados: `apps/backend/src/cycleops/worker/main.py`, `apps/backend/tests/test_worker_main.py`.

Como validar: As quatro entradas não finitas devem lançar ConfigError antes de abrir conexão. Valores positivos finitos, incluindo 0.5 e 1024, devem continuar aceitos; 0 e negativos recusados.

Integridade e validação na persistência

PROBLEMA QEX-04 - Blob armazenado é reutilizado sem conferir a identidade SHA-256

- **Repositório:** quake-exposure.
- **Categoria:** Integridade de armazenamento e recuperação.
- **Gravidade:** Média.
- **Localização:** src/quakeexposure/ingestion/blobs.py:13-31; ingestion/projection.py:117; exposure/worker.py:184-189.
- **Esforço:** médio.
- **Prioridade:** P1.

Problema identificado:

Blob armazenado é reutilizado sem conferir a identidade SHA-256

Evidência:

BlobStore.get apenas descomprime o arquivo; put retorna cedo se o caminho existir. A projeção e o cálculo não revalidam o hash antes de consumir os bytes. No probe, um gzip B válido no caminho identificado por A foi aceito, inclusive após novo put(A).

Por que isso é um problema:

CRC do gzip verifica o próprio gzip, não a correspondência entre conteúdo, nome SHA-256 e registro control.capture. Uma troca por outro arquivo válido pode conservar proveniência A para conteúdo B.

Impacto:

Após cópia/restauração incorreta ou adulteração local, projeções/cálculos podem consumir bytes diferentes da captura registrada. Corrupção aleatória que quebra gzip pode ser detectada; o caso demonstrado é gzip válido com conteúdo errado. Não foi demonstrado acesso remoto ao volume.

Correção recomendada:

Verificar SHA-256 dos bytes descomprimidos contra control.capture antes de projetar/calcular. Validar também o arquivo existente no caminho rápido de put e recusar divergência com erro operacional explícito.

Implementação sugerida:

```
class BlobIntegrityError(ValueError):
    pass

def get(self, rel: str, *, expected_sha256: str) -> bytes:
    body = gzip.decompress((self.root / rel).read_bytes())
    if hashlib.sha256(body).hexdigest() != expected_sha256:
        raise BlobIntegrityError("blob diverge da captura registrada")
    return body
```

Em project_capture, passar capture.sha256. Em _load_grid, selecionar blob_path e sha256 e passar ambos ao armazenamento. Em put, quando o caminho existe, conferir o conteúdo com o hash já calculado antes de retornar. Tratar divergência como inconsistência do arquivo e registrar identificadores, sem payload; preservar o arquivo suspeito para investigação e refazer a captura por procedimento explícito. Atualizar os call sites e testes da mudança de assinatura.

Arquivos afetados: `src/quakeexposure/ingestion/blobs.py`, `src/quakeexposure/ingestion/projection.py`, `src/quakeexposure/exposure/worker.py`, `tests/unit (novos testes de BlobStore)`, `tests/integration/test_collector.py`, `tests/integration/test_exposure.py`.

Como validar: Gravar A, substituir por gzip B válido e exigir BlobIntegrityError em get e put(A). Confirmar leitura/reutilização de A intacto. Cobrir gzip truncado separadamente. Provar que projeção/cálculo não avança com hash divergente; a integração em PostgreSQL deve ser executada quando Docker estiver disponível.

PROBLEMA REC-08 - Campos textuais JSON aceitam NUL que a persistência não representa

- **Repositório:** gestao-recebiveis.
- **Categoria:** Validação de entrada e confiabilidade da API.
- **Gravidade:** Média.
- **Localização:** backend/src/gestao_recebiveis/schemas.py:19; backend/src/gestao_recebiveis/auth.py:64; backend/src/gestao_recebiveis/app.py:79.
- **Esforço:** médio; estimativa: Pequeno/médio: 0,5 dia.
- **Prioridade:** P2.

Problema identificado:

Campos textuais JSON aceitam NUL que a persistência não representa

Evidência:

Probe puro com o Python 3.13.15, Pydantic 2.13.5 e Psycopg 3.3.6 do venv do projeto: PaymentInput aceitou NUL em note/idempotency_key, CancelInput em reason e LoginInput em email. StrDumper do Psycopg recusou os quatro valores com DataError: PostgreSQL text fields cannot contain NUL (0x00) bytes. Nota/chave/e-mail seguem para colunas ou consultas textuais; motivo também segue para AuditEvent.details JSONB. app.py trata IntegrityError, OperationalError e PoolTimeout, mas não essa entrada inválida. Recibo: _auditoria_2026-10-13/recebiveis-nul-boundary-probe.json.

Por que isso é um problema:

Os limites de tamanho e tipos não garantem representabilidade no banco. O CSV já rejeita NUL explicitamente, mas os modelos JSON e a pesquisa textual não compartilham esse contrato.

Impacto:

Uma requisição com esse caractere passa pela validação e pode terminar como erro interno em vez de 422 com identificação do campo. Não foi executado HTTP/PostgreSQL nesta prova e não se demonstrou alteração de saldo; a conclusão sobre 500 deriva do caminho de persistência e dos handlers existentes.

Correção recomendada:

Rejeitar NUL nos campos que serão persistidos/consultados como texto ou JSONB, antes de executar o domínio.

Implementação sugerida:

Criar um validador reutilizável para strings persistidas e aplicá-lo à chave idempotente, nota, motivo e e-mail, além de q e metadados de upload quando alcançam PostgreSQL. Não remover NUL silenciosamente de chaves, nem normalizar senhas como efeito colateral. Retornar erro de campo estável; preservar Unicode válido e as quebras de linha permitidas pelo contrato. Um handler genérico de DataError não substitui a validação da entrada conhecida.

Arquivos afetados: `backend/src/gestao_recebiveis/schemas.py`, `backend/src/gestao_recebiveis/routes.py`, `backend/src/gestao_recebiveis/imports.py (filename)`, `backend/tests/test_field_matrix.py`, `backend/tests/test_api.py`.

Como validar: Exigir 422 para NUL em note, idempotency_key, reason, email, busca e filename persistido. No teste com PostgreSQL, confirmar que saldo, pagamentos e auditoria permanecem iguais após a recusa. Preservar casos positivos com acentos, emoji e texto multilinha permitido. Distinguir o teste unitário de schema/adaptação do teste integrado HTTP ainda necessário.

Observabilidade e correlação de erros

PROBLEMA EVD-07 - Erros rejeitados pelo limite de corpo apresentam dois IDs de rastreamento

- **Repositório:** evidencedesk.
- **Categoria:** Observabilidade e contrato de erro.
- **Gravidade:** Baixa.
- **Localização:** backend/src/evidencedesk/body_limit.py:28-43; backend/src/evidencedesk/app.py:73,107-112.
- **Esforço:** baixo; estimativa: 1-2 horas.
- **Prioridade:** P2.

Problema identificado:

Erros rejeitados pelo limite de corpo apresentam dois IDs de rastreamento

Evidência:

JsonBodyLimit cria um UUID próprio e o coloca no corpo e no cabeçalho de suas rejeições. O middleware externo request_context cria outro UUID, substitui X-Request-ID e usa esse segundo valor no evento http.completed. A prova evd_request_id_probe.json reproduziu HTTP 413 com JSON request_id=92ebc0322a3f4c7d89d12b771dee2661 e X-Request-ID=5f5dd49c9eb5405a9a140b393ac278b4. A mesma construção de rejeição atende tamanho declarado/recebido, Content-Length inválido e timeout.

Por que isso é um problema:

O ID que a interface recebe no envelope de erro não é a chave de correlação registrada pelo middleware externo. Os testes do limitador isolado não exercitam essa composição.

Impacto:

Um relato de erro com o ID do JSON pode não localizar o evento HTTP correspondente nos logs, dificultando o diagnóstico de falhas de envio. Não foi identificado vazamento de dados nem desvio do limite de tamanho.

Correção recomendada:

Definir um único request_id por requisição e reutilizá-lo no limitador, no envelope JSON, no cabeçalho e no evento de conclusão.

Implementação sugerida:

Em JsonBodyLimit, obter o ID de scope['state'] já inicializado pelo middleware externo; criar e guardar um fallback somente se não existir. Manter essa regra válida quando o limitador for usado isoladamente. Evitar gerar um novo UUID dentro do ramo de rejeição.

Arquivos afetados: `backend/src/evidencedesk/body_limit.py`, `backend/src/evidencedesk/app.py`, `backend/tests/unit/test_body_limit.py`.

Como validar: Adicionar testes da aplicação criada por create_app, além do middleware isolado. Para rejeição por tamanho declarado, tamanho recebido, Content-Length inválido e prazo controlado, afirmar que o ID do JSON, do cabeçalho e do evento http.completed é igual, não vazio e gerado pelo servidor. Usar timeout curto controlado no teste.

Documentação de migração e retenção

PROBLEMA REC-07 - O roteiro de atualização descreve a migração atual como apenas aditiva

- **Repositório:** gestao-recebiveis.
- **Categoria:** Documentação operacional e migrações.
- **Gravidade:** Média.
- **Localização:** docs/security.md:32; backend/migrations/versions/e71c2f_partial_payments.py:14.
- **Esforço:** baixo; estimativa: Pequeno: 1-2 horas.
- **Prioridade:** P2.

Problema identificado:

O roteiro de atualização descreve a migração atual como apenas aditiva

Evidência:

O passo 4 de Atualizar uma instalação existente sem apagar dados afirma que a migração acrescenta somente login_admission. No HEAD, alembic upgrade head também alcança e71c2f: bloqueia receivables/payments, valida saldos e quitação legada, remove a unicidade payments.receivable_id e acrescenta índice e constraint de valor positivo. Dados incompatíveis provocam recusa explícita. O downgrade também rejeita múltiplos recebimentos ou pagamento parcial.

Por que isso é um problema:

A instrução é apresentada como procedimento atual, mas descreve o escopo da revisão anterior d6420a. O operador não é informado de que haverá validação e mudança do contrato financeiro.

Impacto:

Uma atualização pode parar pela guarda de consistência ou aguardar locks de tabelas sem que o roteiro explique a causa e a resposta esperada. Não foi demonstrada perda de dados; as próprias guardas são uma qualidade do código.

Correção recomendada:

Atualizar o procedimento para identificar a revisão financeira, suas condições de recusa e os limites de retorno ao schema anterior.

Implementação sugerida:

Substituir a última frase do passo 4 por: "O comando aplica as revisões pendentes até o head. A revisão e71c2f valida os dados financeiros legados sob lock de receivables e payments, retira a unicidade de pagamento por título e acrescenta índice e regra de valor positivo. Se houver inconsistência, a migração para sem corrigi-la silenciosamente; preserve o backup, examine o título indicado e reconcilie a origem antes de repetir." Acrescentar que downgrade não apaga parcelas para caber no modelo antigo e pode ser recusado. Preservar os passos já existentes de parada dos escritores, backup e validação em banco separado.

Arquivos afetados: `docs/security.md`, `docs/verification.md (conferir alinhamento)`, `backend/migrations/versions/e71c2f_partial_payments.py (referência, sem alteração necessária)`.

Como validar: Confrontar o roteiro com alembic history e o arquivo e71c2f; em ambiente descartável, validar upgrade de quitação legada consistente, recusa de saldo incompatível e recusa de downgrade após parcelas. As duas últimas são resultados esperados de proteção.

PROBLEMA CYC-05 - Documentação apresenta a limpeza do arquivo bruto como teto rígido de armazenamento

- **Repositório:** cycleops.
- **Categoria:** Documentação operacional e retenção.
- **Gravidade:** Baixa.
- **Localização:** SECURITY.md:11; apps/backend/src/cycleops/worker/archive.py:1-2,51-60,67-79,98.
- **Esforço:** baixo.
- **Prioridade:** P2.

Problema identificado:

Documentação apresenta a limpeza do arquivo bruto como teto rígido de armazenamento

Evidência:

SECURITY.md afirma teto de 500 MB. ArchiveWriter chama prune apenas em _open, na rotação/reinício; cada write posterior apenas escreve e faz flush. prune preserva keep mesmo acima do máximo; test_worker_archive.py:98-99 testa essa exceção explicitamente.

Por que isso é um problema:

O limite orienta a remoção dos arquivos anteriores durante a rotação. Ele não é uma garantia de espaço máximo, nem uma purga periódica independente de novas escritas. O ativo pode crescer entre duas rotações.

Impacto:

Quem dimensionar o volume supondo um teto rígido pode reservar espaço insuficiente. Não foi medido consumo real de 500 MiB; o achado é a promessa mais forte que o comportamento intencional.

Correção recomendada:

Corrigir SECURITY.md e a docstring para explicar a política real. Manter a preservação do arquivo ativo; um teto físico exigiria decisão separada de rotação por tamanho e comportamento quando não houver espaço.

Implementação sugerida:

Texto para substituir apenas a descrição do arquivo bruto:

"O arquivo bruto do live é dividido por hora. Ao abrir um novo arquivo, a limpeza remove arquivos anteriores com última escrita há mais de 48 horas e depois os mais antigos enquanto o conjunto ultrapassa 500 MiB. O arquivo em uso é preservado; por isso o volume pode passar desse valor entre rotações."

Docstring correspondente: "Hourly NDJSON.gz archive. On rotation, prune older files by a 48-hour retention target and a 500 MiB size threshold, preserving the active file; this is not a hard disk quota."

Arquivos afetados: `SECURITY.md`, `apps/backend/src/cycleops/worker/archive.py`.

Como validar: Conferir que a descrição identifica momento da limpeza, unidade MiB e exceção do arquivo ativo. Preservar os testes existentes e o probe com limiar reduzido; não rodar teste de carga contra o feed real.

Precisão adicional de uma correção anterior

VDP-02 - publicação atômica do HTML. Ao substituir a escrita direta por arquivo temporário e `os.replace`, preservar/definir antes da troca as permissões de leitura necessárias ao report-server, que roda como UID 65534. Um temporário criado por `mkstemp` normalmente nasce com 0600; a atomicidade não deve tornar o resultado ilegível para o servidor. Validar um GET sob o usuário do container após a troca, além da integridade do documento. Isso complementa a recomendação anterior; não é um novo defeito já existente nem autoriza ampliar permissões indiscriminadamente.

Controles observados e verificações por repositório

arthurjoanes

Versão examinada: `603c69d889f19d0781f486238a55e242ca55b66e`.

O que foi confirmado ou encontrado implementado:

- PER-01 continua sendo a mudança objetiva de descoberta das demos; não foi criado novo achado para repetir esse ponto. Tradução preserva o sentido das experiências declaradas.

Verificações desta rodada:

• **Procedimento:** Releitura PT/EN e inventário GitHub **Resultado:** 11 repositórios públicos permanecem no inventário; propósito e alegações profissionais correspondem nas duas versões. **Limite:** Não valida métricas do empregador ou trajetória pessoal.

Arquivos e trechos adicionais examinados:

• `README.md`

• `README.en.md`

• `inventário público atualizado`

Limitações restantes:

• Perfil não tem superfície de execução para auditar sessão, banco ou deploy. Não há base para contestar métricas privadas como falsas.

evidencedesk

Versão examinada: `e4dd8efe73e50999b9a75896ce74b75d460223da`.

O que foi confirmado ou encontrado implementado:

• O contexto autenticado deriva tenant e usuário da sessão e verifica usuário/tenant habilitados. As mutações verificam Origin e CSRF; cookies usam HttpOnly e SameSite=Lax, e a configuração exige proteção adicional fora do modo local.

• A leitura do banco combina contexto de tenant por transação, políticas RLS e verificações explícitas de coleção/incidente. A prontidão verifica o papel do banco contra privilégios incompatíveis com o isolamento; isso foi inspecionado, não exercitado em PostgreSQL nesta rodada.

• O login limita verificações Argon2 simultâneas a duas, além da admissão durável por identidade/origem. Uploads têm limites por processo e tenant, tamanho, hash de manifesto e prazo. O parser isolado aplica limites de recursos em Linux e limites de linhas/saída; a execução Windows não demonstra RLIMIT do contêiner Linux.

• A publicação de objetos usa arquivo temporário, sincronização e instalação imutável; a limpeza mantém estados duráveis e verifica referências/produtores antes de remover o arquivo e devolver quota. O protocolo de restauração inclui ledger de exclusões e falha fechada para condições incompatíveis.

• Logs e telemetria usam campos limitados, sem registrar conteúdo dos documentos, prompts ou mensagens brutas de exceções nos caminhos revisados. Rótulos de métricas limitam método e rota.

• A liberação de modelo verifica endpoint permitido, prompt/esquema/modelo e limites; o adaptador desabilita armazenamento do provedor e retries automáticos. O despacho exige reserva de orçamento e preserva consumo desconhecido. Os 38 testes executados reforçam o armazenamento privado e a validação de release.

• O workflow declara permissões de leitura, fixa ações por SHA, desabilita persistência de credenciais do checkout e verifica dependências/segredos/imagens. Foram lidas as etapas; sua existência não foi tratada como prova de execução recente ou ausência de vulnerabilidades.

Verificações desta rodada:

• **Procedimento:** git -C evidencedesk rev-parse HEAD; git -C evidencedesk status --short **Resultado:** HEAD e4dd8efe73e50999b9a75896ce74b75d460223da; árvore limpa. **Limite:** Leitura local. A comparação com origin HEAD pertence à primeira rodada.

• **Procedimento:** python -B _auditoria_2026-10-13/evd_request_id_probe.py, com PYTHONPATH da cópia execution/evd-domain/backend/src, ED_AI_PROVIDER=disabled e sem chave Azure **Resultado:** Uma requisição de 512 KiB + 1 byte ao login retornou HTTP 413/request**oo_larg** O request_id do JSON foi 92ebc0322a3f4c7d89d12b771dee2661; o cabeçalho X-Request-ID foi 5f5dd49c9eb5405a9a140b393ac278b4.

Resultado salvo em evd_request_id_probe.json. **Limite:** TestClient em processo, sem lifespan, banco, rede, Docker ou carga. Confirma a divergência JSON/cabeçalho na pilha real de middleware; a correspondência do cabeçalho com o campo de log é leitura de app.py.

• **Procedimento:** Na cópia execution/evd-domain: python -B -m pytest backend/tests/unit/test_private_storage.py backend/tests/unit/test_model_release.py -p no:cacheprovider -q **Resultado:** 38 testes passaram em 1,56 s. Fornecedor de IA desabilitado; PYTHONDONTWRITEBYTECODE=1. **Limite:** Runtime Python já existente no workspace; testes unitários com dependências locais, sem serviço Azure, PostgreSQL, Docker ou execução do workflow de CI.

Arquivos e trechos adicionais examinados:

- `backend/src/evidencedesk/identity/service.py`
- `backend/src/evidencedesk/identity/routes.py`
- `backend/src/evidencedesk/identity/admission.py`
- `backend/src/evidencedesk/app.py`
- `backend/src/evidencedesk/config.py`
- `backend/src/evidencedesk/body_limit.py`
- `backend/src/evidencedesk/database.py`
- `backend/src/evidencedesk/telemetry/signals.py`
- `backend/src/evidencedesk/ingestion/limits.py`
- `backend/src/evidencedesk/ingestion/parser.py`
- `backend/src/evidencedesk/ingestion/routes.py`
- `backend/src/evidencedesk/ingestion/service.py`
- `backend/src/evidencedesk/ingestion/contracts.py`
- `backend/src/evidencedesk/evidence/storage.py`
- `backend/src/evidencedesk/evidence/routes.py`
- `backend/src/evidencedesk/evidence/service.py`
- `backend/src/evidencedesk/evidence/deletion.py`
- `backend/src/evidencedesk/retention/service.py`
- `backend/src/evidencedesk/retention/cleanup.py`
- `backend/src/evidencedesk/administration/routes.py`
- `backend/src/evidencedesk/deletion_ledger.py`
- `backend/src/evidencedesk/jobs/service.py`
- `backend/src/evidencedesk/worker.py`
- `backend/src/evidencedesk/investigations/streams.py`
- `backend/src/evidencedesk/investigations/routes.py`
- `backend/src/evidencedesk/investigations/budget.py`
- `backend/src/evidencedesk/model_runtime/release.py`
- `backend/src/evidencedesk/model_runtime/azure.py`
- `backend/src/evidencedesk/maintenance.py`

- backend/migrations/versions/0007_retention_ownership.py
- backend/pyproject.toml
- .github/workflows/ci.yaml
- docs/api-contract.md
- docs/runbooks/backup-restore.md
- backend/tests/unit/test_body_limit.py
- backend/tests/unit/test_private_storage.py
- backend/tests/unit/test_model_release.py
- backend/tests/integration/test_maintenance.py

Limitações restantes:

- Leitura dirigida: arquivos extensos de jobs, budget, retenção, limpeza, Azure, manutenção e runbooks foram inspecionados por funções/seções relevantes; files_read não significa revisão linha a linha de todos esses arquivos.
- Sem PostgreSQL ou Docker nesta rodada: não foram reexecutados isolamento RLS, integração de sessões, fluxo de upload completo, limpeza física, restauração ou concorrência real entre processos.
- Nenhuma chamada a fornecedor de IA. A análise do orçamento verifica a implementação local e não garante equivalência com uma fatura externa.
- Não houve novo scan de vulnerabilidades de dependências nem consulta individual a todas as versões. Nenhuma ausência de CVE foi inferida do workflow.
- A manutenção trata produtores ativos de forma conservadora. Sem reproduzir um caso operacional adicional, isso não foi promovido a novo defeito de retenção.
- Nenhum bypass de autenticação ou vazamento entre tenants foi confirmado na revisão dirigida; isso não equivale a uma certificação de segurança.

Referências adicionais:

- Código local e prova de composição de middleware

gestao-recebiveis

Versão examinada: 7477a6afe0bbc0a5308cec120f04a5f7384b81ad.

O que foi confirmado ou encontrado implementado:

- Chaves idempotentes são coordenadas mesmo quando requisições apontam para títulos diferentes; o conteúdo canônico impede reutilização com outro pedido.
- Recebimentos usam saldo calculado sob lock do título e guardas para valor positivo/limite do saldo; cancelamento com parcela é recusado.
- O resultado desconhecido do provedor preserva a autorização original; lease_token impede finalização por posse antiga e o dia comercial tem guarda própria.
- A migração financeira confere invariantes e recusa downgrade incompatível, em vez de apagar ou reajustar dinheiro.
- Admissão de login é persistida em transação separada, limita Argon2 e guarda HMACs de identidade/origem em vez dos valores crus.
- Escopo de uma empresa é explícito. Não classifiquei ausência de tenant como falha nem contas fictícias publicadas como vazamento de credenciais reais.

Verificações desta rodada:

• **Procedimento:** git status --short; git rev-parse HEAD (início e fim da rodada) **Resultado:** HEAD permanece 7477a6afe0bbc0a5308cec120f04a5f7384b81ad; checkout limpo no início e no fim desta rodada. **Limite:** Não houve novo fetch nem alteração do remoto.

• **Procedimento:** Revisão dirigida de pagamento, importação, auth, worker e relatórios **Resultado:** Lock de chave idempotente antecede lock do título; quitação e cancelamento coordenam reminders; importação usa savepoint; relatórios usam REPEATABLE READ independente da sessão de autenticação. Origin/CSRF/perfil são verificados nas mutações. Datas extremas são tratadas por diferença de datas/clamp, sem somar dias fora do domínio. **Limite:** Leitura não equivale a reexecutar corridas PostgreSQL. Nenhuma quebra nova de saldo ou de autorização foi demonstrada.

• **Procedimento:** Confronto docs/security.md com migrações d6420a/e71c2f e env.py **Resultado:** Confirmado REC-07: roteiro atual diz alteração apenas aditiva de login_admission, mas head inclui migração de contrato de pagamentos com locks e validações. **Limite:** A migração financeira não foi executada nesta rodada; o conflito é documental e verificável diretamente na fonte.

• **Procedimento:** Probe puro de schemas + psycopg.types.string.StrDumper, Python 3.13.15 do venv existente; PYTHONDONTWRITEBYTECODE=1 **Resultado:** Quatro campos com NUL aceitos pelos schemas e recusados pelo adaptador com DataError. Versões registradas: Pydantic 2.13.5 e Psycopg 3.3.6. Recibo: recebiveis-nul-boundary-probe.json. database_accessed=false. **Limite:** Não é teste HTTP integrado nem acesso ao PostgreSQL. Motivo de cancelamento usa JSONB no caminho real; a restrição de JSONB foi confirmada na documentação PostgreSQL 18.

• **Procedimento:** Revisão de prova de restore, permissões, CI e containers **Resultado:** Runner separa evidência privada/publicável, aplica/verifica ACL antes dos segredos, restringe namespaces e destinos e mantém checksums sem alegar autenticidade. Runtime PostgreSQL separado do owner; scripts de CI usam credenciais temporárias e ambientes de teste. **Limite:** Sem executar Docker, migrações, restore, scan ou serviços reais. Hash local não autentica backup, limite já explicitado no projeto e não tratado como achado novo.

Arquivos e trechos adicionais examinados:

• `backend/src/gestao_recebiveis/receivables.py`

• `backend/src/gestao_recebiveis/auth.py`

• `backend/src/gestao_recebiveis/routes.py`

• `backend/src/gestao_recebiveis/schemas.py`

• `backend/src/gestao_recebiveis/clock.py`

• `backend/src/gestao_recebiveis/database.py`

• `backend/src/gestao_recebiveis/balances.py`

• `backend/src/gestao_recebiveis/import_csv.py`

• `backend/src/gestao_recebiveis/imports.py`

• `backend/src/gestao_recebiveis/login_admission.py`

• `backend/src/gestao_recebiveis/config.py`

• `backend/src/gestao_recebiveis/reminders/policy.py`

• `backend/src/gestao_recebiveis/reminders/service.py`

• `backend/src/gestao_recebiveis/reminders/provider.py`

• `backend/src/gestao_recebiveis/worker.py`

• `backend/src/gestao_recebiveis/app.py`

- backend/src/gestao_recebiveis/request_limits.py
- backend/src/gestao_recebiveis/models.py
- backend/src/gestao_recebiveis/reporting.py
- backend/src/gestao_recebiveis/provision_database.py
- backend/src/gestao_recebiveis/audit.py
- backend/migrations/versions/e71c2f_partial_payments.py
- backend/migrations/versions/d6420a_login_admission.py
- backend/migrations/env.py
- backend/tests/test_reports.py
- backend/tests/test_field_matrix.py
- backend/tests/test_database_roles.py
- backend/tests/restore_support.py
- scripts/verify_restore_backup.py
- scripts/prove_restore.py
- backend/pyproject.toml
- backend/Dockerfile
- frontend/Dockerfile
- frontend/Dockerfile.e2e
- frontend/next.config.ts
- database/Dockerfile
- compose.yaml
- compose.e2e.yaml
- .dockerignore
- .github/workflows/ci.yml
- .github/workflows/secrets.yml
- docs/security.md
- docs/demo.md (trechos)

Limitações restantes:

- Não houve validação end-to-end de todos os modelos ou execução da suíte PostgreSQL; os testes existentes foram inspecionados por recorte.
- REC-08 tem reprodução do limite schema/adaptador e inferência controlada sobre o caminho HTTP; não se declara 500 observado em servidor nem corrupção financeira.
- Nomes de arquivos/metadados e busca foram identificados como campos a cobrir na correção; a prova executada contém somente os quatro campos discriminados.
- Não houve scan atual de CVEs nem instalação limpa dos lockfiles; nenhuma afirmação de dependência vulnerável foi acrescentada.
- Arquivos extensos de runner e testes foram lidos em trechos dirigidos. Nenhuma gravação em repositório foi autorizada ou realizada.

Referências adicionais:

- PostgreSQL 18 - JSON Types
- Psycopg 3 - Adapting basic Python types

loja-assistente

Versão examinada: `075ea83a0a7b99ccef5868050609c3c36c4d907f`.

O que foi confirmado ou encontrado implementado:

• As consultas analíticas usam operações previamente definidas e filtros de tenant/loja; o cliente não fornece SQL livre. Histórico, favoritos e retomada verificam permissões atuais, com tratamento de escopo revogado nos caminhos revisados.

• Sessões usam token aleatório de 48 bytes e digest HMAC no banco. Mutações verificam Origin/CSRF; cookies usam HttpOnly e SameSite=Lax, com Secure exigido fora de DEMO_MODE. O segredo fora de demo deve ter pelo menos 32 caracteres.

• O proxy encaminha somente o cookie da aplicação e não confia em X-Forwarded-For; o backend desabilita proxy headers e o Compose publica serviços em loopback. A arquitetura usa proxy de mesma origem; ausência de CORS permissivo não é um defeito.

• A admissão de login é durável, por conta e origem, oferece Retry-After e usa identificadores derivados em lugar de e-mail/IP brutos. Sucesso libera sua reserva e falha conserva a contagem. Esse controle é útil, embora não substitua o limite de concorrência do LOJ-07.

• O limite de corpo conta chunks e rejeita acima de 16 KiB. O proxy aplica prazo de 45 segundos que abrange a leitura do pedido e encaminhamento, com propagação de cancelamento.

• O handler de erro HTTP registra tipo de exceção, sem texto bruto, e os traces do provedor contêm metadados limitados, hashes e uso, sem prompt/resposta completa. O adaptador usa store=false e desabilita retries automáticos; o LOJ-08 se limita ao diagnóstico anterior à inicialização da aplicação.

• A reserva de orçamento e a marcação de despacho usam transações duráveis; custo desconhecido não é liberado como se o pedido fosse gratuito. Sem chamada externa nesta revisão, não se alegou equivalência garantida com a fatura do fornecedor.

• O workflow usa permissões reduzidas, ações por SHA, checkout sem credenciais persistidas, Gitleaks com verificação de checksum e saída redigida e scanner de imagem fixado por digest. Docker usa imagens fixadas, instalação congelada e usuário sem root. A análise é da configuração, sem nova execução da CI.

Verificações desta rodada:

• **Procedimento:** git -C loja-assistente rev-parse HEAD; git -C loja-assistente status --short **Resultado:** HEAD 075ea83a0a7b99ccef5868050609c3c36c4d907f; árvore limpa. **Limite:** Leitura local. A comparação com origin HEAD pertence à primeira rodada.

• **Procedimento:** python -B _auditoria_2026-10-13/loja_login_capacity_probe.py, com PYTHONPATH da cópia execution/loj-domain/backend/src, DEMO_MODE=true, LLM_ENABLED=false e chave de provedor vazia **Resultado:** Hasher configurado com memory**ost=655** KiB, time_cost=3 e parallelism=4; pool de 5+10 conexões; runtime AnyIO com 40 tokens; admissão de origem=30 e conta=5. Quinze chamadas de login com verificador barato substituto alcançaram simultaneamente a verificação e terminaram em 401. Uma Session SQLAlchemy sobre SQLite manteve conexão após SELECT e a liberou após rollback. Orçamento calculado: 15 × 64 MiB = 960 MiB, contra mem_limit=768m no Compose. **Limite:** A admissão e o trabalho de senha foram substituídos por stubs na prova de concorrência. Não foram executados Argon2 pesado em paralelo, HTTP de carga, PostgreSQL, swap ou OOM. SQLite demonstra o ciclo de vida do ORM, não mede o pool PostgreSQL. Quinze identidades distintas cabem nos limites iniciais declarados por conta/origem; isso é análise do orçamento permitido, não uma medição de RSS.

• **Procedimento:** python -B _auditoria_2026-10-13/loja_config_redaction_probe.py, com _env_file=None e marcador sintético audit-synthetic-key-NOT-A-CREDENTIAL **Resultado:** Configuração inválida por COOKIE**ECURE=f**se fora de DEMO_MODE produziu ValidationError. str(error) incluiu input_value com o sufixo c-key-NOT-A-CREDENTIAL. O marcador completo não apareceu, devido à abreviação do Pydantic. hide_input_in_errors estava false. Resultado salvo em loja_config_redaction_probe.json. **Limite:** Nenhum arquivo .env real, chave real, serviço de log ou provedor foi usado. A prova verifica a representação da exceção; a chegada a stderr na inicialização normal decorre da construção não capturada de Settings() no import, não de uma execução de deploy.

Arquivos e trechos adicionais examinados:

- `backend/src/loja_assistente/auth/service.py`
- `backend/src/loja_assistente/auth/routes.py`
- `backend/src/loja_assistente/auth/admission.py`
- `backend/src/loja_assistente/config.py`
- `backend/src/loja_assistente/app.py`
- `backend/src/loja_assistente/database.py`
- `backend/src/loja_assistente/request_limits.py`
- `backend/src/loja_assistente/observability/routes.py`
- `backend/src/loja_assistente/assistant/provider_trace.py`
- `backend/src/loja_assistente/assistant/interpreters/openai_adapter.py`
- `backend/src/loja_assistente/assistant/budget.py`
- `backend/src/loja_assistente/assistant/budget_policy.py`
- `backend/src/loja_assistente/assistant/interpretation.py`
- `backend/src/loja_assistente/conversations/service.py`
- `backend/src/loja_assistente/favorites/service.py`
- `backend/src/loja_assistente/clarifications/service.py`
- `backend/src/loja_assistente/analytics/queries.py`
- `backend/src/loja_assistente/analytics/service.py`
- `backend/Dockerfile`
- `compose.yaml`
- `frontend/src/app/api/[...path]/route.ts`
- `.github/workflows/ci.yml`
- `docs/security.md`
- `docs/api-contract.md`
- `docs/decisoes-tecnicas.md`
- `backend/tests/test_login_admission.py`
- `backend/tests/test_request_limits.py`
- `backend/tests/test_secure_config.py`
- `backend/tests/test_budget_adapter.py`

Limitações restantes:

• Leitura dirigida: budget, clarifications, consultas analíticas, documentação e alguns testes foram revisados em seções específicas; files_read não implica revisão integral de cada arquivo extenso.

• Provas usaram o Python já disponível no workspace com o código copiado do HEAD; não constituem instalação limpa do lockfile da Loja Assistente nem teste da imagem publicada.

• Sem PostgreSQL/Docker, nenhum ensaio de carga real, nenhuma medição de RSS e nenhum Argon2 caro em paralelo. Os números do LOJ-07 descrevem configuração, concorrência de stubs e orçamento permitido.

• Sem chamadas a LLM, serviço externo de logs ou uso de segredo real. LOJ-08 demonstrou somente um fragmento de marcador sintético na representação da exceção.

• Não foi encontrada rotina automática geral de retenção para sessões/conversas nos caminhos revisados; a documentação já trata retenção como requisito de evolução para produção. Sem requisito de prazo atual descumprido, isso fica como limite de implantação, não como novo defeito confirmado.

• O backend direto não demonstrou nesta rodada um prazo de leitura equivalente ao proxy. A publicação local em loopback e o prazo do proxy são contexto essencial; não se alegou exposição pública nem ataque executado.

• Não houve novo scan de dependências ou revisão de todas as CVEs. O workflow não foi usado como prova de ausência de vulnerabilidades.

• Nenhum bypass de sessão, CSRF ou vazamento entre tenants foi confirmado nos fluxos dirigidos. Não houve teste completo de integração do sistema nesta rodada.

Referências adicionais:

• argon2-cffi - How to Hash a Password

• SQLAlchemy - Session Basics

• Starlette - Thread Pool

• Pydantic - ConfigDict.hide_input_in_errors

• Prova isolada de orçamento de login

• Prova de redação de erro de configuração

varejo-data-pipeline

Versão examinada: `cd8bff90ce9d1ef37f727ec6f7fd9d8cbe615134`.

O que foi confirmado ou encontrado implementado:

• A reconstrução do candidato lê o histórico oficialmente publicado, evitando adotar automaticamente restos de candidato anterior que falhou.

• A validação não confunde reconciliação de receita com integridade da venda: SALE_DATE_CONFLICT verifica datas dos itens ativos.

• No adapter OpenLineage, um manifesto de candidato isolado não basta para provar commit; a reconstrução usa ponteiro/ancestralidade e registros legados explícitos.

• A retenção é conservadora e declara que não autoriza VACUUM ou exclusão individual de arquivos Delta.

• As ferramentas JVM checam hashes upstream/rebuild/provenance e detectam ZIP com nomes duplicados, sem tratar o scanner como assinatura de confiança.

Verificações desta rodada:

• **Procedimento:** git status --short; git rev-parse HEAD (início e fim da rodada) **Resultado:** HEAD permanece cd8bff90ce9d1ef37f727ec6f7fd9d8cbe615134; checkout limpo no início e no fim desta rodada. **Limite:** A comparação remota foi realizada na primeira rodada; nesta rodada apenas a identidade local foi novamente consultada.

• **Procedimento:** Leitura dirigida de publicador, pipeline, transformações e contratos **Resultado:** Escritor único usa flock; os candidatos partem do histórico da publicação oficial; conflitos e separação de data da mesma venda bloqueiam publicação. O ponto visível usa JSON temporário, fsync, replace e fsync do diretório. Valores/timestamps têm validação e canonicalização explícitas. **Limite:** Revisão estática; não reexecuta Spark/Delta ou concorrência em Linux.

• **Procedimento:** Leitura de proof_contracts.py, prove_state.py e lineage.py **Resultado:** Backup verifica inventário antes/depois, recusa entradas especiais e destino ocupado. Retenção protege diretórios Delta completos e perfis com hash/identidade. Reexportação de lineage usa lock e cadeia de publicações comprometidas, com eventos imutáveis. **Limite:** VDP-01 já cobre a ordenação por mtime pós-restauração; não duplicado. Alguns trechos do runner grande foram lidos de forma dirigida.

• **Procedimento:** Leitura de Compose, workflows e instaladores de JAR **Resultado:** Batch sem rede, mounts de código somente leitura, recursos limitados; componentes baixados têm hashes; rebuilds são validados em conjunto antes de copiar; CI faz scan e exige presença dos inventários OS/JVM/Python no gate. **Limite:** Não houve build nem scan novo. Existência de gate não certifica ausência atual de vulnerabilidades; não foi feita avaliação exaustiva de todos os backports.

Arquivos e trechos adicionais examinados:

• `src/retail_pipeline/publication.py`

• `src/retail_pipeline/pipeline.py`

• `src/retail_pipeline/transformations.py`

• `src/retail_pipeline/contracts.py`

• `src/retail_pipeline/ingestion.py`

• `src/retail_pipeline/batch_contracts.py`

• `src/retail_pipeline/input_limits.py`

• `src/retail_pipeline/lineage.py`

• `scripts/proof_contracts.py`

• `scripts/prove_state.py`

• `scripts/fetch_artifact.py`

• `scripts/download_jars.py`

• `scripts/install_rebuilt_jars.py`

• `scripts/patch_runtime_jars.py`

• `scripts/check_image_scan.py`

• `compose.yaml`

• `.dockerignore`

• `.github/workflows/ci.yml`

• `.github/workflows/secrets.yml`

Limitações restantes:

• Nenhum achado novo confirmado no recorte desta rodada; isso não cancela VDP-01 a VDP-04 nem afirma ausência de falhas.

• Runtime declarado Linux/Spark/Delta não foi executado; daemon Docker anteriormente indisponível não foi iniciado.

• O produto é local e não oferece multiusuário/tenant; não tratei essa limitação explícita como vulnerabilidade.

• Não examinei exaustivamente toda a árvore vendor/backports ou todas as dependências transitivas.

• A futura correção de VDP-02 deve preservar permissões de leitura do report-server UID 65534: temporário mkstemp padrão 0600 seguido de replace precisa de política de modo apropriada. É cuidado de implementação do achado anterior, não defeito novo.

api-sentinel

Versão examinada: `a0e1375bfecabcdf0a5e98802598bff63bbe44f6`.

O que foi confirmado ou encontrado implementado:

• Não foi confirmado novo defeito de autenticação, autorização, SQL injection, SSRF ou divulgação de segredo nos caminhos examinados. Essa frase se limita à cobertura descrita; os achados API-01 a API-05 da primeira rodada continuam válidos.

• Credencial expirada/revogada é consultada no banco a cada autenticação. Limites de autenticação e trabalho em andamento precedem a operação de negócio; cancelamento libera tarefas e recursos.

• O log de exceção da API registra tipo e localização de frames, sem mensagem, locals ou código-fonte. Respostas de validação/erro são genéricas; não repassam SQL, payload ou credencial.

• ERP/probe limitam tempo e tamanho de resposta, recusam compressão inesperada e não seguem redirecionamentos. A ferramenta de contratos usa transporte sem proxy de ambiente, não segue redirects e limita o corpo.

• Papéis de banco e ACL Redis estão separados por função. Senhas PostgreSQL literais são credenciais locais explicitamente documentadas; não foram tratadas como vazamento de produção.

• CI usa escopo contents:read, referências SHA das Actions, fluxo específico de scan aplicação/proxy e limpeza de projetos identificados. Gitleaks tem exceções de caminhos/padrões delimitados; não há exclusão geral de evidências.

• Compose publica os serviços em loopback. Algumas imagens auxiliares são tags versionadas sem digest; isso foi registrado como limite de reprodutibilidade/escopo, sem alegar vulnerabilidade concreta ou inventar finding.

Verificações desta rodada:

• **Procedimento:** git status --short; git rev-parse HEAD; git ls-remote origin HEAD **Resultado:** Status vazio no início e ao encerrar; HEAD local e remoto iguais a a0e1375bfecabcdf0a5e98802598bff63bbe44f6. **Limite:** Não demonstra execução atual de CI, scanner ou da stack.

• **Procedimento:** Na cópia git archive da rodada anterior, com PYTHONDONTWRITEBYTECODE=1/PYTHONPATH=src e Python de .runtime/verifyvenv: python -X utf8 -m pytest tests/unit/test_auth_admission.py tests/unit/test_middleware.py tests/unit/test_config.py tests/unit/test_receiver.py tests/unit/test_receiver_config.py tests/unit/test_receiver_probe.py tests/unit/test_redis_bootstrap.py tests/unit/test_rate_limit.py tests/unit/test_review_cleanup.py tests/contracts/test_verifier.py -q -p no:cacheprovider **Resultado:** 161 passed, 4 skipped, 6 subtests passed em 9,07 s; duas advertências de depreciação Starlette/httpx/AnyIO. **Limite:** Ambiente preexistente; quatro casos que exigem extras de contratos ficaram pulados. Casos isolados usam mocks/fixtures locais; não são aprovação de PostgreSQL, Redis ou proxy real.

• **Procedimento:** Leitura cruzada auth/admit/queries/cache-key/cursor/CLI e schema inicial **Resultado:** As rotas chamam authorize antes de cache/ERP e quotas; as consultas comerciais incluem tenant_id; emissão administrativa verifica que todas as lojas escolhidas pertencem ao tenant. Cursor é HMAC e vincula organização, loja, período e dataset. **Limite:** Não houve prova de concorrência ou SQL com banco real nesta rodada; nenhum bypass novo foi demonstrado.

• **Procedimento:** Leitura cruzada ERP, probe, diagnostics e contracts_adapter **Resultado:** ERP usa host de configuração, SKU limitado a SKU-[0-9]{3}, store inteiro, follow_redirects=False e trust_env=False. Ferramenta de contratos recusa URL externa arbitrária/referência remota e vincula base à tentativa. Destinos de investigação aceitam somente origens loopback configuradas. **Limite:** Valores de ambiente/configuração continuam dentro da fronteira administrativa local. Não houve ensaio contra serviços externos nem exploração de rede.

• **Procedimento:** docker info --format '{{.ServerVersion}}' **Resultado:** Falhou: pipe dockerDesktopLinuxEngine ausente; daemon Linux indisponível. **Limite:** Sem build, scan, migração real, carga, rede entre containers ou integração nesta rodada.

Arquivos e trechos adicionais examinados:

• `src/api_sentinel/auth.py`

• `src/api_sentinel/cursor.py`

• `src/api_sentinel/config.py`

• `src/api_sentinel/telemetry.py (validação de entrada, safe_exception_context e caminhos de erro; leitura dirigida)`

• `src/api_sentinel/erp.py`

• `src/api_sentinel/app.py`

• `src/api_sentinel/queries.py`

• `src/api_sentinel/cli.py`

• `src/api_sentinel/db.py`

• `src/api_sentinel/rate_limit.py`

• `migrations/versions/0001_initial.py`

• `migrations/env.py`

• `alert_receiver/app.py`

• `alert_receiver/config.py`

• `alert_receiver/contracts.py`

• `alert_receiver/probe.py`

• `alert_receiver/diagnostics.py`

• `scripts/contracts_adapter.py`

• `scripts/verify_contracts.py (índice e chamadas relevantes via busca)`

• `scripts/provision_contracts.py (índice e referências a credenciais via busca)`

• `scripts/bootstrap.py`

• `scripts/review_scans.py`

• `scripts/review.py (índice, comandos e varredura de artefatos via busca)`

• `tests/unit/test_auth_admission.py (linhas 1-70)`

- `tests/contracts/test_verifier.py (linhas 1-70 e condições de skip via busca)`
- `docs/security.md`
- `compose.yml`
- `pyproject.toml`
- `Dockerfile`
- `deploy/contracts/Dockerfile`
- `deploy/proxy/nginx.conf`
- `deploy/redis/users.acl`
- `.dockerignore`
- `.gitleaks.toml`
- `.github/workflows/ci.yml`
- `.github/workflows/secrets.yml`

Limitações restantes:

- Sem revisão exaustiva de todo o histórico Git ou varredura nova de segredos. Gitleaks/Trivy e os avisos antigos citados na documentação não foram reaprovados como atuais.
- Lockfile uv.lock não recebeu auditoria linha a linha nem consulta completa de advisories; não há conclusão de ausência de CVEs.
- Não foi reexecutada migração/seed contra PostgreSQL; a leitura de permissões e isolamento não substitui prova no banco.
- Scripts grandes review.py/verify_contracts.py/provision_contracts.py tiveram inspeção dirigida, não integral.
- Não há mecanismo de backup/recovery de produção prometido pelo API Sentinel: laboratório local de dados sintéticos. A ausência de uma solução de produção não foi transformada em defeito.
- Repositório original não editado. Testes em cópia temporária com bytecode/cache desativados.

Referências adicionais:

- Fontes versionadas do repositório

containerops

Versão examinada: `57dc89474b8aa2067a1c8a925f33def0ceb27abe`.

O que foi confirmado ou encontrado implementado:

- Autorização usa proprietário derivado do Bearer, comparação constante de token e filtro owner/id no GET; chave idempotente é única por proprietário. Resposta de job não devolve payload e a sanitização de erro tem teste com marcador privado.
- A admissão e o despacho usam lock transacional compartilhado; conclusão/renovação exigem lease_token e lease vigente. Pausa impede admissão nova e retenção, permitindo drenar o trabalho existente antes do backup.
- Papéis PostgreSQL separam DML, migração e leitura de backup; restore ocorre em recursos descartáveis, usa pg_restore em transação e compara snapshot/novo job/limpeza antes de registrar aprovação.
- Pacote valida tipos/chaves/datas/origem, hashes e tamanhos; recusa links/reparse/hardlinks, nomes extras, JSON duplicado e mutação durante cópia. O archive é inspecionado sem extração e tem limites para arquivo/camadas expandidas.

• Archive transportado recusa tags compartilhadas; carregamento exige confiança e sessão, confere identidade de config/manifests/camadas e colisão de tag. OPS-05 não invalida esses controles de conteúdo ou isolamento; afeta classificação após falha.

• Scan é feito por archive sem socket Docker, verifica identidade e idade/hash da base; reports começam incomplete e HIGH/CRITICAL bloqueiam o comando. CI usa permissão contents:read, Actions por SHA e upload de caminhos selecionados, sem publicar o runtime inteiro.

• Não houve outro defeito novo confirmado nos tópicos examinados. Não se transformaram ausência de serviço externo, limitação local documentada ou falta de prova de produção em finding.

Verificações desta rodada:

• **Procedimento:** git status --short; git rev-parse HEAD; git ls-remote origin HEAD **Resultado:** Status vazio; HEAD local e remoto iguais a 57dc89474b8aa2067a1c8a925f33def0ceb27abe. **Limite:** Sem execução atual dos workflows remotos.

• **Procedimento:** Na cópia git archive, com PYTHONDONTWRITEBYTECODE=1: python -X utf8 -m unittest discover -s tests -p test_backup_package.py -q **Resultado:** 24 testes aprovados em 5,681 s. **Limite:** Fixtures/mocks; não executam pg_restore ou Docker real.

• **Procedimento:** Na cópia da aplicação, PYTHONPATH=src e Python de containerops/.venv: python -X utf8 -m pytest tests/test_security_review.py tests/test_http_contract.py tests/test_body_limit.py tests/test_api.py tests/test_domain.py -q -p no:cacheprovider **Resultado:** 98 testes aprovados em 5,37 s; duas advertências de depreciação. Uma tentativa anterior apontou por engano para app/.venv inexistente e não iniciou testes; caminho corrigido para .venv da raiz. **Limite:** Ambiente previamente instalado; banco isolado por mocks. Não houve teste contra banco real.

• **Procedimento:** python -B com unittest.TestLoader().discover para test_backup_catalog.py, test_oci_archive.py, test_runtime_context.py e test_operations.py; PYTHONDONTWRITEBYTECODE=1 **Resultado:** 53 testes executados em 9,431 s: 50 aprovados e 3 skips. A primeira execução com -X utf8 apenas no processo pai teve dois erros de decoding do stderr dos subprocessos Windows; execução normal, coerente com os subprocessos, passou. **Limite:** Não classificado como bug do produto: o erro inicial foi induzido pela configuração do comando da auditoria. Três casos condicionados a plataforma ficaram pulados. Testes de operação usam fixtures/mocks.

• **Procedimento:** python -X utf8 -B _auditoria_2026-10-13/probe_import_registration.py **Resultado:** Importação real de pacote sintético seguida de erro simulado em register**ackup d**xou diretório publicado: validation=valid, imported=false, protected=false. restore_test(trusted_source=False) atingiu stub do preflight. Com segunda cópia da mesma origem, plano keep_last=0 incluiu a primeira entre candidatas. Controle após registro correto recusou restore antes do preflight com mensagem --trusted-source. Recibo: containerops-import-registration-repro.json. **Limite:** Zero comandos externos; dump contém apenas marcador sintético. Preflight foi interrompido antes de Docker. Não executou SQL, restore, imagens nem exclusão. Proteção DACL foi substituída por fixture, pois a propriedade investigada é a ordem entre publicação e registro.

• **Procedimento:** Leitura cruzada pause/drain/cleanup/snapshot/backup/restore/release e catálogo **Resultado:** Pausa também suspende retenção de jobs; snapshot usa REPEATABLE READ; restore separa fases e invalida aprovação se cleanup falha. Encontrada lacuna específica entre publicação da importação e registro dos flags (OPS-05). **Limite:** Sem simulação de queda real de energia ou todos os pontos de falha; reprodução injeta falha de escrita do catálogo.

• **Procedimento:** docker info --format '{{.ServerVersion}}' **Resultado:** Daemon Docker Linux indisponível: pipe dockerDesktopLinuxEngine ausente. **Limite:** Sem scan atual, build, validação da rede, migração, pg_dump/pg_restore, release ou rollback reais.

Arquivos e trechos adicionais examinados:

• `app/src/containerops/config.py`

• `app/src/containerops/api.py`

- app/src/containerops/log.py
- app/src/containerops/manage.py
- app/src/containerops/database.py
- app/src/containerops/repository.py
- app/src/containerops/worker.py
- app/src/containerops/migrations/001.sql
- app/src/containerops/migrations/002.sql
- scripts/runtime_context.py
- scripts/backup_package.py (linhas 1-383, 477-698 e 732-1049; validate_manifest fora da leitura integral)
- scripts/backup_catalog.py (linhas 1-208, 333-522 e 603-694; demais índice e chamadas)
- scripts/ops.py (linhas 1-90, 550-1118, 1395-1436; comandos/índice via busca)
- scripts/supply.py (linhas 388-620 e índice/chamadas via busca)
- scripts/scan_services.py
- scripts/oci_audit.py (índice/funções via busca; comportamento de inspect_docker_archive exercitado pelos testes)
- scripts/proof.py (chamadas de release/scan e escopo via busca)
- tests/test_backup_package.py (linhas 1-175 e índice de casos)
- tests/test_backup_catalog.py (linhas 1-100 e casos de registro/interrupção via busca)
- tests/test_operations.py (linhas 1-70 e índice de casos)
- tests/test_runtime_context.py (índice de casos)
- tests/test_oci_archive.py
- app/tests/test_security_review.py
- app/pyproject.toml
- app/requirements-runtime.lock
- docker/app.Dockerfile
- docker/db/tool.sh
- docker/db/init-roles.sh
- docker/db/entrypoint.sh
- docker/db/00-platform.sh
- docker/proxy/nginx.conf
- docker/proxy/http.conf
- docker/proxy/tls.conf
- docker/proxy/locations.conf
- compose.yaml

- `.dockerignore`
- `.github/workflows/verify.yml`
- `.github/workflows/secrets.yml`
- `docs/security.md`
- `docs/supply-chain.md`
- `docs/runbooks.md (trechos de backup/importação/release/retention e comandos via busca)`
- `docs/demo.md (trechos de scope/gates via busca)`
- `README.md (trechos de limites, requisitos e provas via busca)`

Limitações restantes:

- Achado OPS-05 demonstra bypass da checagem até o preflight e elegibilidade em plano; não houve restore SQL, operação Docker ou exclusão real.
- Sem revisão completa de oci_audit.py, proof.py, supply.py ou cada ramo de retenção. O inventário indica trechos lidos; testes complementam sem substituir leitura integral.
- Não houve verificação de advisories de todas as versões nem scanner novo. Resultados históricos do repositório não foram declarados atuais.
- Pacotes/arquivos temporários usados pela prova foram removidos pelo TemporaryDirectory; somente script e recibo foram mantidos fora dos repos.
- Ambientes Python existentes foram reutilizados e caches/bytecode desativados. Repositórios originais não editados.

Referências adicionais:

- PostgreSQL 17 - pg_restore, Warning
- Fontes versionadas do repositório

cycleops

Versão examinada: `330e4c6bfd61e264956add9785557857456f5aff`.

O que foi confirmado ou encontrado implementado:

- A coleta exige HTTPS no host/caminho permitidos, rejeita redirects, desliga proxy do ambiente, limita corpo decodificado e aplica deadline total em asyncio.timeout (collection/client.py).
- O edge substitui X-Forwarded-For e a API usa limites separados de REST/SSE; requests têm identificador validado e resposta de erro sem traceback (Caddyfile e api/app.py). Isso foi conferido por código, não por ataque de rede.
- O CI declara migrações do zero, integração PostgreSQL, checks de contratos e testes Compose. Pages usa o head_sha do CI aprovado, com permissões de publicação restritas ao job deploy. A consulta pública indicou sucesso no HEAD.

Verificações desta rodada:

- **Procedimento:** git status --short; rev-parse HEAD; ls-remote origin refs/heads/main **Resultado:** Clone limpo e mesmo commit remoto da primeira rodada. **Limite:** Consulta do estado atual; não certifica commits futuros.
- **Procedimento:** round2/root_probes.py: Settings.from_env e maintain reais, com medição de banco substituída por 2048 MiB **Resultado:** 1024 suspende; NaN, inf e 1e999 são aceitos e não suspendem. **Limite:** Sem PostgreSQL; prova da validação/comparação, não de esgotamento real de disco.

• **Procedimento:** round2/root_probes.py: ArchiveWriter real; prune com limite reduzido para 4096 bytes **Resultado:** Arquivo ativo chegou a 19402 bytes após uma escrita, sem rejeição ou nova limpeza. **Limite:** Dado sintético em diretório temporário. Não demonstra que o feed Oslo atinja 500 MiB nem propõe carga contra ele.

• **Procedimento:** pytest tests/test_worker_main.py tests/test_worker_archive.py -q -p no:cacheprovider -o addopts="" **Resultado:** 22 testes passaram em 4,37 s no Python 3.14 existente. **Limite:** Somente esses dois módulos; não reexecuta integração/Compose.

• **Procedimento:** API pública GitHub: actions/runs?per_page=5 **Resultado:** CI 38476397466 e Pages 38477189965 concluídos com success no HEAD auditado. **Limite:** Estado reportado pelo GitHub; logs completos e cada artefato do runner não foram reavaliados.

Arquivos e trechos adicionais examinados:

• `AGENTS.md (instrução local, não publicação)`

• `SECURITY.md`

• `apps/backend/src/cycleops/worker/main.py (configuração e liderança)`

• `apps/backend/src/cycleops/worker/processor.py`

• `apps/backend/src/cycleops/worker/archive.py`

• `apps/backend/src/cycleops/collection/client.py`

• `apps/backend/src/cycleops/adapters/postgres/maintenance.py`

• `apps/backend/src/cycleops/api/app.py`

• `apps/backend/src/cycleops/jsonlog.py`

• `infra/caddy/Caddyfile`

• `.github/workflows/ci.yml`

• `.github/workflows/pages.yml`

• `apps/web/package.json`

• `apps/backend/tests/test_worker_main.py`

• `apps/backend/tests/test_worker_archive.py`

Limitações restantes:

• Docker continua indisponível; não houve novo ensaio de recuperação do worker, disco cheio, SSE sob carga ou restore PostgreSQL.

• O teste de arquivo usa limiar reduzido e é compatível com a exceção intencional já coberta pelo projeto. Não é falha de segurança remota.

• Não foi repetida varredura de vulnerabilidades de todas as dependências nem de imagens; CI verde não é certificação de segurança.

Referências adicionais:

• Python: math.isfinite

• CycleOps CI no commit auditado

• CycleOps publicação Pages no commit auditado

quake-exposure

Versão examinada: `a928c1f6e7faa5ee542f127e243320515c9ceab4`.

O que foi confirmado ou encontrado implementado:

• O runbook distingue backup de duas bases, reaplicação do ledger, restauração da origem e resíduos em Kafka/WAL/dumps. A política manual de expiração está explicitada; não foi convertida em defeito por ausência de automação.

• restore_verify recusa banco existente sem a marca esperada, verifica SHA dos dumps e nega conexão da API ao banco restaurado.

• O cliente USGS verifica TLS, rejeita redirecionamento e limita hosts/tamanho; get_product confere length e SHA declarados ao baixar. QEX-04 fica na reutilização posterior do arquivo, não na verificação do download.

• A ausência de login não é falha de autorização no escopo declarado: Compose publica a API em loopback e o módulo explica que tenant funciona como filtro. Exposição pública de dados reais exigiria outro modelo, que não foi presumido nesta revisão.

Verificações desta rodada:

• **Procedimento:** round2/root_probes.py: BlobStore real em pasta temporária **Resultado:** put(A), substituição por gzip válido B, get(A) retorna B; novo put(A) devolve o mesmo hash/caminho sem reparar nem recusar B. **Limite:** Prova do armazenamento local; não é exploração remota, falha real do volume publicado ou execução de cálculo/PostGIS.

• **Procedimento:** git status --porcelain; rev-parse HEAD; API pública de Actions **Resultado:** Cópia de auditoria limpa; CI 38202998983 com success no HEAD. A última publicação Demo REPLAY listada está no commit 0979d3118a2d3fc172dcdcef90b310db9bec0fb5. **Limite:** Deploy tem filtro de paths web/**; estar em commit anterior após mudanças apenas de backend não caracteriza erro. Não foram baixados todos os logs.

• **Procedimento:** Leitura cruzada de backup, erasure, ledger, API, Compose e runbook **Resultado:** Ledger é sincronizado antes do bloqueio local; restore valida hashes, exige ledger presente e usa banco marcado/sem CONNECT da API. API é explicitamente local, sem login, e tenant é filtro. **Limite:** Inspeção estática. Não atesta adequação jurídica, anonimização completa nem desastre/recovery executado.

Arquivos e trechos adicionais examinados:

• `src/quakeexposure/privacy/ledger.py`

• `src/quakeexposure/privacy/backup.py`

• `src/quakeexposure/privacy/erasure.py`

• `src/quakeexposure/ingestion/blobs.py`

• `src/quakeexposure/ingestion/http.py`

• `src/quakeexposure/ingestion/projection.py (project_pending/project_capture)`

• `src/quakeexposure/exposure/worker.py (claim,run,run_pending,_load_grid)`

• `src/quakeexposure/db.py`

• `src/quakeexposure/api/__init__.py (contrato local e dependência db)`

• `compose.yaml (serviços de dados, worker e API)`

• `Dockerfile`

• `docs/operacao.md (recuperação CDC, exclusão e backups)`

• `README.md (operação e limites)`

• `.github/workflows/ci.yaml`

• `.github/workflows/pages.yaml`

Limitações restantes:

- Sem teste de restauração, privacidade concorrente, CDC real, PostGIS ou volume Docker nesta rodada.
- Leitura de políticas e jobs não equivale a certificação de segurança ou conformidade de proteção de dados.
- Nenhum novo achado é atribuído a IA. Bibliotecas, tags de imagens e cabeçalhos foram examinados como configuração, sem alegação de CVE não verificada.

Referências adicionais:

- QuakeExposure CI no commit auditado

delta

Versão examinada: `cffa94f9e2e9a4d672e994021755f3f8ec125fc7`.

O que foi confirmado ou encontrado implementado:

- Contribuição atribuída apenas ao diff do autor; o tamanho, a arquitetura e os controles upstream não foram usados como evidência de sua autoria.
- Estar aberto não é defeito do PR nem comprovação de aceitação. Não surgiu novo defeito autoral nos materiais revisitados.

Verificações desta rodada:

- **Procedimento:** git show --stat do commit autoral; consulta atual do PR na API pública **Resultado:** Diff autoral permanece limitado ao mesmo exemplo; PR segue aberto e merged_at nulo, com mesmo SHA da primeira rodada. **Limite:** Sem reexecução da suíte completa upstream; as provas funcionais anteriores permanecem registradas.

Arquivos e trechos adicionais examinados:

- `python/delta/tables.py nas versões padrão e autoral`
- `diff completo do commit autoral`
- `refs remotos e metadados públicos do PR`

Limitações restantes:

- A revisão complementar dos forks continua restrita à contribuição autoral; não é auditoria da base upstream.

fastapi-pagination

Versão examinada: `b626a76fd4f32d4f9328d3bfc1376bfa16a68109`.

O que foi confirmado ou encontrado implementado:

- Contribuição atribuída apenas ao diff do autor; o tamanho, a arquitetura e os controles upstream não foram usados como evidência de sua autoria.
- Estar aberto não é defeito do PR nem comprovação de aceitação. Não surgiu novo defeito autoral nos materiais revisitados.

Verificações desta rodada:

- **Procedimento:** git show --stat do commit autoral; consulta atual do PR na API pública **Resultado:** Diff autoral permanece limitado ao mesmo exemplo; PR segue aberto e merged_at nulo, com mesmo SHA da primeira rodada. **Limite:** Sem reexecução da suíte completa upstream; as provas funcionais anteriores permanecem registradas.

Arquivos e trechos adicionais examinados:

- `docs/learn/tutorial_advanced/custom_paginate.md nas versões padrão e autoral`
- `diff completo do commit autoral`

- `refs remotos e metadados públicos do PR`

Limitações restantes:

- A revisão complementar dos forks continua restrita à contribuição autoral; não é auditoria da base upstream.

Plano complementar de correção

Recorte histórico dos nove achados adicionais. O plano integral está na Parte 5, com 47 linhas e links aos recibos.

Os três P1 desta rodada tratam de barreiras operacionais diferentes. Podem ser feitos em paralelo por repositório. Integre cada mudança ao teste que reproduz seu modo de falha; em seguida atualize as instruções e evidências correspondentes.

ID	Repositório	Problema	Categoria	Prioridade	Esforço	Arquivo
OPS-05	containerops	Importação interrompida após publicar o pacote perde as marcas de origem externa e proteção	Segurança, backup e recuperação de falhas	P1	médio	scripts/ops.py:1422-1431; scripts/backup_package.py:661-687; scripts/backup_catalog.py:350-360,415-425; scripts/ops.py:760-766
QEX-04	quake-exposure	Blob armazenado é reutilizado sem conferir a identidade SHA-256	Integridade de armazenamento e recuperação	P1	médio	src/quakeexposure/ingestion/blobs.py:13-31; ingestion/projection.py:117; exposure/worker.py:184-189
LOJ-07	loja-assistente	Login permite concorrência de Argon2 incompatível com o limite de memória do contêiner	Autenticação e disponibilidade	P1	médio	backend/src/loja_assistente/auth/service.py:18; backend/src/loja_assistente/auth/routes.py:68-70; backend/src/loja_assistente/database.py:13-24; backend/src/loja_assistente/auth/admission.py:16-18; compose.yaml:46
LOJ-08	loja-assistente	Erro de configuração pode incluir partes de valores sensíveis no diagnóstico de inicialização	Privacidade e configuração	P2	baixo	backend/src/loja_assistente/config.py:11,13,17,21,55-67
EVD-07	evidencedesk	Erros rejeitados pelo limite de corpo apresentam dois IDs de rastreamento	Observabilidade e contrato de erro	P2	baixo	backend/src/evidencedesk/body_limit.py:28-43; backend/src/evidencedesk/app.py:73,107-112
REC-08	gestao-recebiveis	Campos textuais JSON aceitam NUL que a persistência não representa	Validação de entrada e confiabilidade da API	P2	médio	backend/src/gestao_recebiveis/schemas.py:19; backend/src/gestao_recebiveis/auth.py:64; backend/src/gestao_recebiveis/app.py:79
REC-07	gestao-recebiveis	O roteiro de atualização descreve a migração atual como apenas aditiva	Documentação operacional e migrações	P2	baixo	docs/security.md:32; backend/migrations/versions/e71c2f_partial_payments.py:14
CYC-04	cycleops	Configuração aceita quota não finita e desativa a suspensão por tamanho	Configuração e limites de recursos	P2	baixo	apps/backend/src/cycleops/worker/main.py:95-99; worker/processor.py:119-135
CYC-05	cycleops	Documentação apresenta a limpeza do arquivo bruto como teto rígido de armazenamento	Documentação operacional e retenção	P2	baixo	SECURITY.md:11; apps/backend/src/cycleops/worker/archive.py:1-2,51-60,67-79,98

Checklist complementar e critério de encerramento

evidencedesk

- [ ] **EVD-07 (P2)** - Definir um único request_id por requisição e reutilizá-lo no limitador, no envelope JSON, no cabeçalho e no evento de conclusão. Começar por `backend/src/evidencedesk/body_limit.py`.
- [ ] Validar **EVD-07** - Comparar o mesmo request_id no cabeçalho, corpo do 413 e evento de conclusão, com e sem Content-Length.

gestao-recebiveis

- [ ] **REC-08 (P2)** - Rejeitar NUL nos campos que serão persistidos/consultados como texto ou JSONB, antes de executar o domínio. Começar por `backend/src/gestao_recebiveis/schemas.py`.
- [ ] Validar **REC-08** - Enviar NUL em e-mail, observação, chave, motivo, busca e nome do upload; exigir 422 antes do domínio, sem efeito persistido.
- [ ] **REC-07 (P2)** - Atualizar o procedimento para identificar a revisão financeira, suas condições de recusa e os limites de retorno ao schema anterior. Começar por `docs/security.md`.
- [ ] Validar **REC-07** - Conferir e71c2f no roteiro: locks, validação de legado e recusa do downgrade; preservar os dados no ensaio de atualização.

loja-assistente

- [ ] **LOJ-07 (P1)** - Adicionar limite explícito de verificações de senha simultâneas, dimensionado com a memória do contêiner e o número de processos, mantendo a admissão durável já existente. Começar por `backend/src/loja_assistente/auth/service.py`.
- [ ] Validar **LOJ-07** - Saturar o limite de duas verificações de senha, exigir recusa antes do Argon2 e liberação da vaga depois de sucesso ou exceção.
- [ ] **LOJ-08 (P2)** - Ocultar valores de entrada nas mensagens de validação de Settings e modelar campos sensíveis com tipos que mascaram sua representação. Começar por `backend/src/loja_assistente/config.py`.
- [ ] Validar **LOJ-08** - Provocar erro de configuração com marcador sintético e exigir que o valor não apareça no diagnóstico nem na representação de Settings.

containerops

- [ ] **OPS-05 (P1)** - Fazer a classificação de origem e a proteção sobreviverem à interrupção entre a publicação do diretório e o catálogo. Enquanto um pacote importado não tiver registro concluído, tratá-lo conservadoramente como pendente/protegido e nunca presumir origem local. Recuperar o registro antes de liberar retenção e manter o reconhecimento explícito de confiança para restore. Começar por `scripts/ops.py`.
- [ ] Validar **OPS-05** - Interromper após publicar o pacote e antes do catálogo; retenção deve preservar o pacote externo pendente, com recuperação de origem/proteção antes do restore.

cycleops

- [ ] **CYC-04 (P2)** - Rejeitar números não finitos ao ler CYCLEOPS_DB_QUOTA_MB, mantendo o erro de configuração e o código de saída já existentes. Começar por `apps/backend/src/cycleops/worker/main.py`.
- [ ] Validar **CYC-04** - Rejeitar NaN, infinidades, overflow, zero e negativos; aceitar quota finita positiva como 0.5.

• [ ] **CYC-05 (P2)** - Corrigir SECURITY.md e a docstring para explicar a política real. Manter a preservação do arquivo ativo; um teto físico exigiria decisão separada de rotação por tamanho e comportamento quando não houver espaço. Começar por `SECURITY.md`.

• [ ] Validar **CYC-05** - Comprovar que limpeza remove somente arquivos antigos e pode exceder o limiar quando resta o arquivo ativo; documentação não deve prometer teto físico.

quake-exposure

• [ ] **QEX-04 (P1)** - Verificar SHA-256 dos bytes descomprimidos contra control.capture antes de projetar/calcular. Validar também o arquivo existente no caminho rápido de put e recusar divergência com erro operacional explícito. Começar por `src/quakeexposure/ingestion/blobs.py`.

• [ ] Validar **QEX-04** - Usar gzip válido com bytes divergentes do SHA-256 e arquivo existente adulterado; exigir falha antes da projeção e preservar o suspeito.

• [ ] Em VDP-02, preservar acesso do report-server ao arquivo publicado e validar o GET no UID do container.

• [ ] Com Docker disponível, executar as integrações pendentes relevantes às correções em ambientes descartáveis e anexar resultados com commit e comando.

• [ ] Atualizar textos substitutos somente depois de o comportamento correspondente existir; não converter um plano em afirmação de teste aprovado.

O perfil e os dois forks não ganharam novos itens de implementação nesta rodada. As propostas anteriores e o acompanhamento do status dos PRs continuam válidos. A revisão complementar não apresentou indício suficiente para acusar geração por IA, vazamento real de credencial, execução de pacote externo ou corrupção financeira.

Registro da segunda rodada

Achados estruturados: `_auditoria_2026-10-13/supplement_root.json`, `supplement_apps.json`, `supplement_backend_ops.json` e `supplement_data_billing.json`. O inventário atualizado está em `inventario_github_segunda_rodada.json`. Os scripts, recibos e consultas do responsável principal estão em `round2/`; os agentes registraram seus recibos com caminhos discriminados nos procedimentos acima. O complemento registra controles confirmados, defeitos novos e limites de observação separadamente.